Attacking a cluster

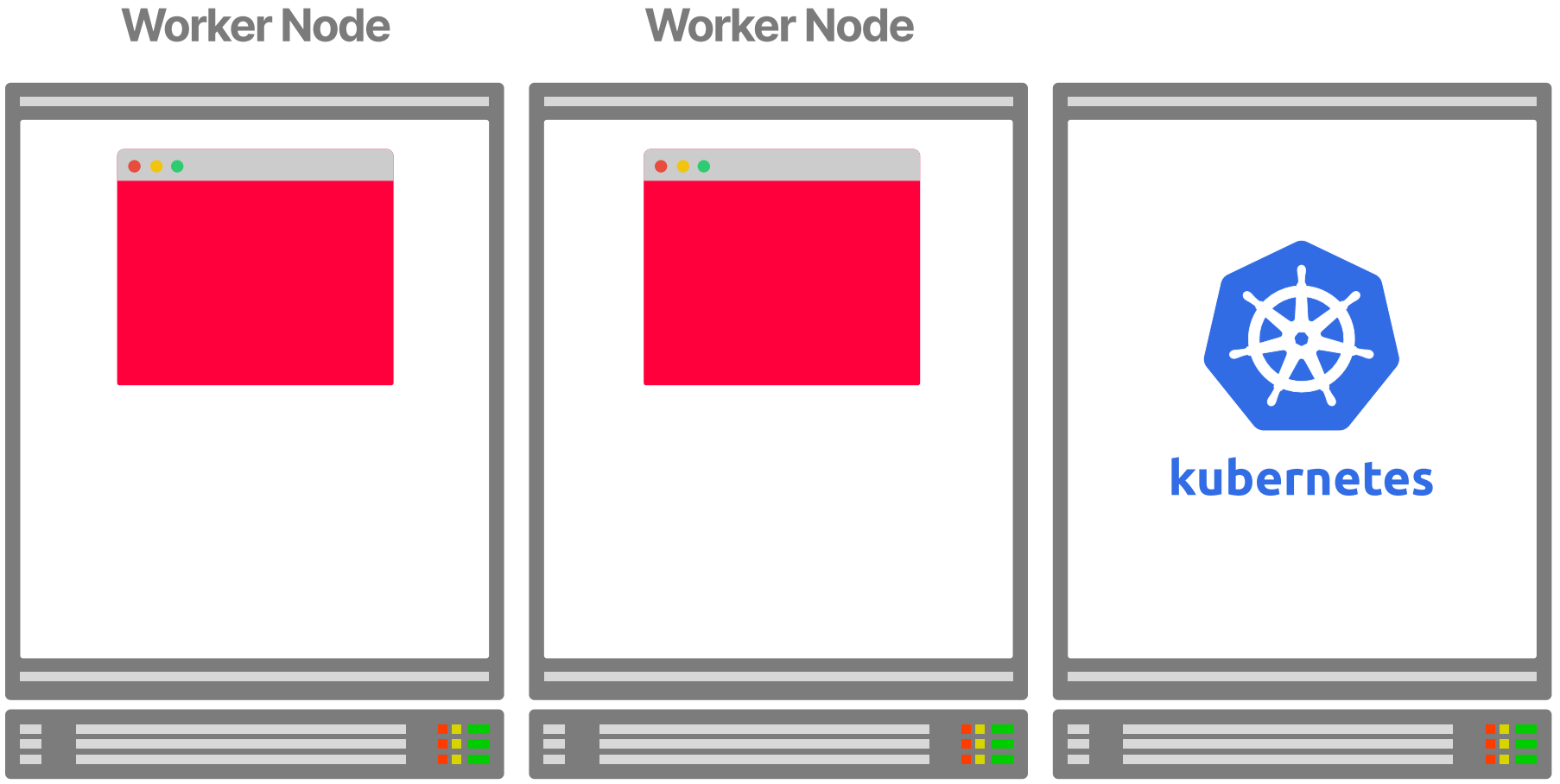
Threat matrix for Kubernetes

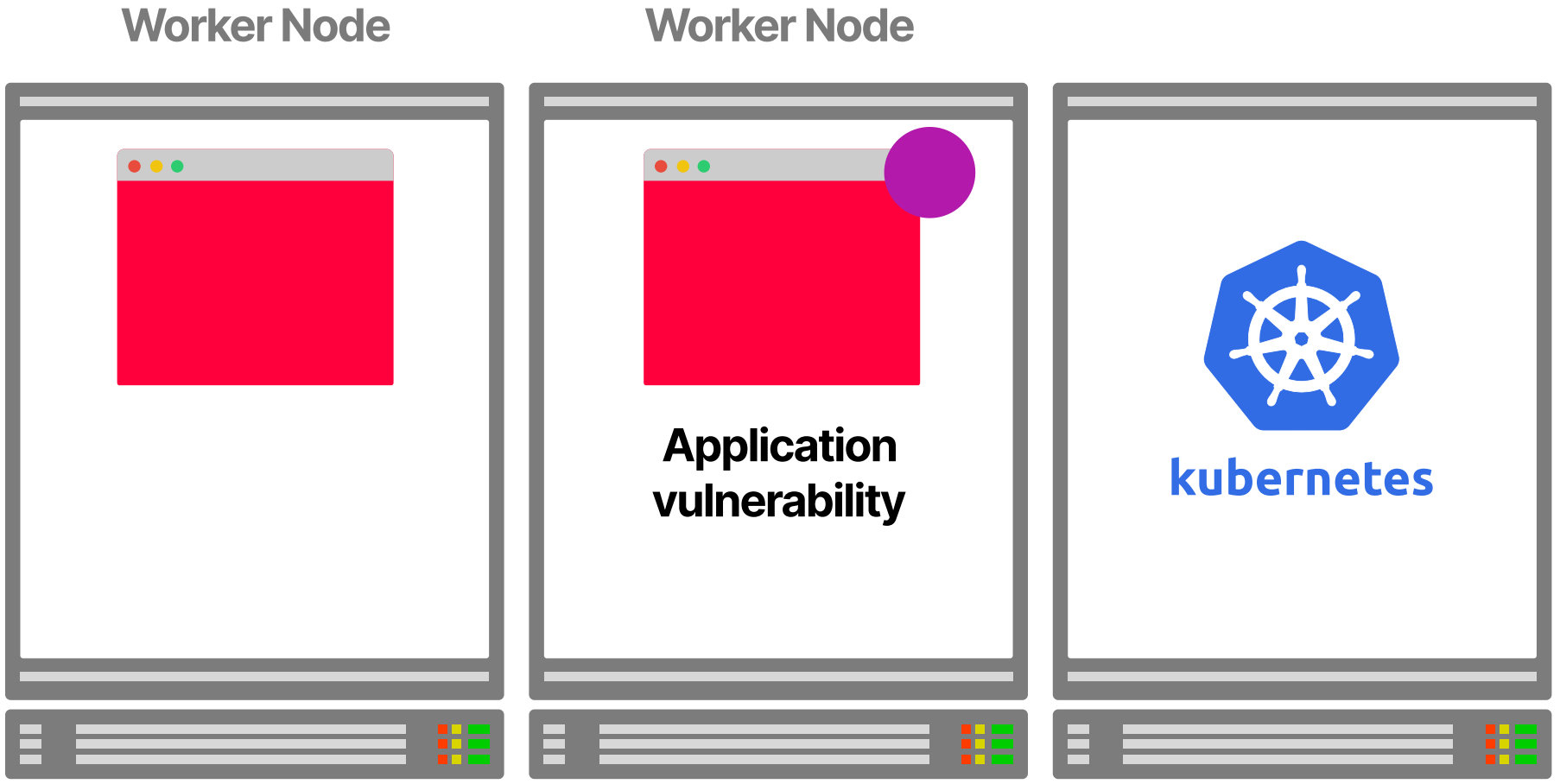
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container	Backdoor container	Priviliged container	Clear container logs	Kubernetes secrets	Access the Kubernetes API server	Access cloud resources
Compromised images in registry	bash/cmd inside container	Writable hostPath mount	Cluster-admin binding	Delete Kubernetes events	Kubernetes IAMs	Access Kubelet API	Pod service account
Kubeconfig file	New container	Kubernetes CronJob	hostPath mount	Pod / container name squatting	Pod service account	Network mapping	Cluster internal networking
Application vulnerability		Malicious admission controller	Access to cloud resources	Connect from proxy server	Applications credentials	Access Kubernetes dashboard	Application credentials
Exposed sensitive interfaces					Access managed identities credentials	Instance metadata API	Writable volume mounts on the host
Control plane + kubelet misconfiguration					Malicious admission controller		CoreDNS poisoning
							ARP poisoning and IP spoofing
							Container escape

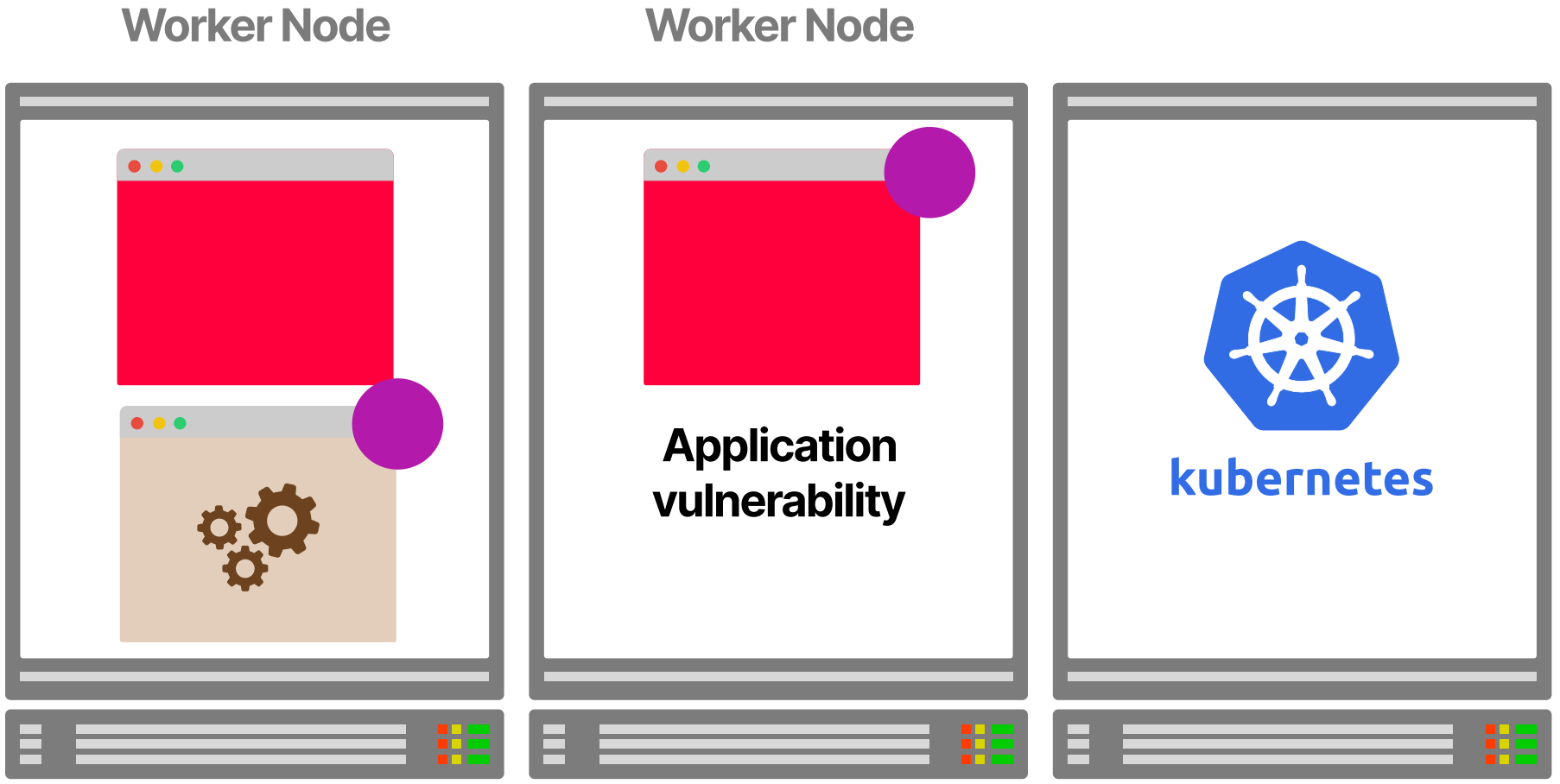
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement

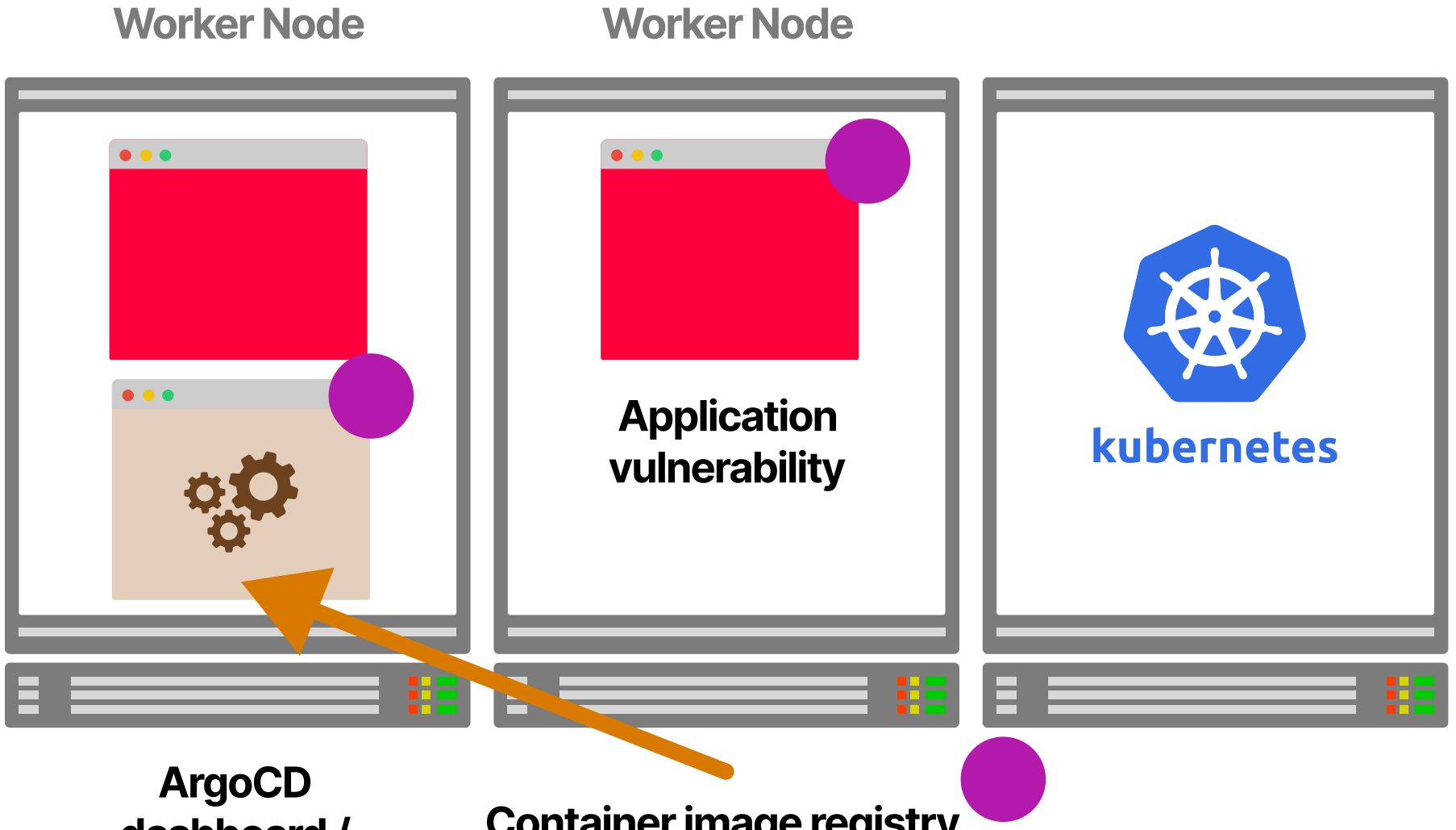
Initial access

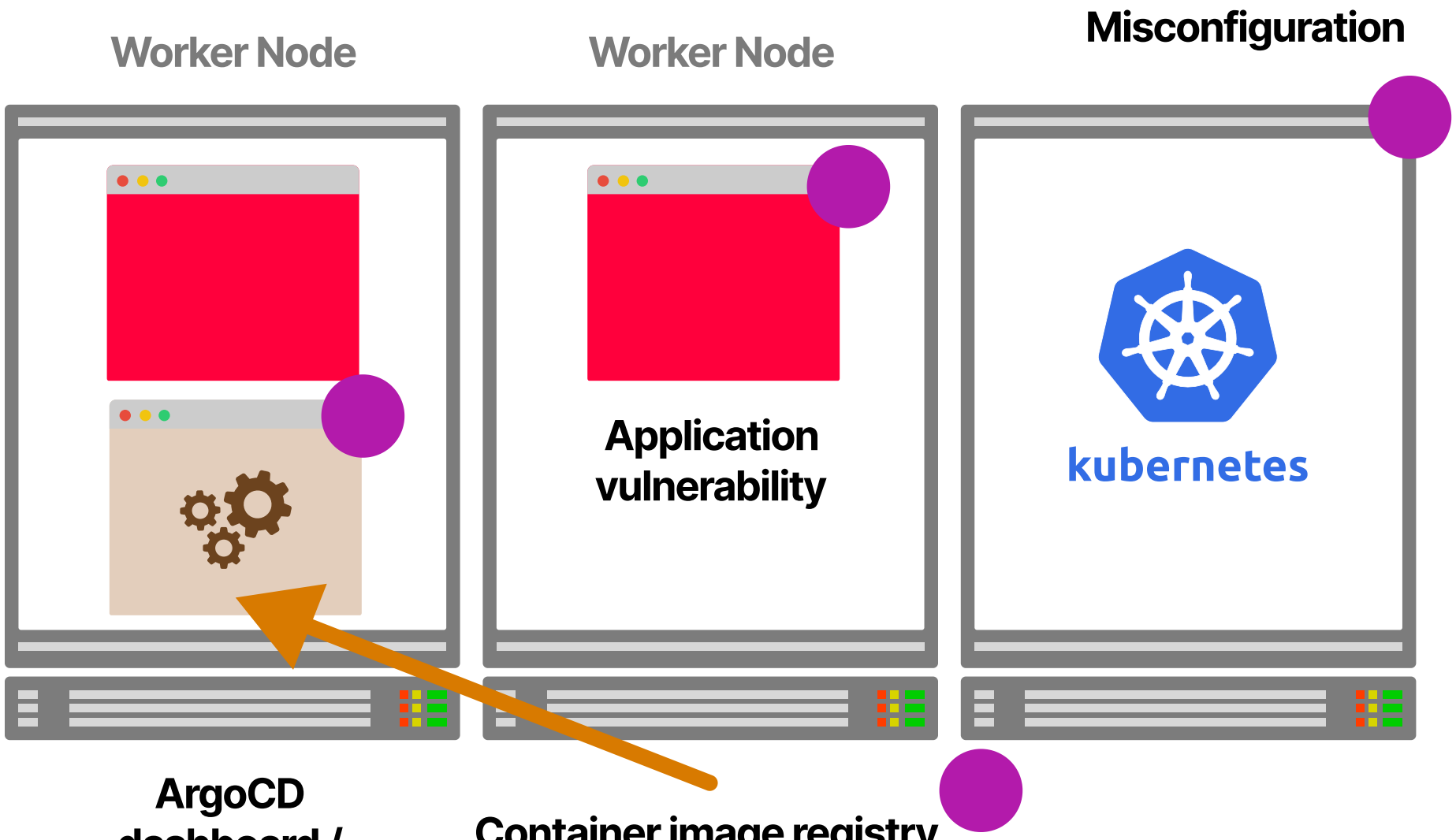
01

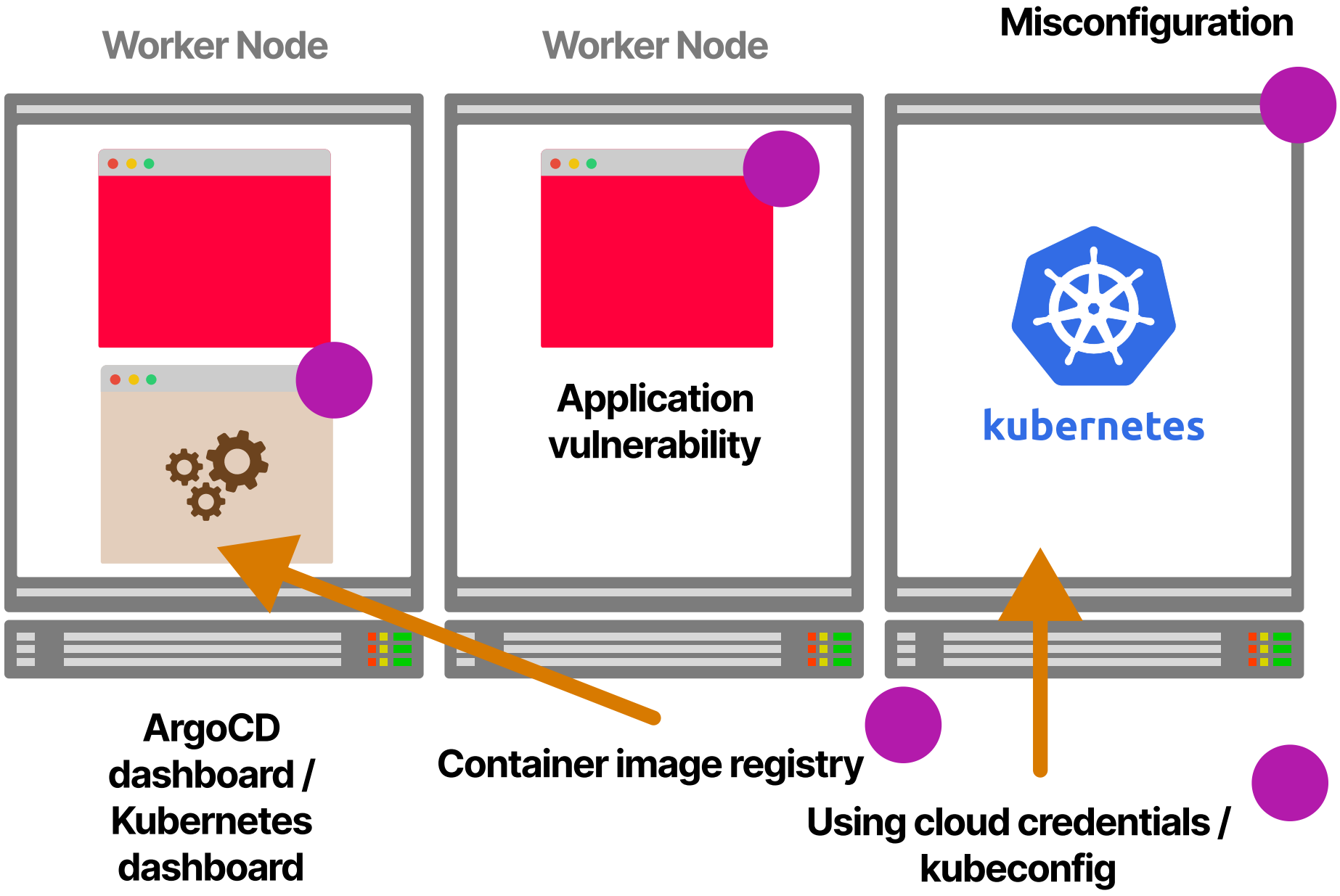

Worker Node
Worker Node
kubernetes


Worker Node
Worker Node
Application vulnerability
kubernetes


Worker Node
Worker Node
Application vulnerability
kubernetes
ArgoCD dashboard / Kubernetes dashboard

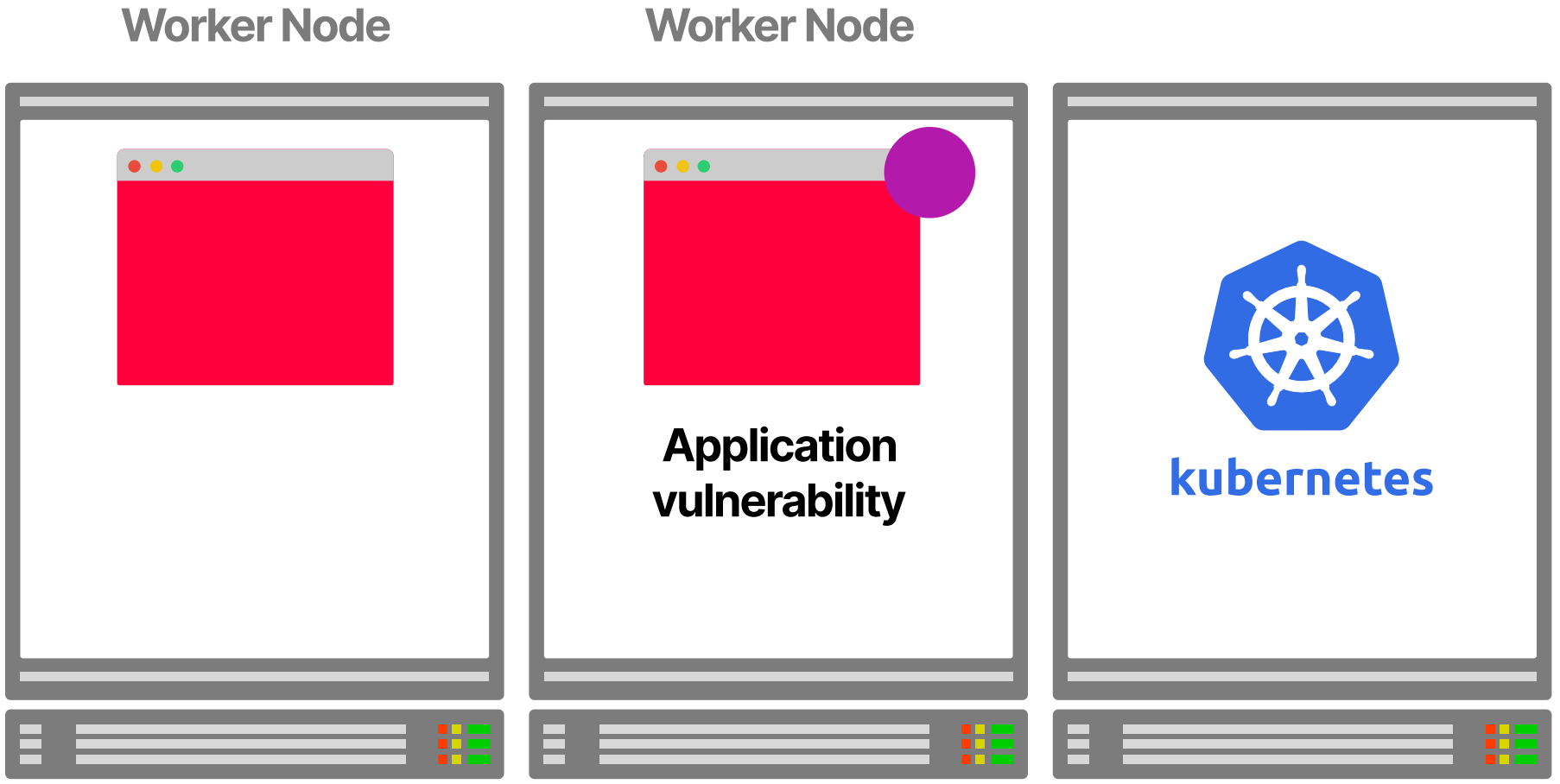

Worker Node
Worker Node
Application vulnerability
kubernetes
ArgoCD dashboard / Kubernetes dashboard
Container image registry


Worker Node
Worker Node
Misconfiguration
Application vulnerability
kubernetes
ArgoCD dashboard / Kubernetes dashboard
Container image registry


Worker Node
Worker Node
Misconfiguration
Application vulnerability
kubernetes
ArgoCD dashboard / Kubernetes dashboard
Container image registry
Using cloud credentials / kubeconfig

Initial access

1 Application vulnerabilities


Worker Node
Worker Node
Application vulnerability
kubernetes

1. Application vulnerabilities

OWASP scanning

Code quality tools

Static code analyzers

Dependency scanners

1. Application vulnerabilities

OWASP scanning

Code quality tools

Static code analyzers

Dependency scanners

1. Application vulnerabilities

OWASP scanning

Code quality tools

Static code analyzers

Dependency scanners

1. Application vulnerabilities

OWASP scanning

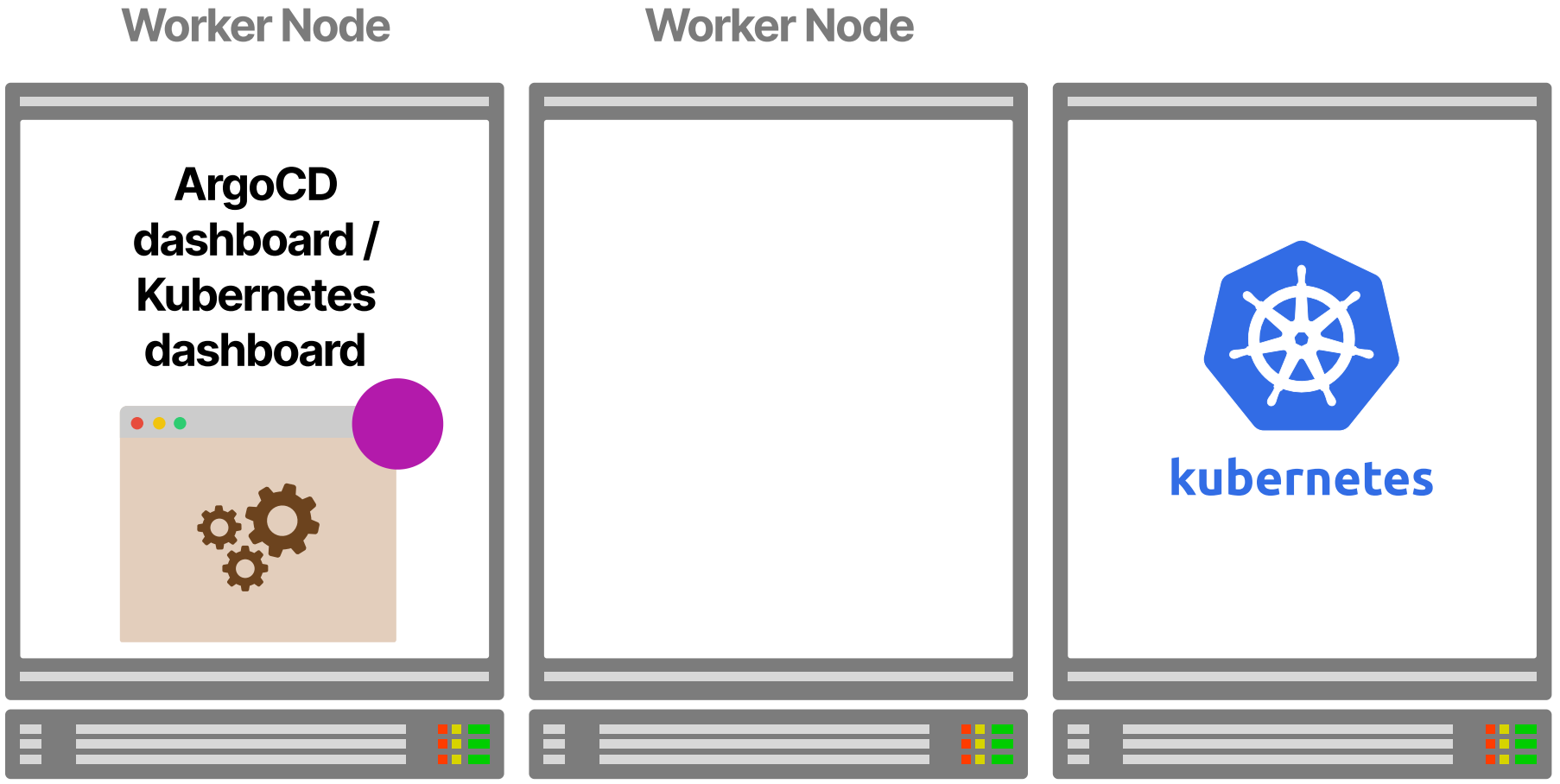
Code quality tools

Static code analyzers

Dependency scanners

Initial access

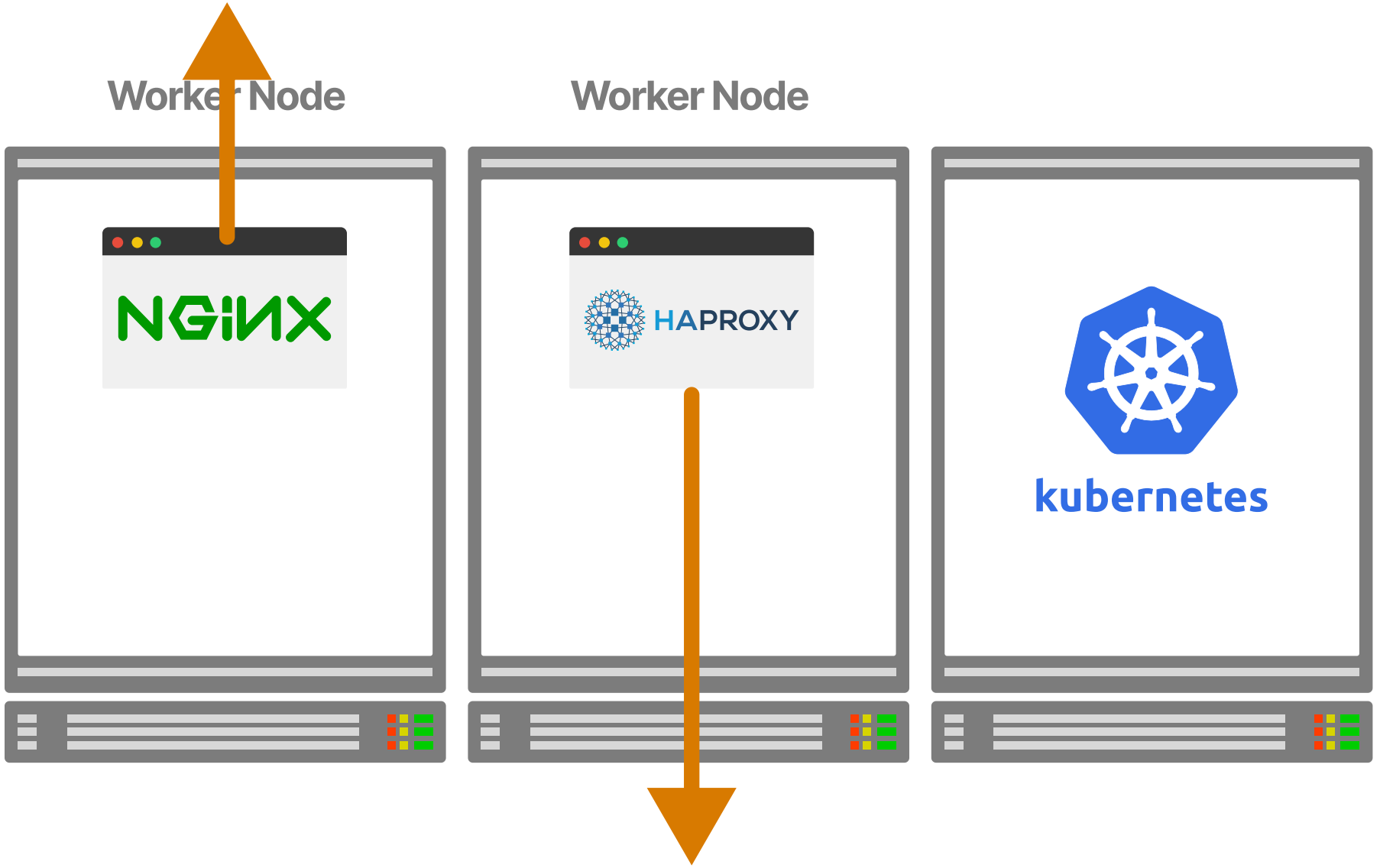
2 Exposed sensitive interfaces


Worker Node
Worker Node
ArgoCD dashboard / Kubernetes dashboard
kubernetes

2. Exposed sensitve interfaces

Internal ingress

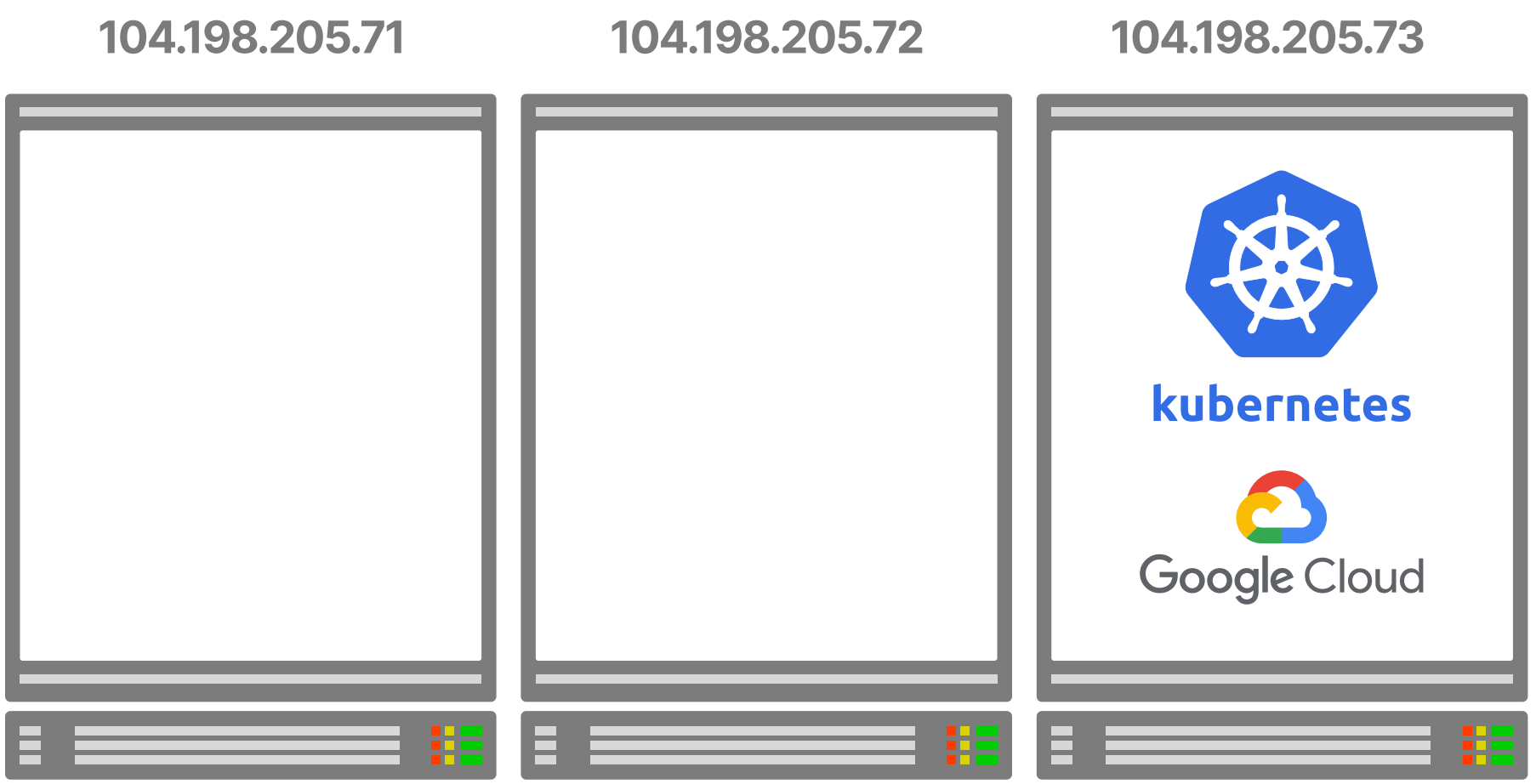
Nodes internal network

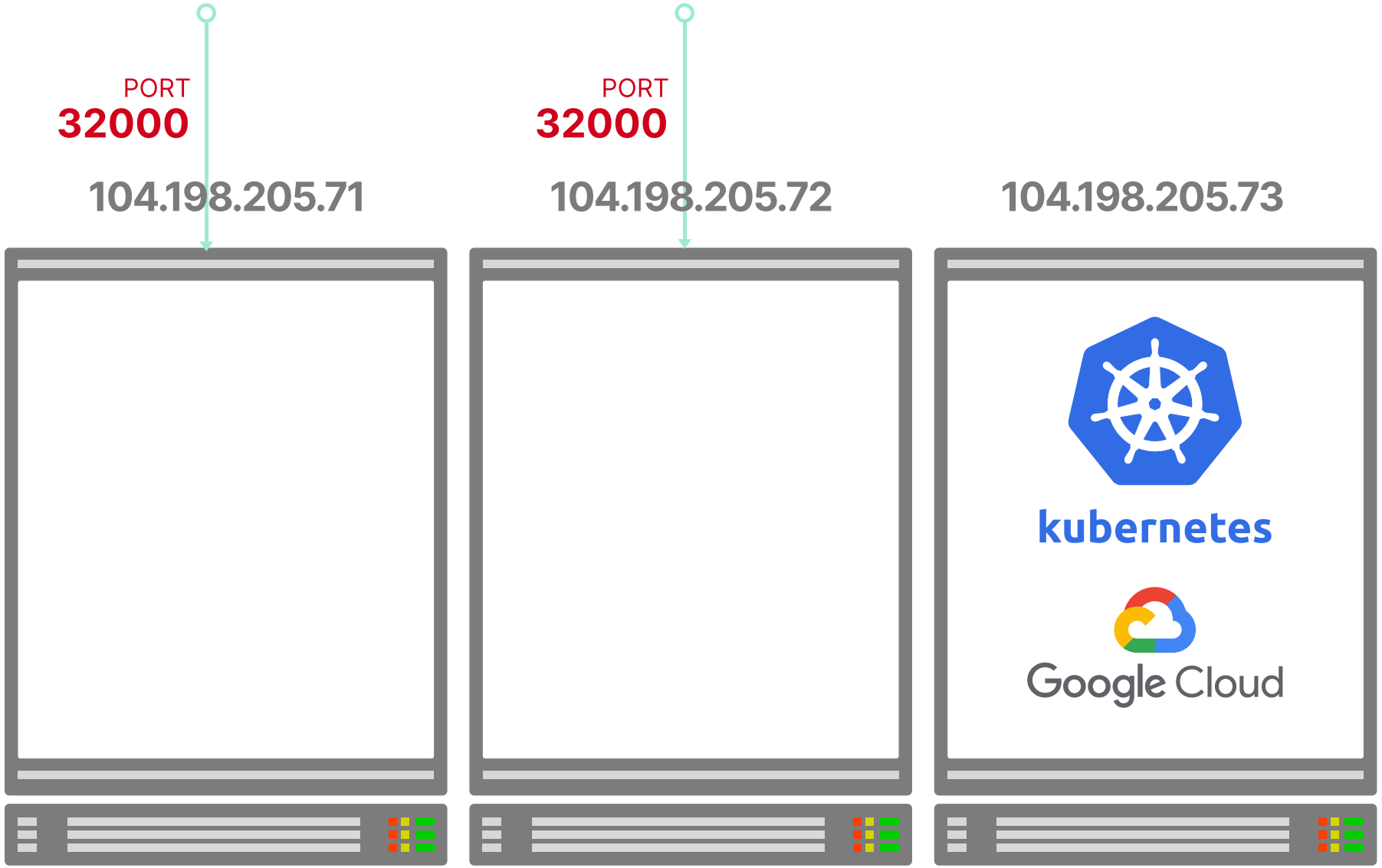

Worker Node
Worker Node
NGINX
HAPROXY
kubernetes

2. Exposed sensitve interfaces

Internal ingress

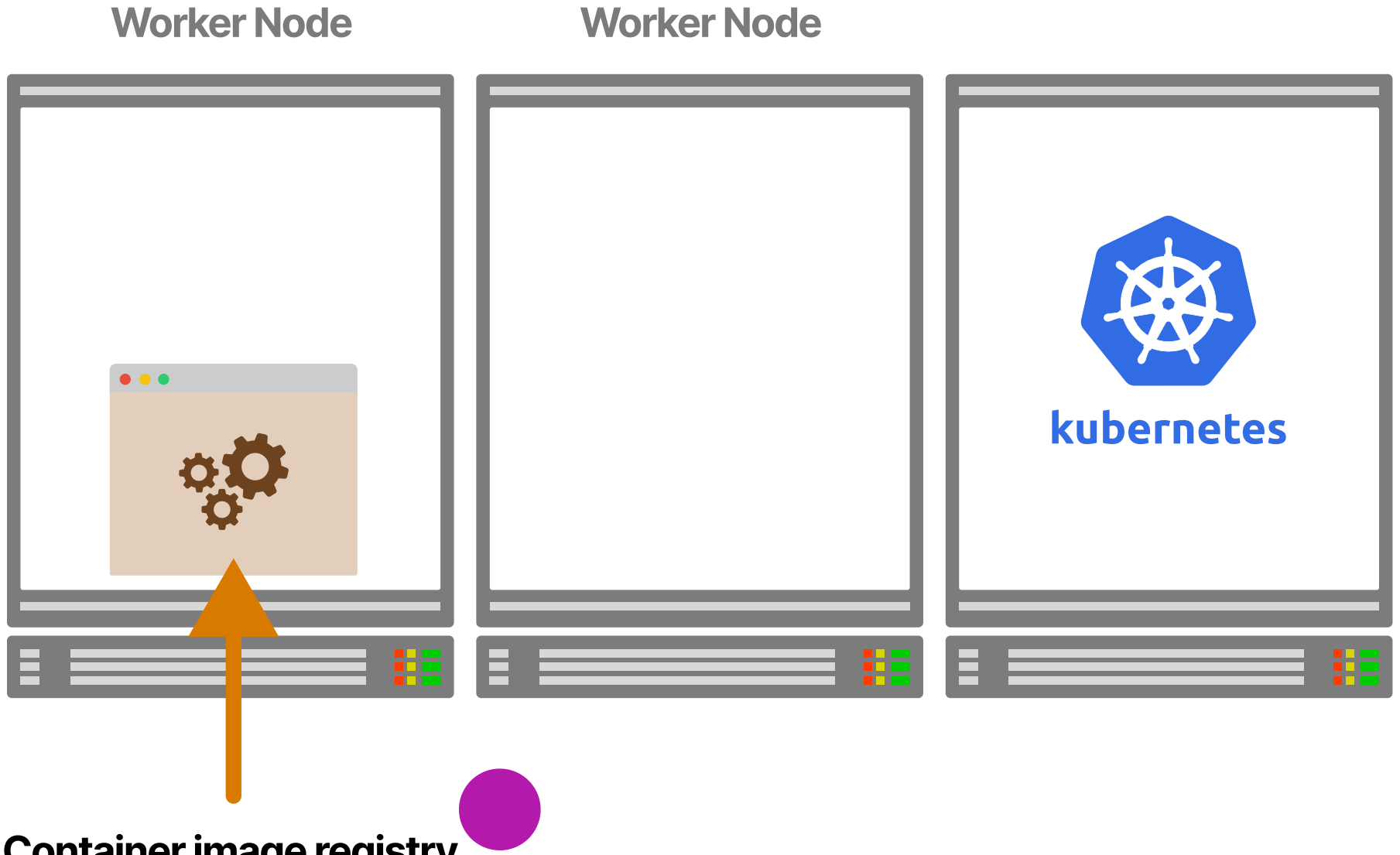
Nodes internal network


104.198.205.71
104.198.205.72
104.198.205.73
kubernetes
Google Cloud


PORT
32000
104.198.205.71
PORT
32000
104.198.205.72
104.198.205.73
kubernetes
Google Cloud

Initial access

3 Container image registry


Worker Node
Worker Node
kubernetes
Container image registry

3. Container image registry

Notarization

Allowlist for images

Allowlist for registry

3. Container image registry

Notarization

Allowlist for images

Allowlist for registry



3. Container image registry

Notarization

Allowlist for images

Allowlist for registry

3. Container image registry

Notarization

Allowlist for images

Allowlist for registry

3. Container image registry

Notarization

Allowlist for images

Allowlist for registry

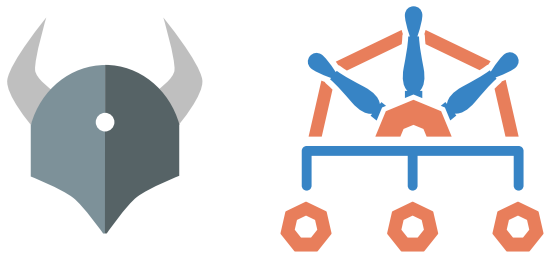


3. Container image registry

Notarization

Allowlist for images

Allowlist for registry



3. Container image registry

Notarization

Allowlist for images

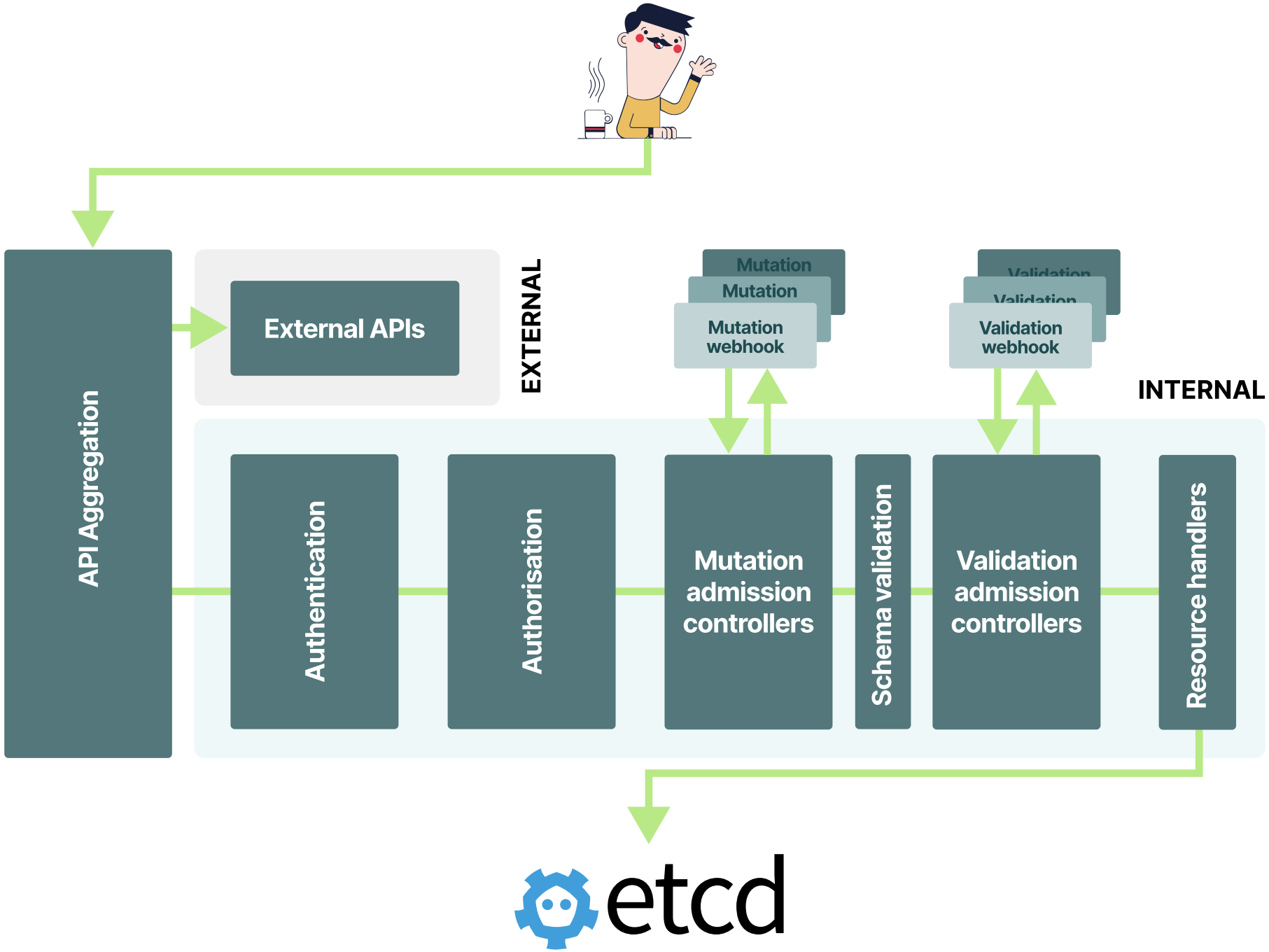
Allowlist for registry

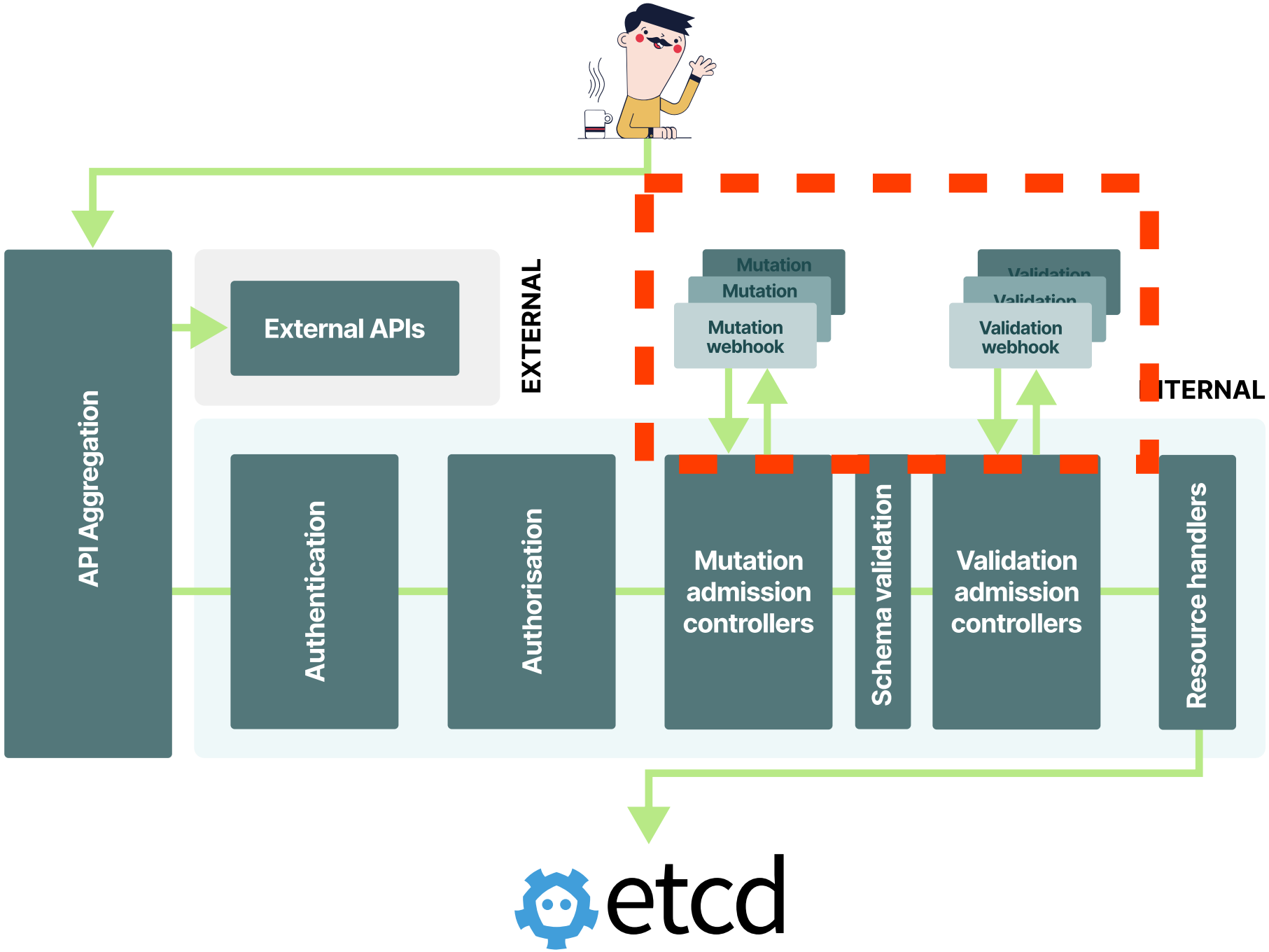




polaris

Open Policy Agent

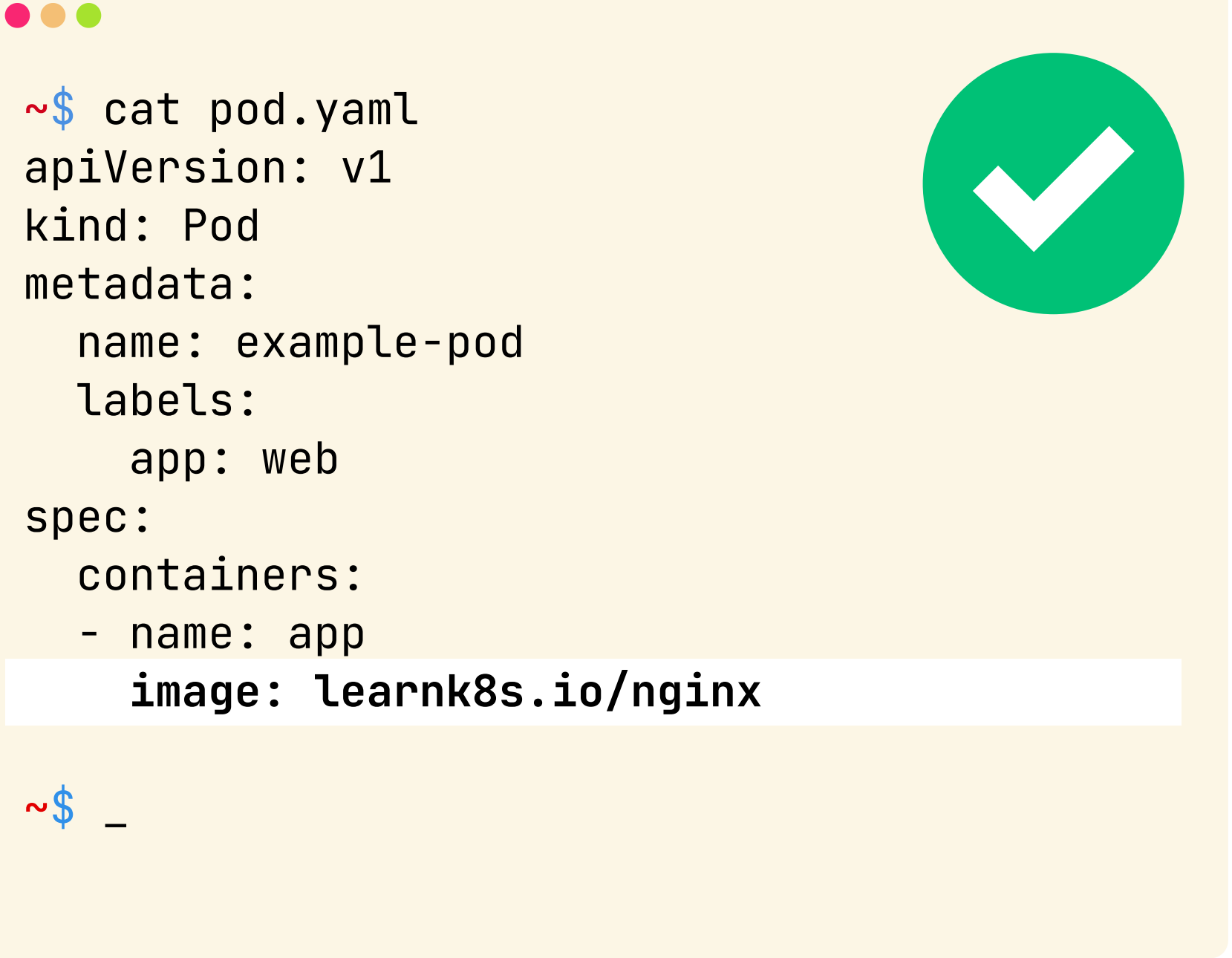

API Aggregation
External APIs
EXTERNAL
Mutation
Mutation
Mutation webhook
Validation
Validation
Validation webhook
INTERNAL
Authentication
Authorisation
Mutation admission controllers
Schema validation
Validation admission controllers
Resource handlers
etcd


API Aggregation
External APIs
EXTERNAL
Mutation
Mutation
Mutation webhook
Validation
Validation
Validation webhook
ITERNAL
Authentication
Authorisation
Mutation admission controllers
Schema validation
Validation admission controllers
Resource handlers
etcd

```
package kubernetes.admission

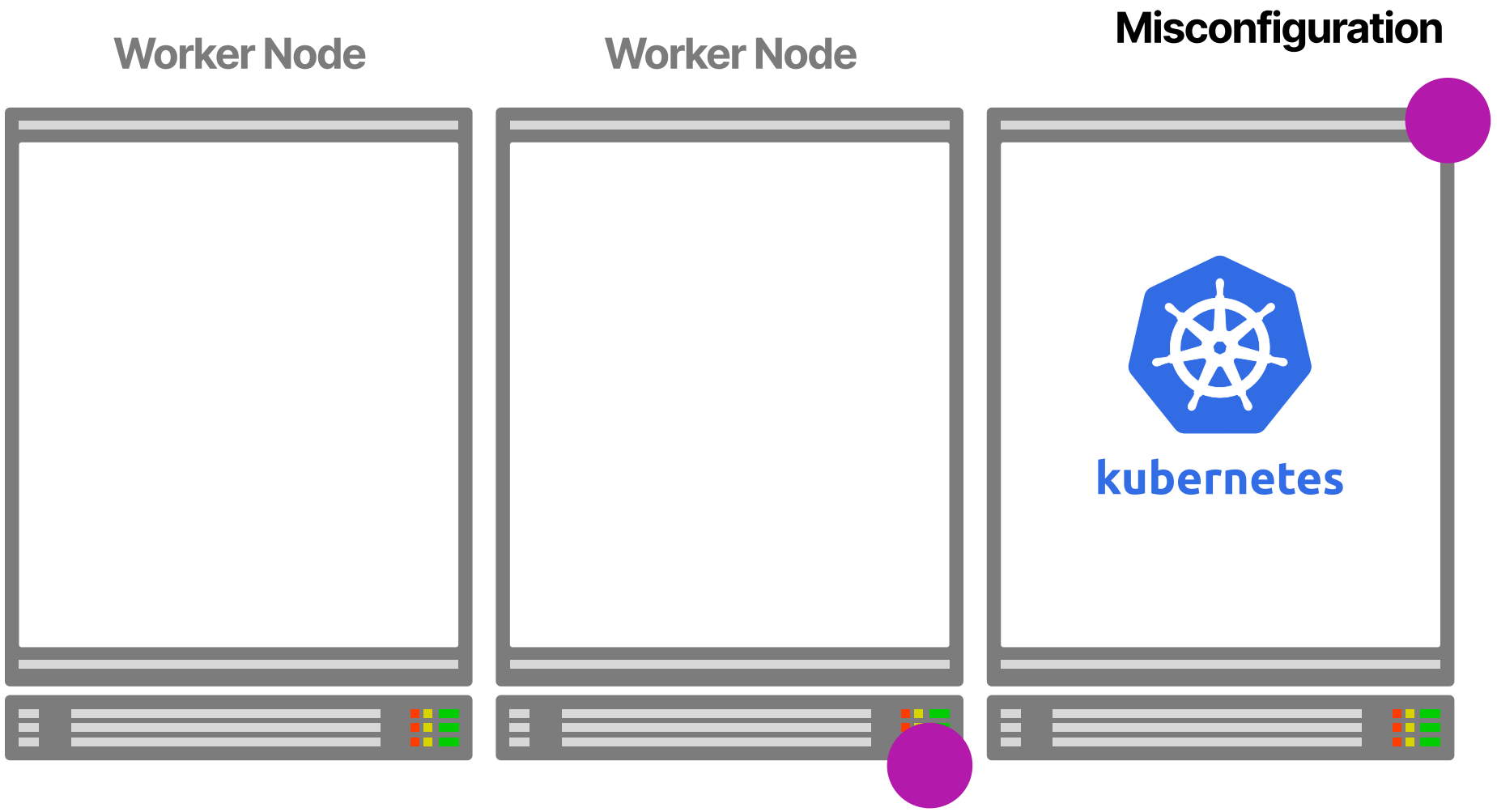
deny[msg] {
    input.request.kind.kind == "Pod"
    some i
    image := input.request.object.spec.containers[i].image
    not startswith(image, "learnk8s.io/")
    msg := sprintf("image '%v' from untrusted registry", [image])
}
```


~$ cat pod.yaml
apiVersion: v1
kind: Pod
metadata:
name: example-pod
labels:
app: web
spec:
containers:
- name: app
image: nginx
~$ _


~$ cat pod.yaml
apiVersion: v1
kind: Pod
metadata:
name: example-pod
labels:
app: web
spec:
containers:
- name: app
image: learnk8s.io/nginx
~$ _

Initial access

4 Control plane & kubelet misconfiguration


Misconfiguration
Worker Node
Worker Node
kubernetes

4. Control plane & kubelet misconfiguration



4. Control plane & kubelet misconfiguration



4. Control plane & kubelet misconfiguration

aquasecurity/kube-bench

derailed/popeye

cyberark/kubesploit

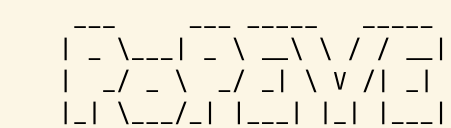
```
[INFO] 1 Master Node Security Configuration
[INFO] 1.1 API Server
[WARN] 1.1.1 Ensure that the --anonymous-auth argument is set to false (Not Scored)
[PASS] 1.1.2 Ensure that the --basic-auth-file argument is not set (Scored)
[PASS] 1.1.3 Ensure that the --insecure-allow-any-token argument is not set (Not Scored)
[PASS] 1.1.4 Ensure that the --kubelet-https argument is set to true (Scored)
[PASS] 1.1.5 Ensure that the --insecure-bind-address argument is not set (Scored)
[PASS] 1.1.6 Ensure that the --insecure-port argument is set to 0 (Scored)
[PASS] 1.1.7 Ensure that the --secure-port argument is not set to 0 (Scored)
[FAIL] 1.1.8 Ensure that the --profiling argument is set to false (Scored)
[FAIL] 1.1.9 Ensure that the --repair-malformed-updates argument is set to false (Scored)
[PASS] 1.1.10 Ensure that the admission control plugin AlwaysAdmit is not set (Scored)
[FAIL] 1.1.11 Ensure that the admission control plugin AlwaysPullImages is set (Scored)
[INFO] 1.1.12 [DEPRECATED] Ensure that the admission control plugin DenyEscalatingExec is set (Not Scored)
[WARN] 1.1.13 Ensure that the admission control plugin SecurityContextDeny is set (Not Scored)
[PASS] 1.1.14 Ensure that the admission control plugin NamespaceLifecycle is set (Scored)
[FAIL] 1.1.15 Ensure that the --audit-log-path argument is set as appropriate (Scored)
[FAIL] 1.1.16 Ensure that the --audit-log-maxage argument is set to 30 or as appropriate (Scored)
[FAIL] 1.1.17 Ensure that the --audit-log-maxbackup argument is set to 10 or as appropriate (Scored)
[FAIL] 1.1.18 Ensure that the --audit-log-maxsize argument is set to 100 or as appropriate (Scored)
[PASS] 1.1.19 Ensure that the --authorization-mode argument is not set to AlwaysAllow (Scored)
[PASS] 1.1.20 Ensure that the --token-auth-file parameter is not set (Scored)
[FAIL] 1.1.21 Ensure that the --kubelet-certificate-authority argument is set as appropriate (Scored)
[PASS] 1.1.22 Ensure that the --kubelet-client-certificate and --kubelet-client-key arguments are set
[PASS] 1.1.23 Ensure that the --service-account-lookup argument is set to true (Scored)
[FAIL] 1.1.24 Ensure that the admission control plugin PodSecurityPolicy is set (Scored)
[PASS] 1.1.25 Ensure that the --service-account-key-file argument is set as appropriate (Scored)
[PASS] 1.1.26 Ensure that the --etcd-certfile and --etcd-keyfile arguments are set as appropriate (Scored)
[PASS] 1.1.27 Ensure that the admission control plugin ServiceAccount is set(Scored)
[PASS] 1.1.28 Ensure that the --tls-cert-file and --tls-private-key-file arguments are set as appropriate
[PASS] 1.1.29 Ensure that the --client-ca-file argument is set as appropriate (Scored)
[WARN] 1.1.30 Ensure that the API Server only makes use of Strong Cryptographic Ciphers (Not Scored)
[PASS] 1.1.31 Ensure that the --etcd-cafile argument is set as appropriate (Scored)
[PASS] 1.1.32 Ensure that the --authorization-mode argument is set to Node (Scored)
[PASS] 1.1.33 Ensure that the admission control plugin NodeRestriction is set (Scored)
[FAIL] 1.1.34 Ensure that the --encryption-provider-config argument is set as appropriate (Scored)
```

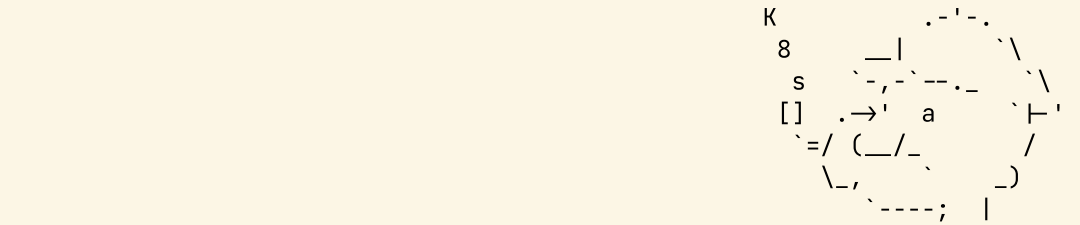
4. Control plane & kubelet misconfiguration

aquasecurity/kube-bench

derailed/popeye

cyberark/kubesploit





GENERAL [MINIKUBE]

```
  · Connectivity.....................................................................
  · MetricServer.....................................................................
```

CLUSTER (1 SCANNED) 0 0 0 1 100

```
  · Version..........................................................................
      [POP-406] K8s version OK.
```

CLUSTERROLES (64 SCANNED) 0 0 15 49 100

```
  · admin............................................................................
      [POP-400] Used? Unable to locate resource reference.
  · cluster-admin....................................................................
  · edit.............................................................................
      [POP-400] Used? Unable to locate resource reference.
  · kubeadm:get-nodes................................................................
  · system:aggregate-to-admin........................................................
      [POP-400] Used? Unable to locate resource reference.
  · system:aggregate-to-edit.........................................................
      [POP-400] Used? Unable to locate resource reference.
  · system:aggregate-to-view.........................................................
      [POP-400] Used? Unable to locate resource reference.
  · system:aggregated-metrics-reader.................................................
```

4. Control plane & kubelet misconfiguration

aquasecurity/kube-bench

derailed/popeye

cyberark/kubesploit



```
                    ,(
                 ((((((((((*
              ((((((((((((((((((((
          ((((((((((((((((((((((((((((((
      ((((((((((((((#        .((((((((((((((#
     /((((((((((((               ((((((((((((
     ((((((((((((                 ((((((((((((
    ((((((((((((        (((        ((((((((((*
    ((((((               , /              ((((((
   (((((((#                               ((((((((
  .((((((((,                             (((((((((
  ((((((((((((        *(((  (((((    ((((((((((((
 /((((((((((((             ((((((   ((((((((((((
  #((((((((((((              ((((( ,(((((((((((((*
    ((((((((((/          (         .#((((((((((*
      #((((((((((                ((((((((((/
        ((((((((((    ( ( ( (   ((((((((((*
          ((((((((((((((((((((((((((A((/
            ((((((((  KUBESPLOIT  (((((((*
              ((((((((((((((((((((((*
                 Version: 0.1.1
                 Merlin version: 0.9.1
                 Build: 3e8ae779c355e325b1f667efefa433e5373b6f1e
                 GitHub: https://github.com/cyberark/kubesploit

[+] Reading config YAML file

[+] Parsing config YAML file

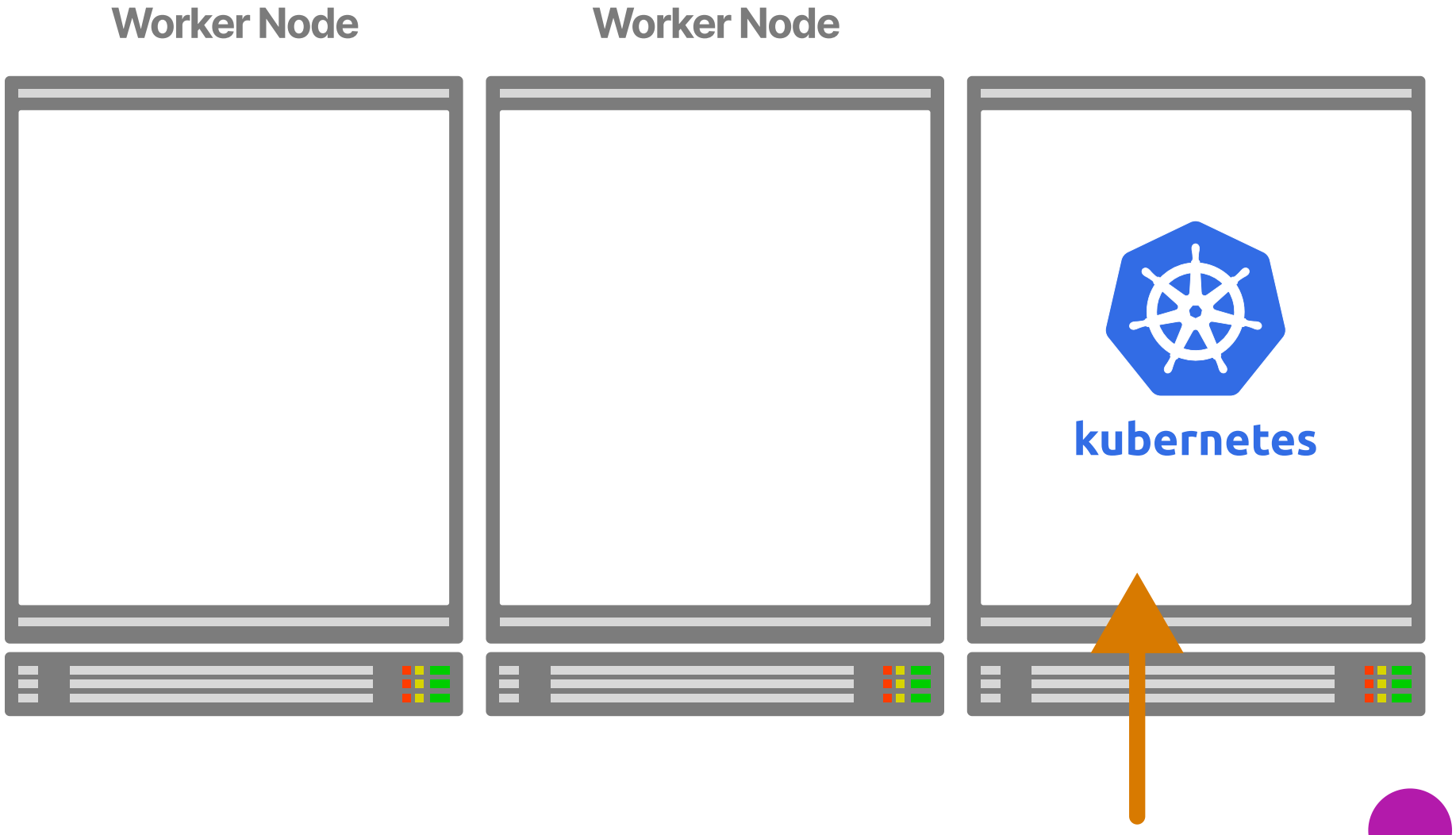
[-] Certificate was not found at: /root/kubesploit/data/x509/server.crt
Creating in-memory x.509 certificate used for this session only

[+] Default listener was created with an ID of: a93e9a30-cf30-4449-8969-da8230615221

[+] Started HTTP2 listener on 172.17.0.11:443
kubesploit»
```

Initial access

5 Using cloud credentials / kubeconfig


Worker Node
Worker Node
kubernetes
Using cloud credentials / kubeconfig

5. Using cloud credentials / kubeconfig

Enable 2FA

Separate IAMs

Segragate accounts

Rotate credentials

OIDC

5. Using cloud credentials / kubeconfig

Enable 2FA

Separate accs/RBACs

Segragate accounts

Rotate credentials

OIDC

5. Using cloud credentials / kubeconfig

Enable 2FA

Separate IAMs

Segragate accounts

Rotate credentials

OIDC

5. Using cloud credentials / kubeconfig

Enable 2FA

Separate IAMs

Segragate accounts

Rotate credentials

OIDC

5. Using cloud credentials / kubeconfig

Enable 2FA

Separate IAMs

Segragate accounts

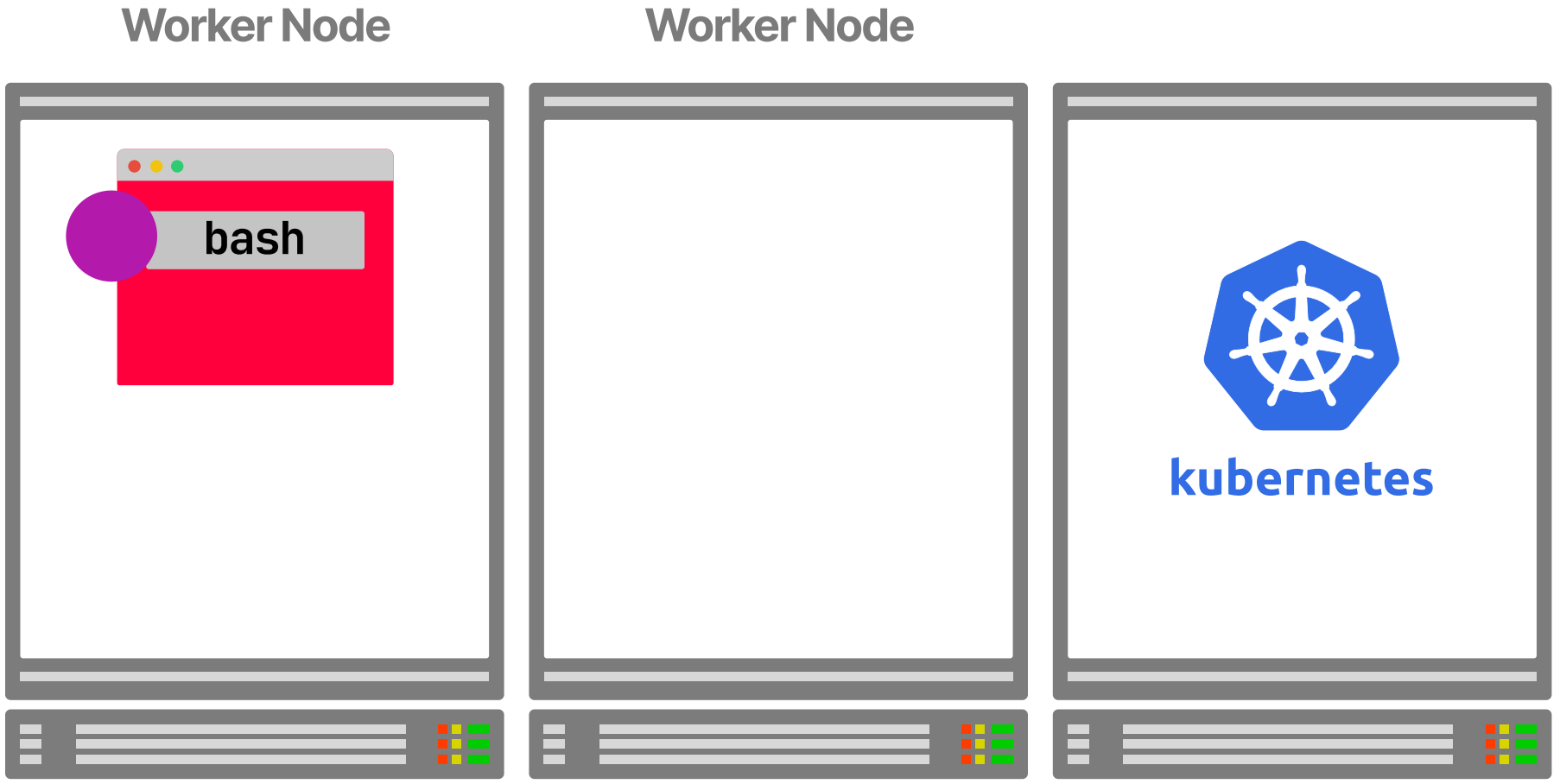
Rotate credentials

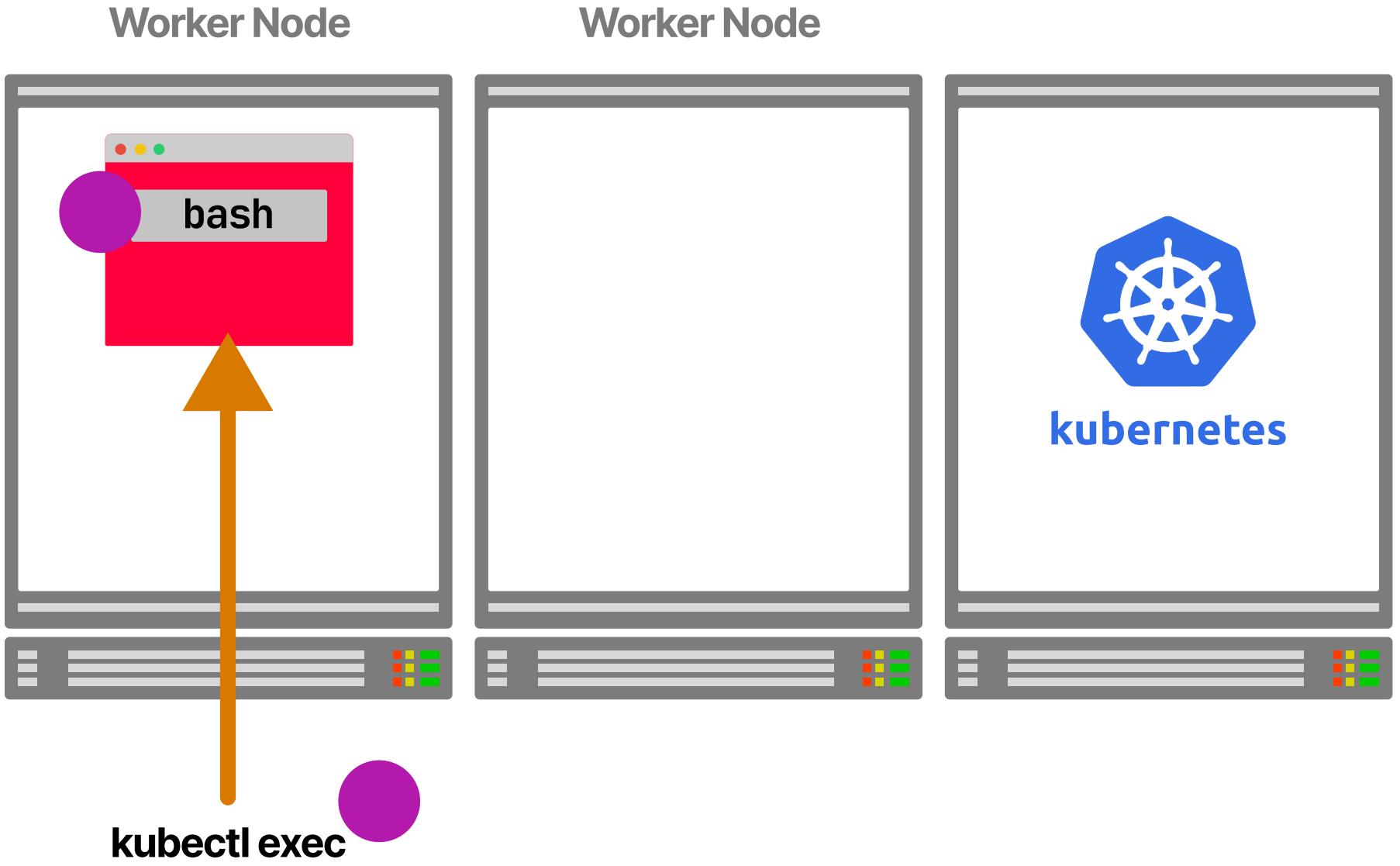
OIDC

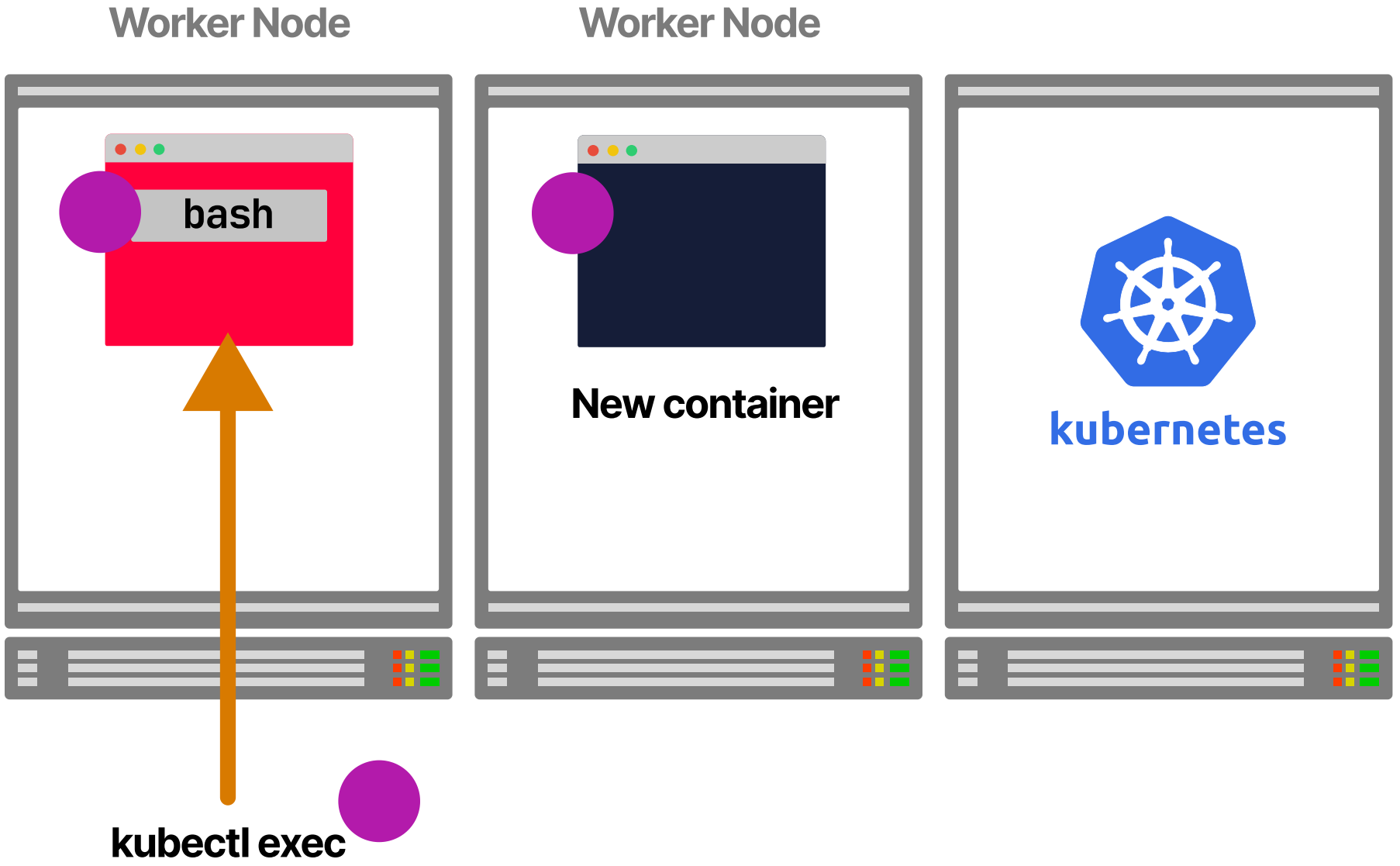
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials							
Compromised images in registry							
Kubeconfig file							
Application vulnerability							
Exposed sensitive interfaces							
Control plane + kubelet misconfiguration							

Execution

02

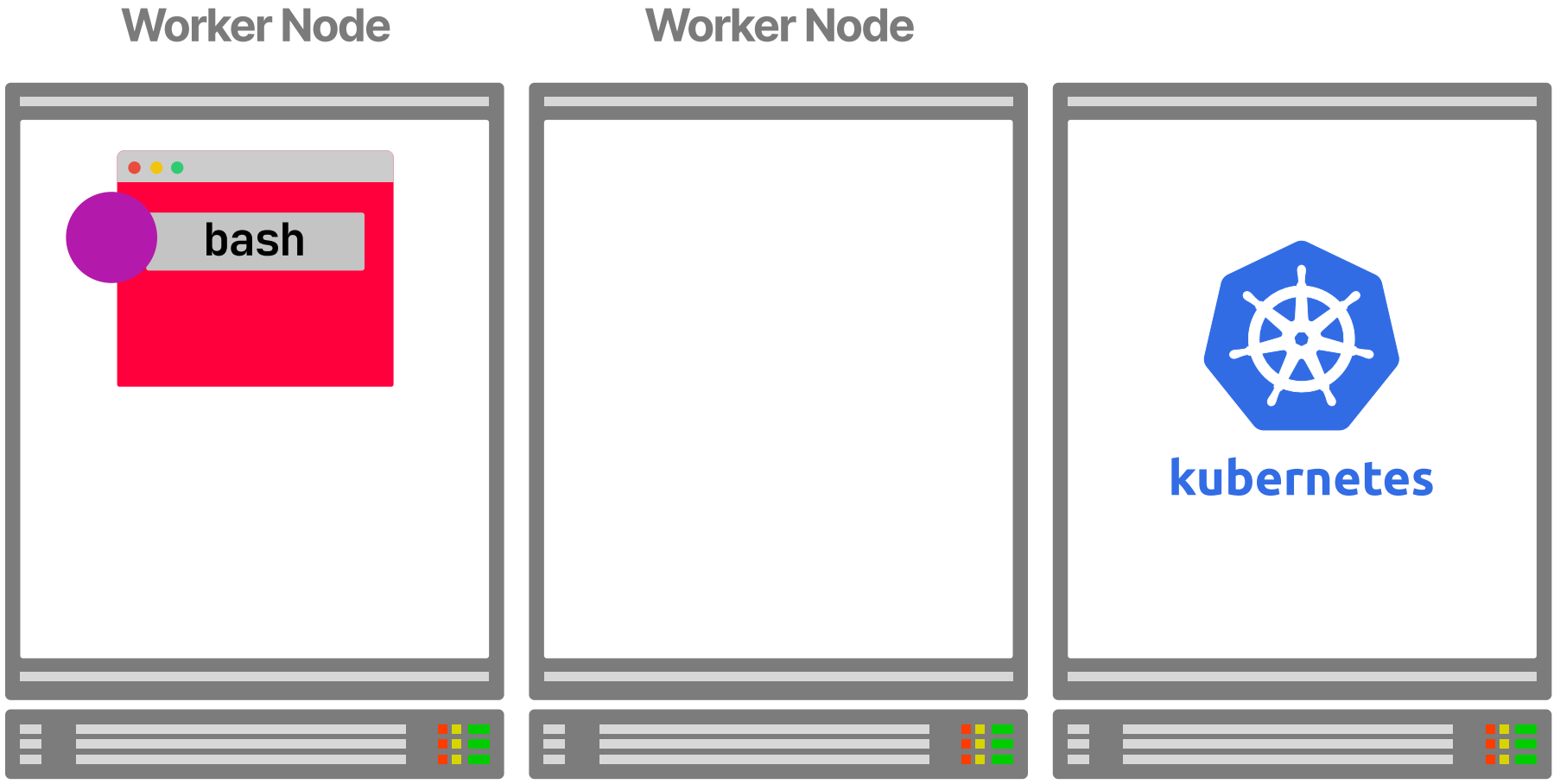

Worker Node
Worker Node
bash
kubernetes


Worker Node
Worker Node
bash
kubernetes
kubectl exec


Worker Node
Worker Node
bash
New container
kubernetes
kubectl exec

Execution

1. Bash inside the container


Worker Node
Worker Node
bash
kubernetes

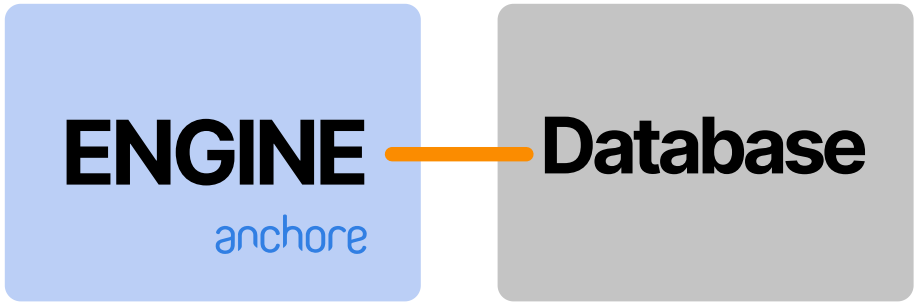
1. Bash inside the container

anchore/anchore-engine

aquasecurity/trivy

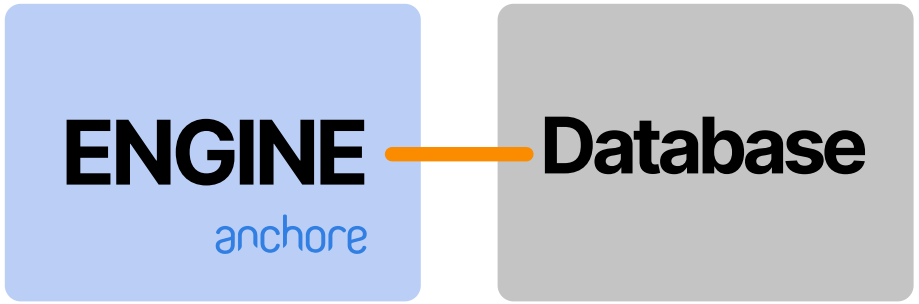
GoogleContainerTools/distroless

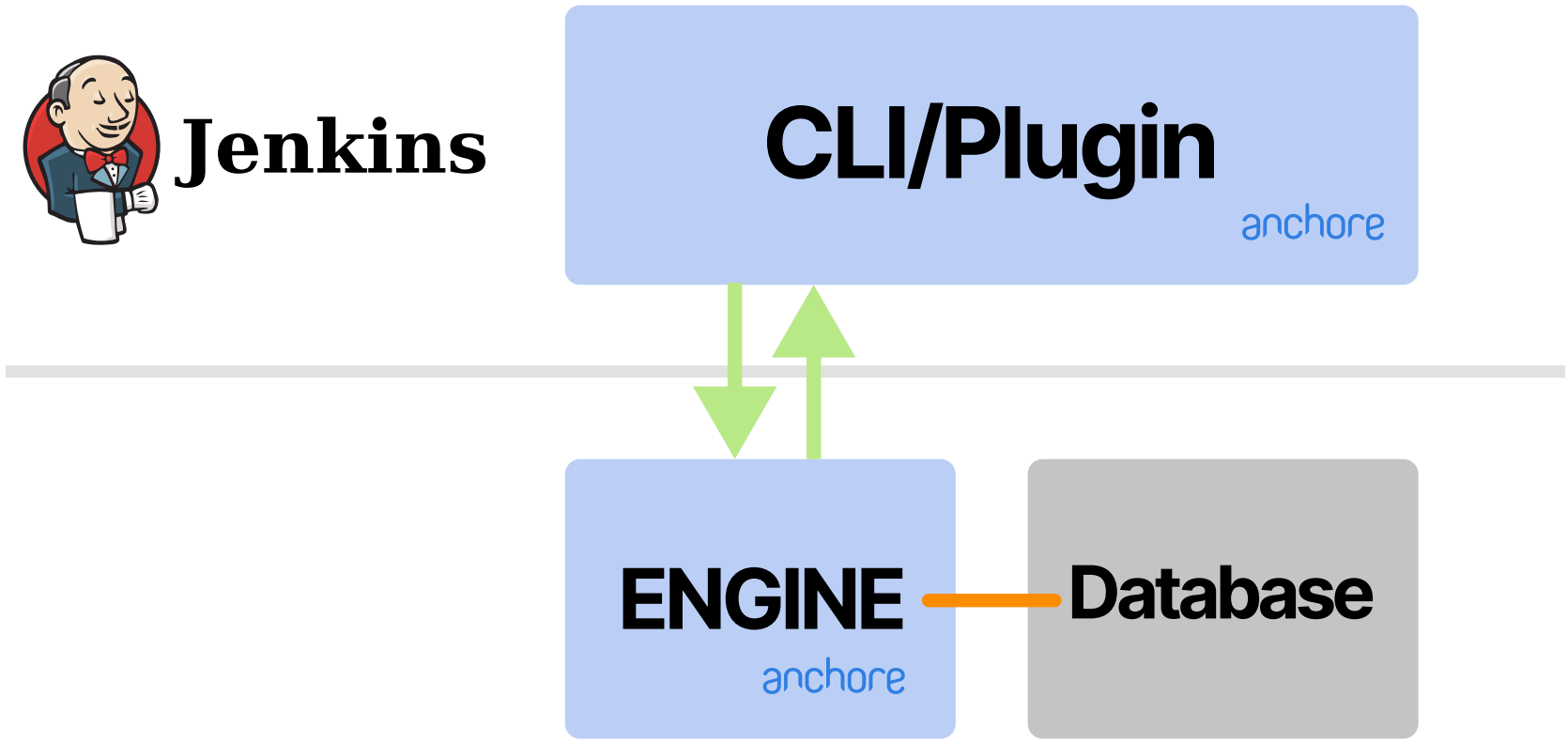
Container image comparison


ENGINE
anchore
Database



Jenkins




Jenkins
CLI/Plugin
anchore
ENGINE
anchore
Database

```
Image archive loaded into Anchore Engine using tag -- nginx:latest
Waiting for analysis to complete...

 Status: not_analyzed
 Status: analyzing.................
 Status: analyzed

Analysis completed!


 Policy Evaluation - nginx:latest
------------------------------------------------------------

Image Digest: sha256:bc3907dd0381d1bbc3865e29851c7387723c20c2a5e5cc8034a5ab910d1d03ba
Full Tag: localhost:5000/nginx:latest
Image ID: 4f380adfc10f4cd34f775ae57a17d2835385efd5251d6dfe0f246b0018fb0399
Status: pass
Last Eval: 2021-06-30T11:57:31Z
Policy ID: 2c53a13c-1765-11e8-82ef-23527761d060
Final Action: warn
Final Action Reason: policy_evaluation

Gate                    Trigger             Detail
dockerfile              instruction         Dockerfile directive 'HEALTHCHECK' not found, matching condition 'not_e
vulnerabilities         package             MEDIUM Vulnerability found in os package type (dpkg) - libgnutls30 (CVE
vulnerabilities         package             MEDIUM Vulnerability found in os package type (dpkg) - libwebp6 (CVE-20
```

1. Bash inside the container

anchore/anchore-engine

aquasecurity/trivy

GoogleContainerTools/distroless

Container image comparison

nginx (debian 10.9)
==========
Total: 170 (UNKNOWN: 0, LOW: 110, MEDIUM: 15, HIGH: 30, CRITICAL: 15)

LIBRARY	VULNERABILITY ID	SEVERITY	INSTALLED VERSION	FIXED VERSION	TITLE
apt	CVE-2011-3374	LOW	1.8.2.3		It was found that apt-key in apt, all versions, do not correctly... -->avd.aquasec.com/nvd/cve-2011-3374
bash	CVE-2019-18276		5.0-4		bash: when effective UID is not equal to its real UID the... -->avd.aquasec.com/nvd/cve-2019-18276
	TEMP-0841856-B18BAF				-->security-tracker.debian.org/tracker/TEMP-0841856-B18BAF
coreutils	CVE-2016-2781		8.30-3		coreutils: Non-privileged session can escape to the parent session in chroot -->avd.aquasec.com/nvd/cve-2016-2781
	CVE-2017-18018				coreutils: race condition vulnerability in chown and chgrp -->avd.aquasec.com/nvd/cve-2017-18018
curl	CVE-2021-22898	HIGH	7.64.0-4+deb10u2		curl: TELNET stack contents disclosure -->avd.aquasec.com/nvd/cve-2021-22898
gcc-8-base	CVE-2018-12886		8.3.0-6		gcc: spilling of stack protection address in cfgexpand.c and function.c leads to... -->avd.aquasec.com/nvd/cve-2018-12886
	CVE-2019-15847				gcc: POWER9 "DARN" RNG intrinsic produces repeated output -->avd.aquasec.com/nvd/cve-2019-15847
gpgv	CVE-2019-14855	LOW	2.2.12-1+deb10u1		gnupg2: OpenPGP Key Certification Forgeries with SHA-1 -->avd.aquasec.com/nvd/cve-2019-14855
libapt-pkg5.0	CVE-2011-3374		1.8.2.3		It was found that apt-key in apt, all versions, do not correctly... -->avd.aquasec.com/nvd/cve-2011-3374
libc-bin	CVE-2021-33574	CRITICAL	2.28-10		glibc: mq_notify does not handle separately allocated thread attributes -->avd.aquasec.com/nvd/cve-2021-33574
	CVE-2020-1751	HIGH			glibc: array overflow in backtrace functions for powerpc -->avd.aquasec.com/nvd/cve-2020-1751

1. Bash inside the container

anchore/anchore-engine

aquasecurity/trivy

GoogleContainerTools/distroless

Container image comparison

"Distroless" images contain only your application and its runtime dependencies. They do not contain package managers, shells or any other programs

1. Bash inside the container

anchore/anchore-engine

aquasecurity/trivy

GoogleContainerTools/distroless

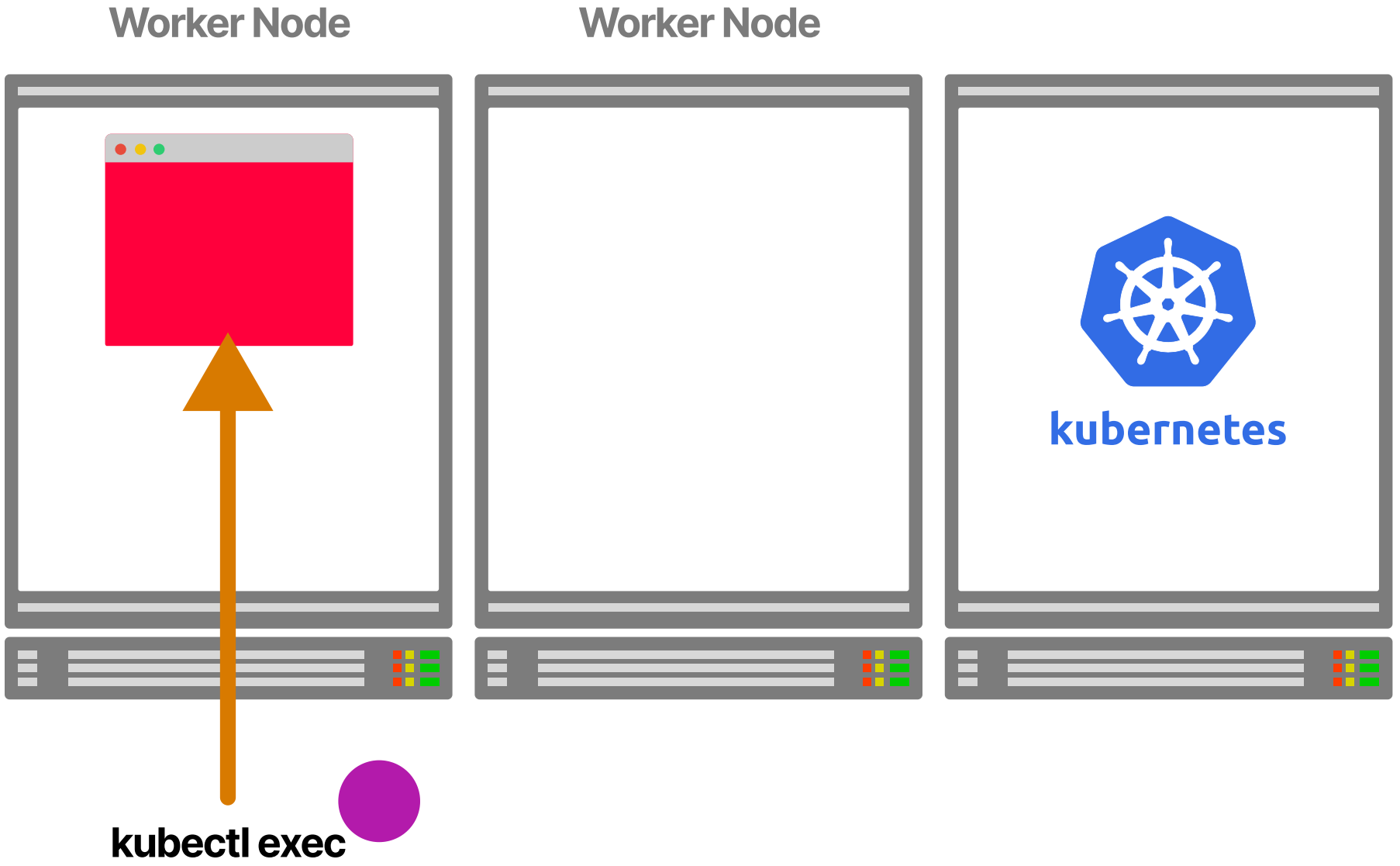
Container image comparison

Image Type	Alpine	CentOS	Debian	Debian Slim
Micro"	Ubuntu LTS	Version	3.11	7.8
8.2	8.2	20.04	C Library	musl c
glibc	glibc	glibc	glibc	Package Format
rpm	rpm	rpm	-	dpkg
apt	dnf	yum/dnf	yum/dnf	yum/dnf
GNU Core Utils	GNU Core Utils	GNU Core Utils	GNU Core Utils	GNU Core Utils
2.7MB	71MB	49MB	26MB	63MB
Storage Size	5.7MB	202MB	117MB	72MB
73MB	Java App Compressed Size:	115MB	190MB	199MB
150MB	202MB	"Java App	Storage Size:"	230MB
508MB	413MB	364MB	455MB	Life Cycle
-	Likely 3 Years"	"Unknown	-	Likely 3 Years"
+EUS"	"10 years	+EUS"	"10 years	security"
Generally within minor version	"Generally	within a major version"	Based on Tier	Based on Tier
"Centos	Tools Container"	Standard Packages	Standard Packages	"Fedora
"Standard	Packages"	"Standard	Packages"	Standard Packages
Community	Community	Community & Commercial	Community & Commercial	Community & Commercial
Community	Community	Community	Community & Commercial	Community & Commercial
Community	Community	Community	Community	Commercial
None	"Announce List	Errata"	"OVAL Data	CVE Database

crunchtools.com/comparison-linux-container-images

Execution

2. Kubectl exec


Worker Node
Worker Node
kubernetes
kubectl exec

2. Kubectl exec

Limit permissions

Enable API auditing

2. Kubectl exec

Limit permissions

Enable API auditing

```
apiVersion: audit.k8s.io/v1
kind: Policy
rules:
  # Log pod changes at RequestResponse level
  - level: RequestResponse
    resources:
    - group: ""
      # Resource "pods" doesn't match requests to any subresource
      # of pods, which is consistent with the RBAC policy.
      resources: ["pods"]
  # Log "pods/log", "pods/status" at Metadata level
  - level: Metadata
    resources:
    - group: ""
      resources: ["pods/log", "pods/status"]

  # Don't log requests to a configmap called "controller-leader"
  - level: None
    resources:
    - group: ""
      resources: ["configmaps"]
      resourceNames: ["controller-leader"]
```

```
apiVersion: audit.k8s.io/v1
kind: Policy
rules:
  # Log pod changes at RequestResponse level
  - level: RequestResponse
    resources:
    - group: ""
      # Resource "pods" doesn't match requests to any subresource
      # of pods, which is consistent with the RBAC policy.
      resources: ["pods"]
  # Log "pods/log", "pods/status" at Metadata level
  - level: Metadata
    resources:
    - group: ""
      resources: ["pods/log", "pods/status"]

  # Don't log requests to a configmap called "controller-leader"
  - level: None
    resources:
    - group: ""
      resources: ["configmaps"]
      resourceNames: ["controller-leader"]
```

```
apiVersion: audit.k8s.io/v1
kind: Policy
rules:
  # Log pod changes at RequestResponse level
  - level: RequestResponse
    resources:
    - group: ""
      # Resource "pods" doesn't match requests to any subresource
      # of pods, which is consistent with the RBAC policy.
      resources: ["pods"]
  # Log "pods/log", "pods/status" at Metadata level
  - level: Metadata
    resources:
    - group: ""
      resources: ["pods/log", "pods/status"]

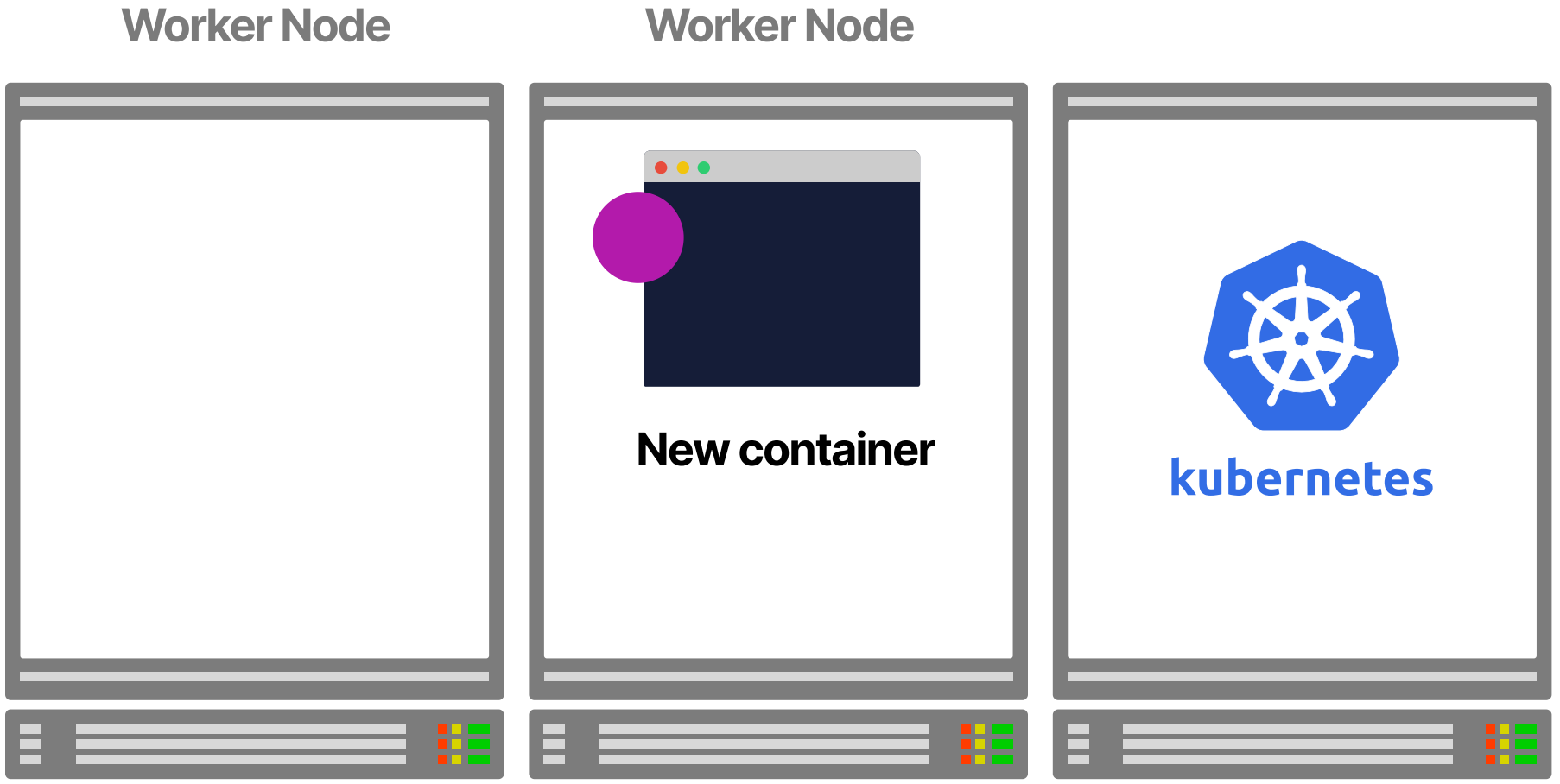
  # Don't log requests to a configmap called "controller-leader"
  - level: None
    resources:
    - group: ""
      resources: ["configmaps"]
      resourceNames: ["controller-leader"]
```

```
apiVersion: audit.k8s.io/v1
kind: Policy
rules:
  # Log pod changes at RequestResponse level
  - level: RequestResponse
    resources:
    - group: ""
      # Resource "pods" doesn't match requests to any subresource
      # of pods, which is consistent with the RBAC policy.
      resources: ["pods"]
  # Log "pods/log", "pods/status" at Metadata level
  - level: Metadata
    resources:
    - group: ""
      resources: ["pods/log", "pods/status"]

  # Don't log requests to a configmap called "controller-leader"
  - level: None
    resources:
    - group: ""
      resources: ["configmaps"]
      resourceNames: ["controller-leader"]
```

Execution

3. New container


Worker Node
Worker Node
New container
kubernetes

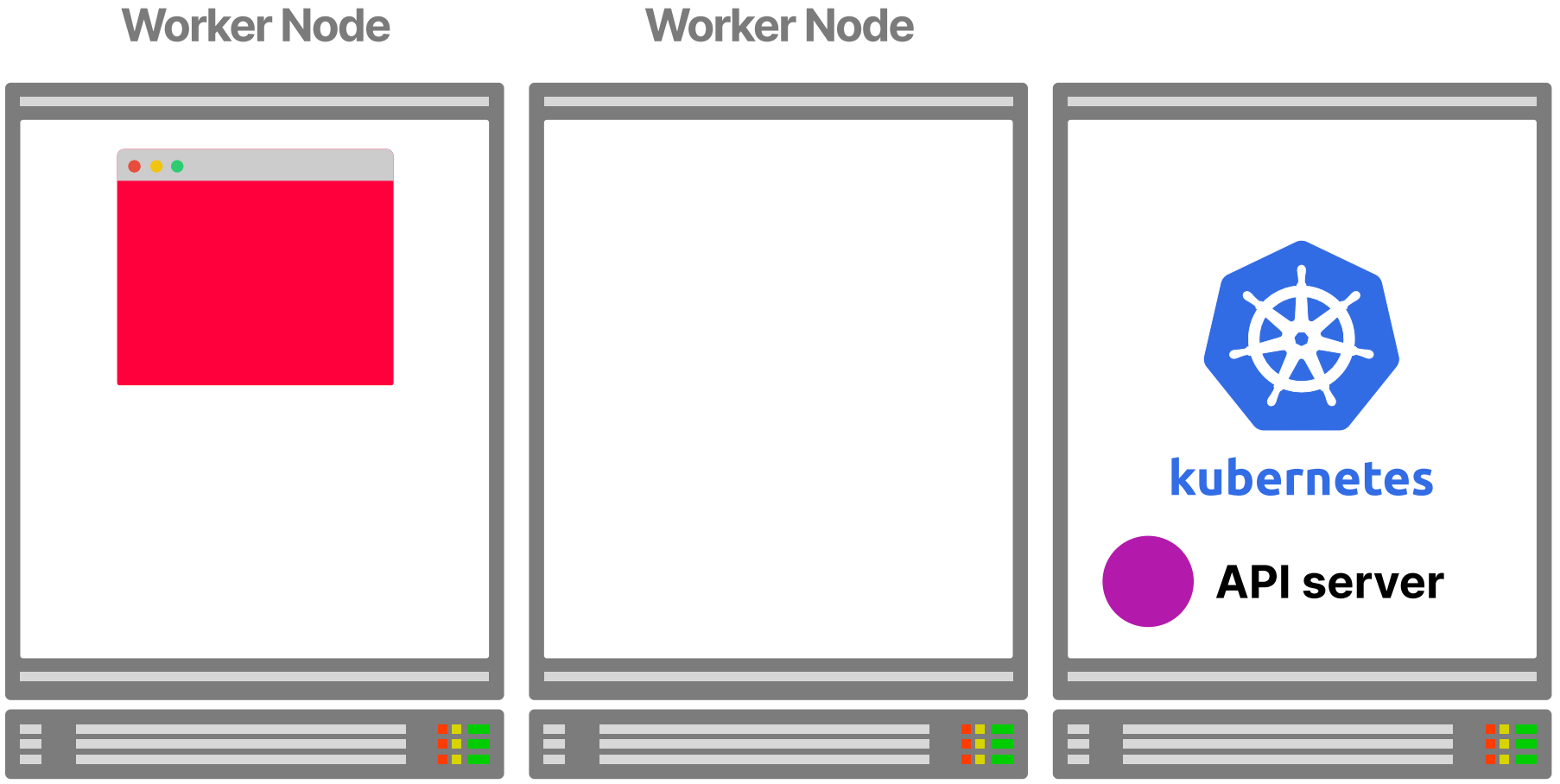
3. New container

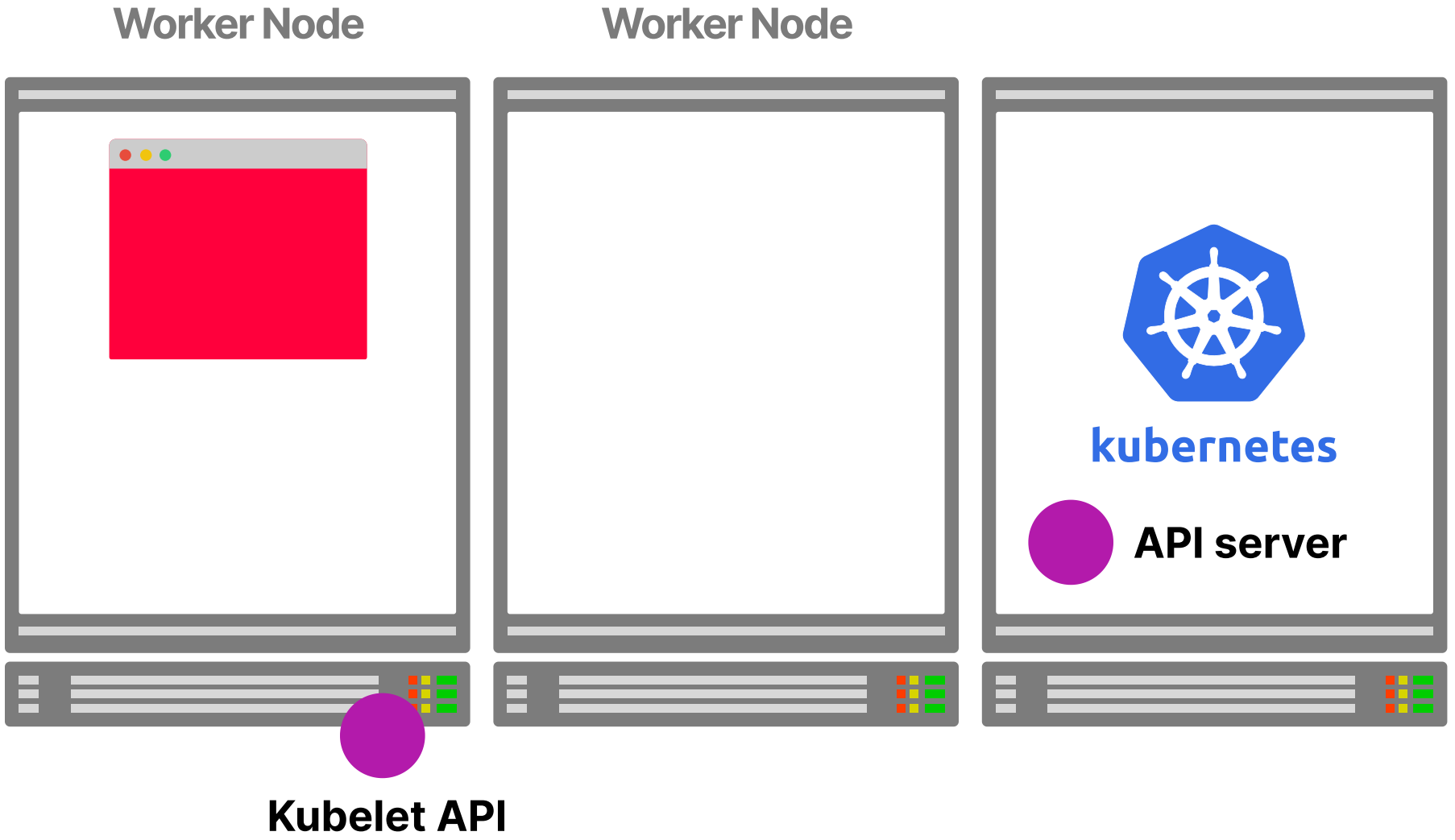
Limit permissions
Enable API auditing

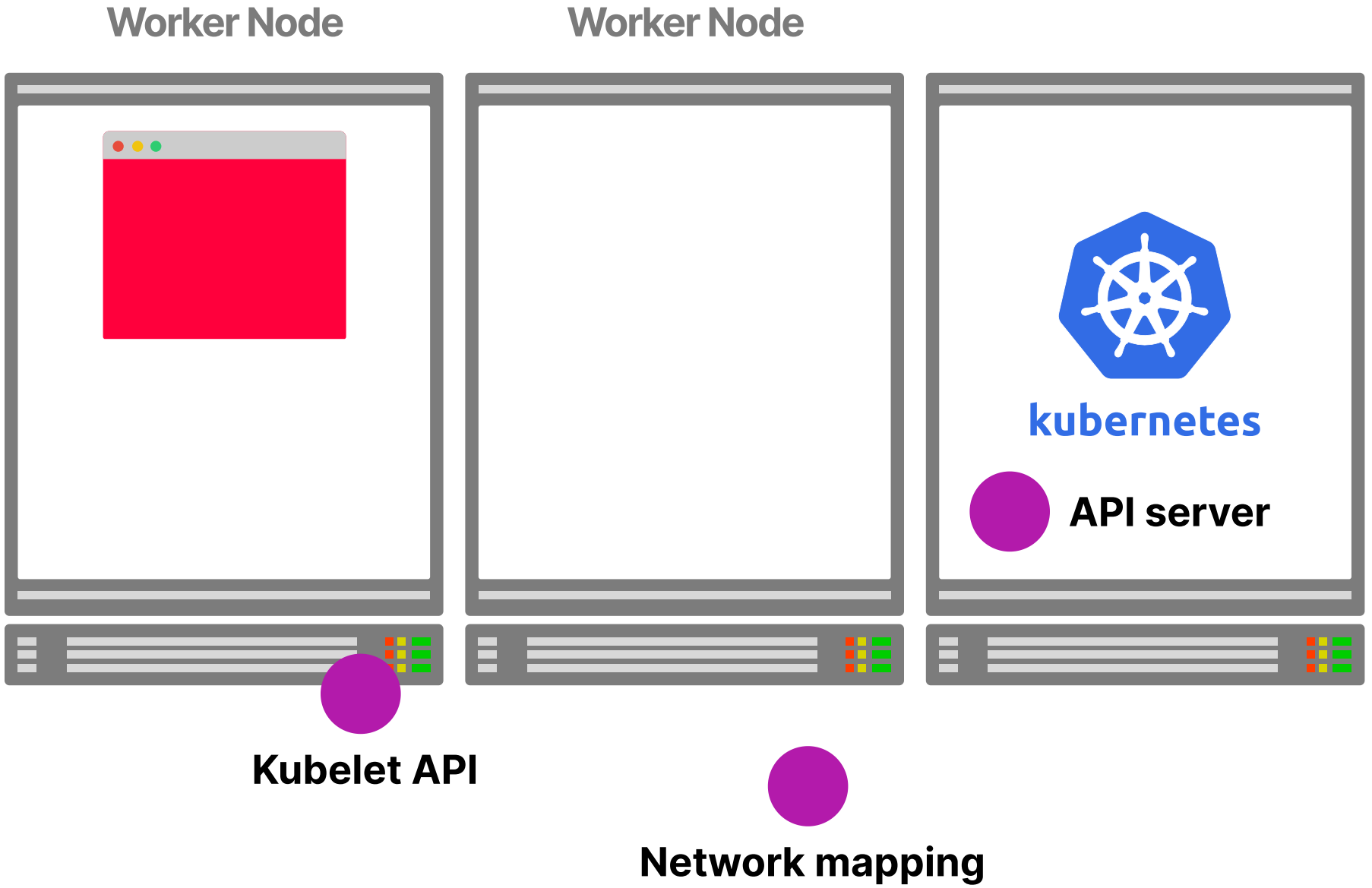
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container						
Compromised images in registry	bash/cmd inside container						
Kubeconfig file	New container						
Application vulnerability							
Exposed sensitive interfaces							
Control plane + kubelet misconfiguration							

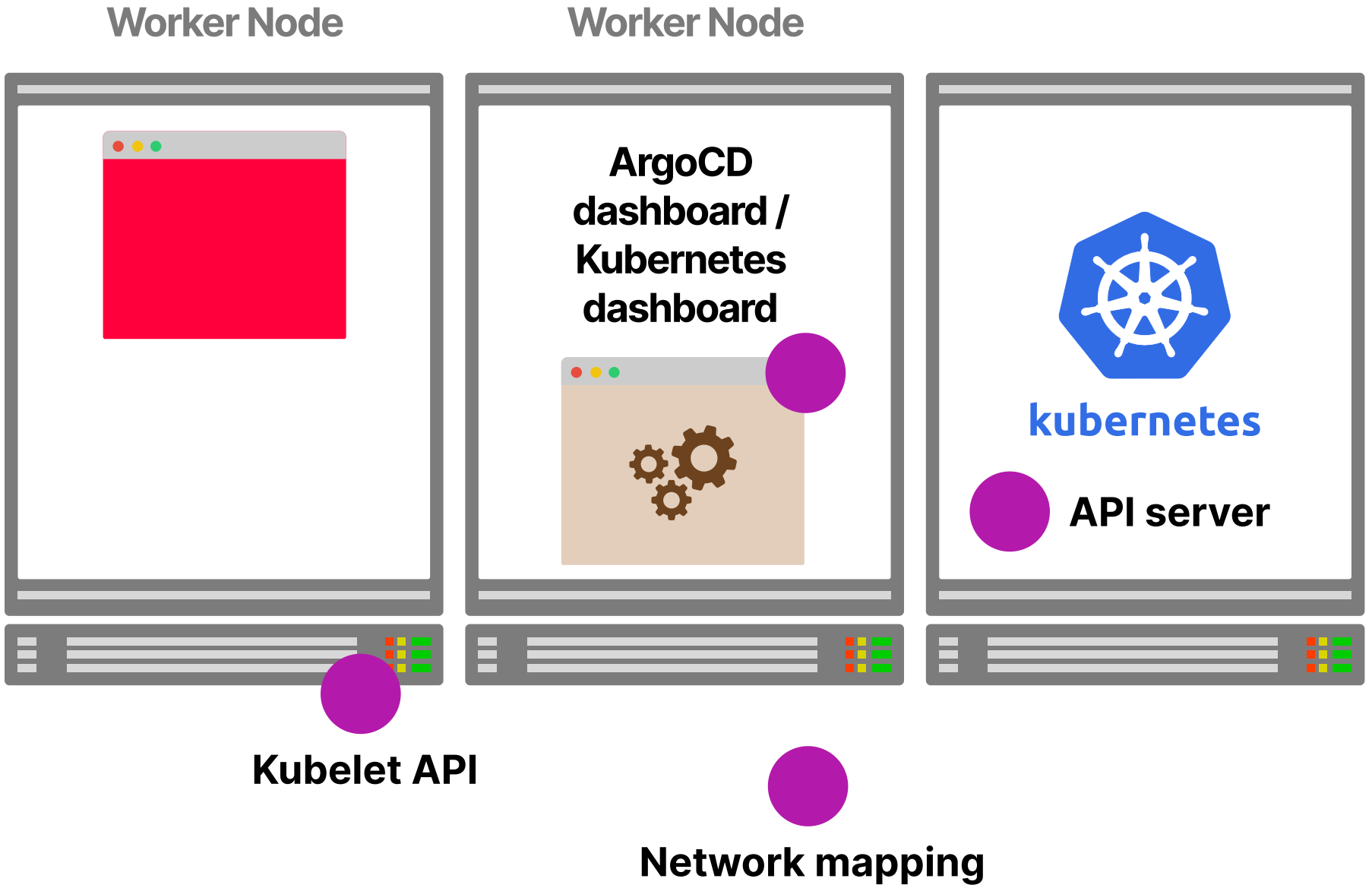
Discovery

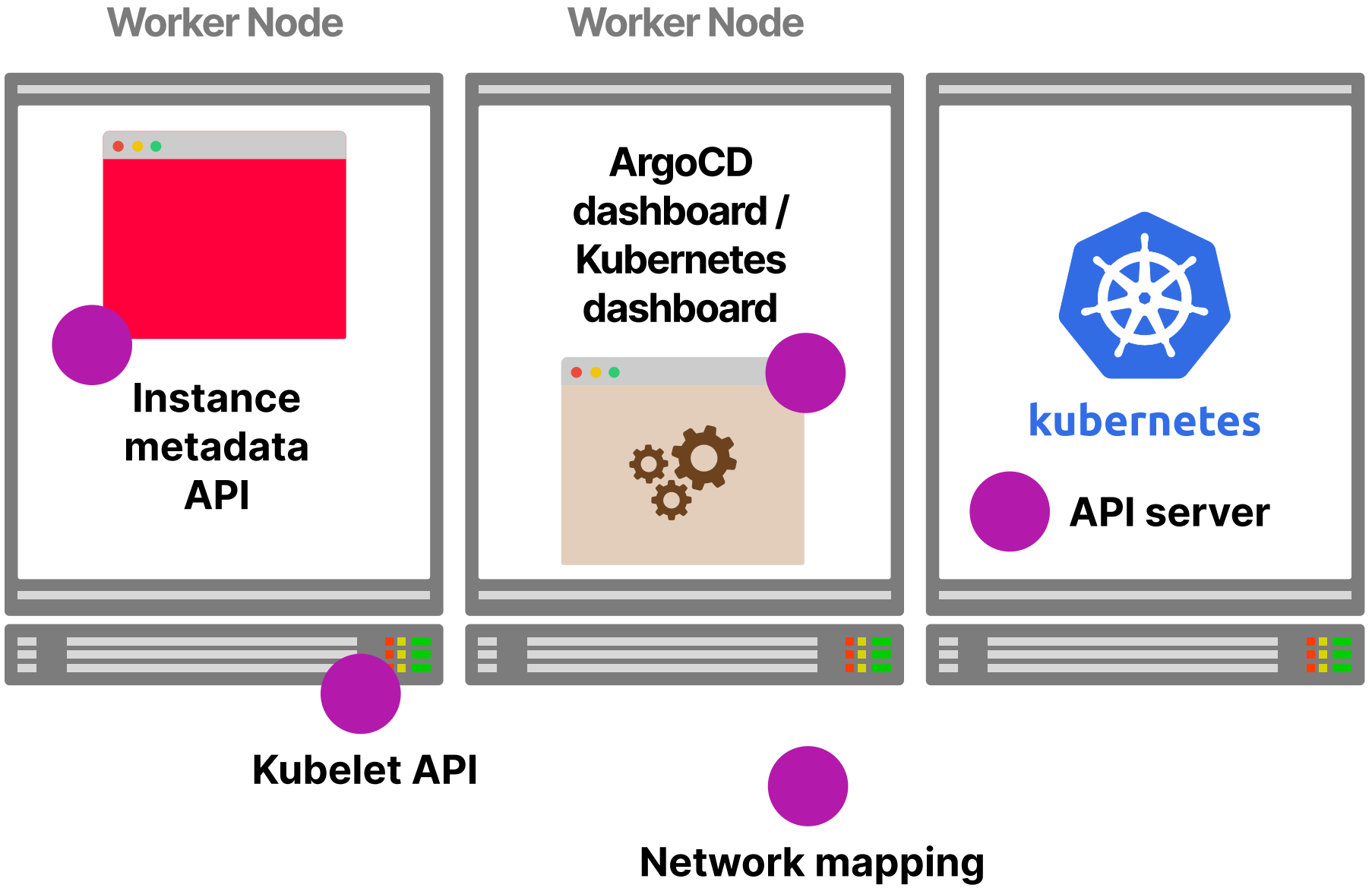
03


Worker Node
Worker Node
kubernetes
API server


Worker Node
Worker Node
kubernetes
API server
Kubelet API

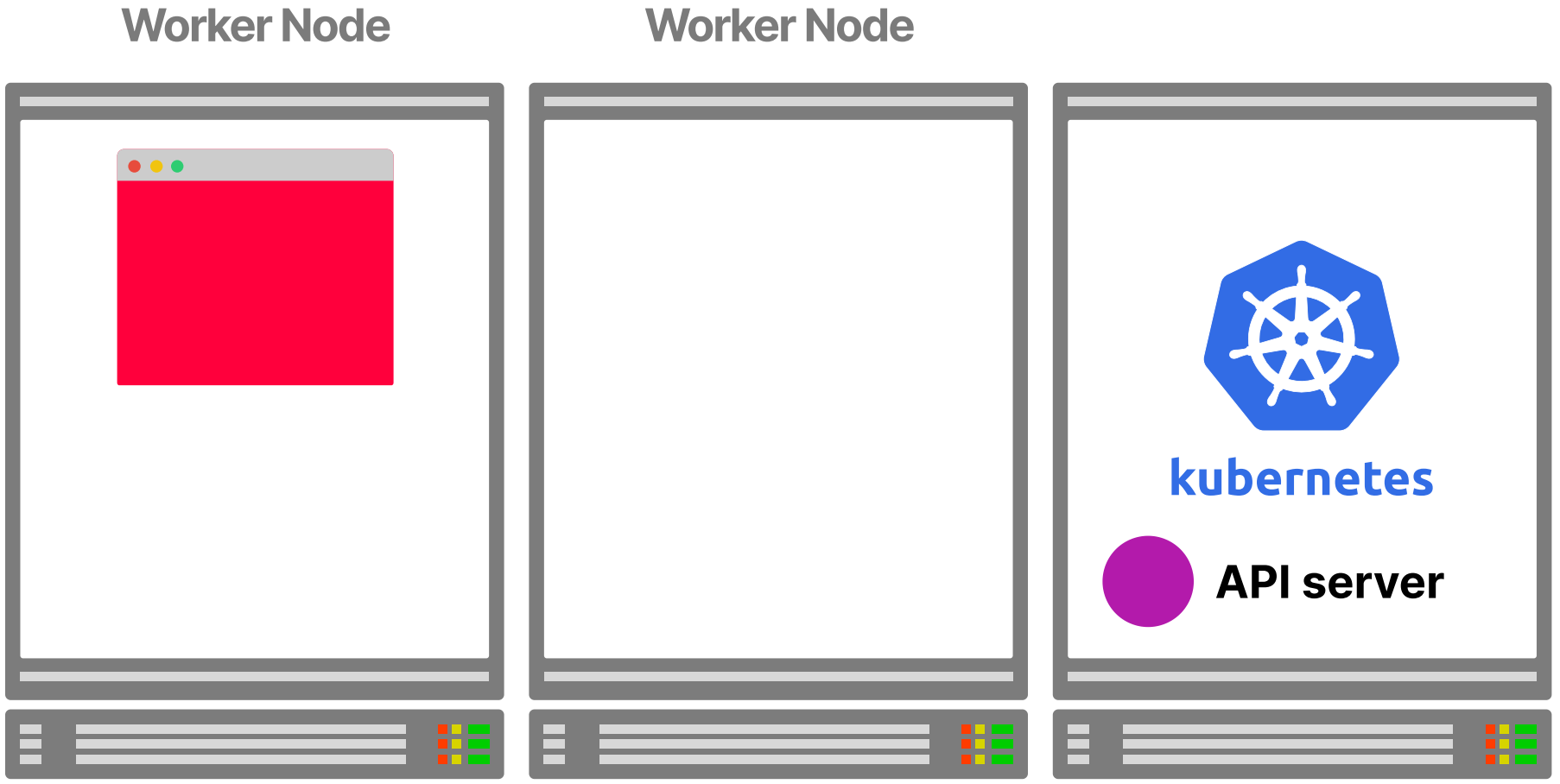

Worker Node
Worker Node
kubernetes
API server
Kubelet API
Network mapping


Worker Node
Worker Node
ArgoCD dashboard / Kubernetes dashboard
kubernetes
API server
Kubelet API
Network mapping


Worker Node
Worker Node
Instance metadata API
ArgoCD dashboard / Kubernetes dashboard
kubernetes
API server
Kubelet API
Network mapping

Discovery

1. API server


Worker Node
Worker Node
kubernetes
API server

1. API server

RBAC

No anonymous access

CVEs

1. API server

RBAC

No anonymous access

CVEs

1. API server

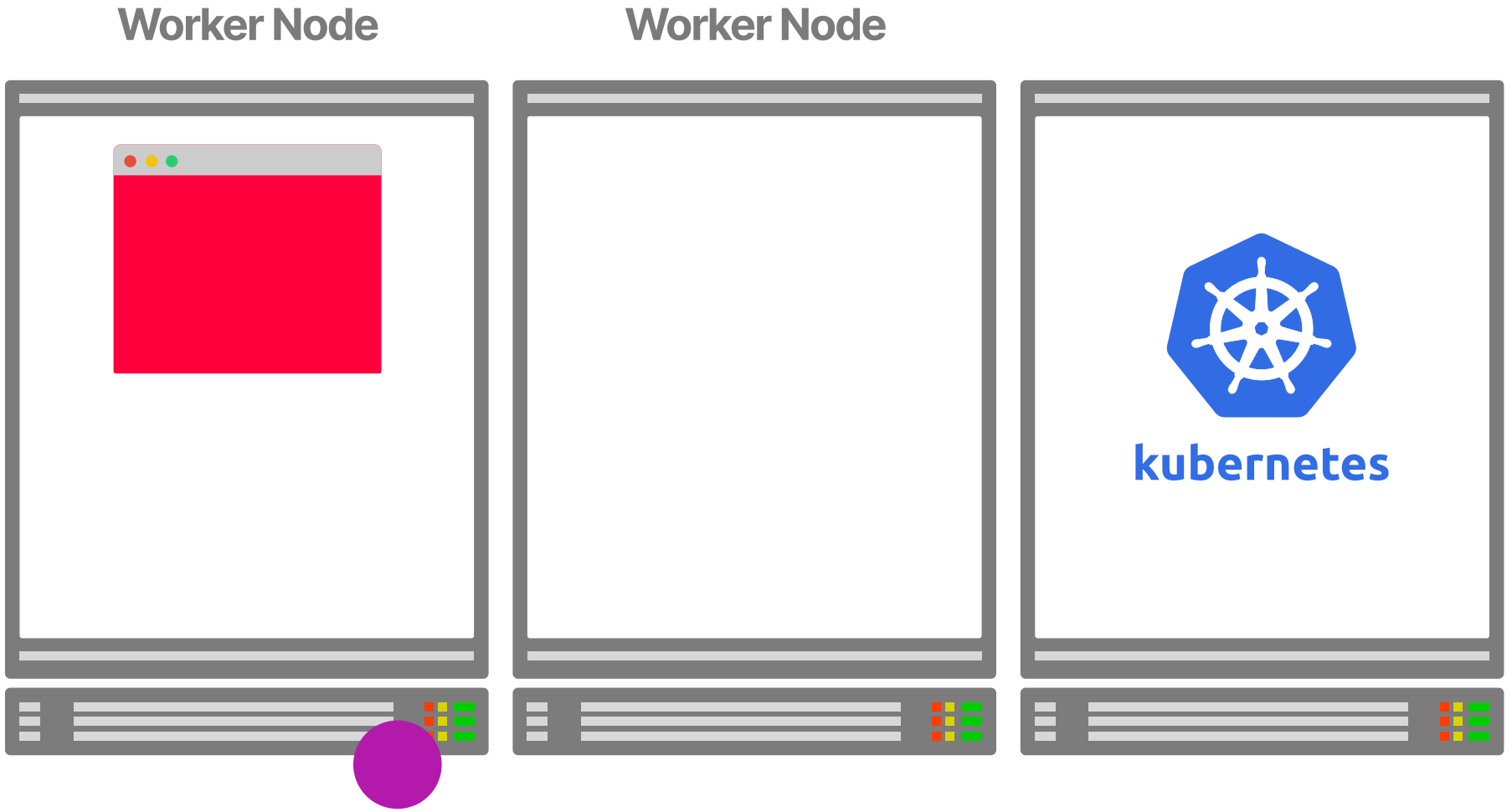
RBAC

No anonymous access

CVEs

Discovery

2. Kubelet API


Worker Node
Worker Node
kubernetes
Kubelet API

2. Kubelet API

RBAC

No anonymous access

2. Kubelet API

RBAC

No anonymous access

cyberark/kubeletctl

---

2. Kubelet API

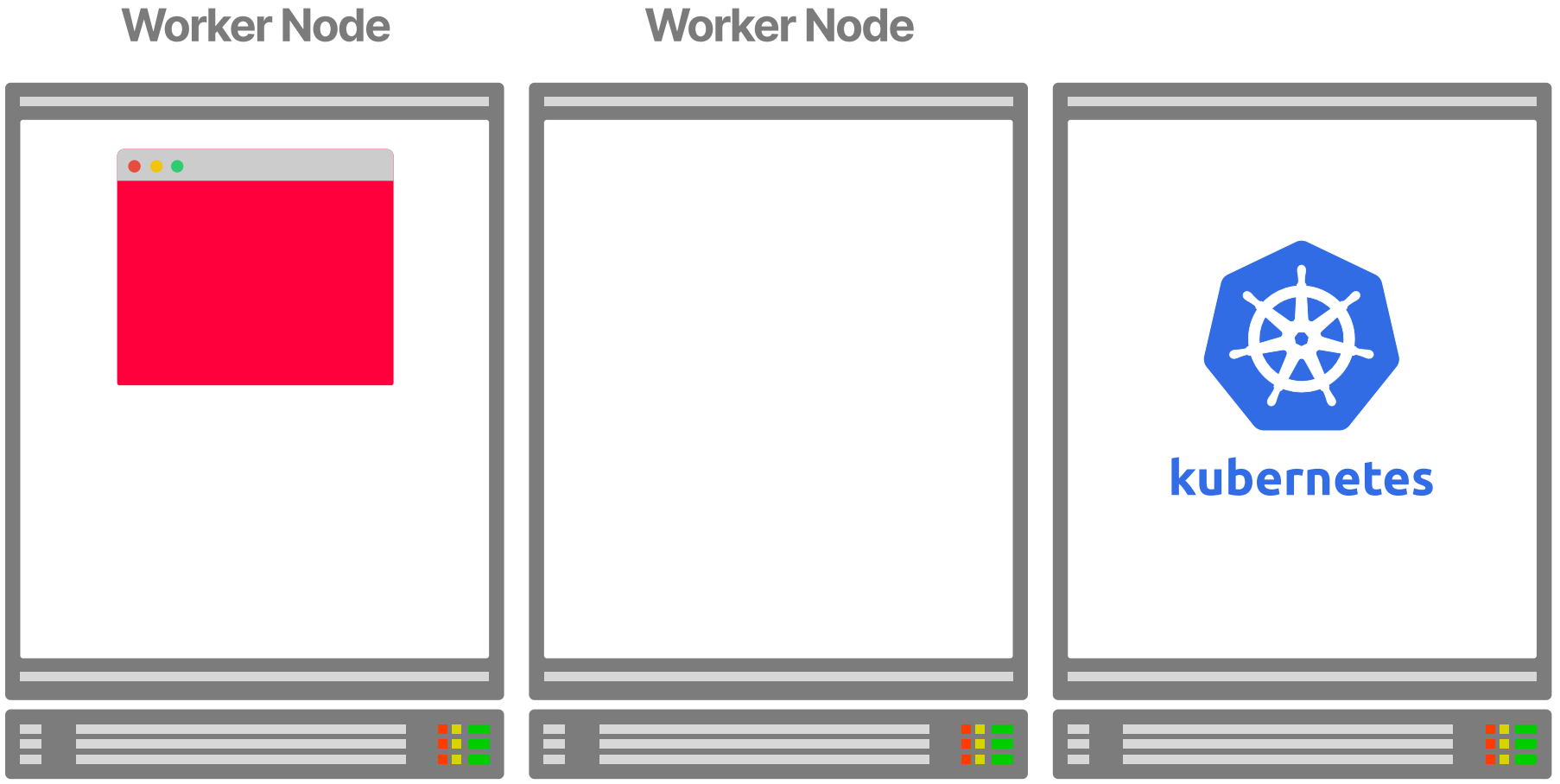
```
Usage:
  kubeletctl [flags]
  kubeletctl [command]

Available Commands:
  attach        Attach to a container
  configz       Return kubelet's configuration.
  containerLogs Return container log
  cri           Run commands inside a container through the Container Runtime Interface (CRI)
  debug         Return debug information (pprof or flags)
  exec          Run commands inside a container
  healthz       Check the state of the node
  help          Help about any command
  log           Return the log from the node.
  metrics       Return resource usage metrics (such as container CPU, memory usage, etc.)
  pods          Get list of pods on the node
  portForward   Attach to a container
  run           Run commands inside a container
  runningpods   Returns all pods running on kubelet from looking at the container runtime cache.
  scan          Scans for nodes with opened kubelet API
  spec          Cached MachineInfo returned by cadvisor
  stats         Return statistical information for the resources in the node.
  version       Print the version of the kubeletctl

Flags:
      --cacert string      CA certificate (example: /etc/kubernetes/pki/ca.crt )
      --cert string        Private key (example: /var/lib/kubelet/pki/kubelet-client-current.pem)
      --cidr string        A network of IP addresses (Example: x.x.x.x/24)
  -k, --config string      KubeConfig file
  -c, --container string   Container name
  -h, --help               help for kubeletctl
      --http               Use HTTP (default is HTTPS)
  -i, --ignoreconfig       Ignore the default KUBECONFIG environment variable or location ~/.kube
      --key string         Digital certificate (example: /var/lib/kubelet/pki/kubelet-client-current.pem)
  -n, --namespace string   pod namespace
  -p, --pod string         Pod name
      --port string        Kubelet's port, default is 10250
```

Discovery

3. Network mapping



Network mapping

3. Network mapping

Network Policies

Encrypted traffic

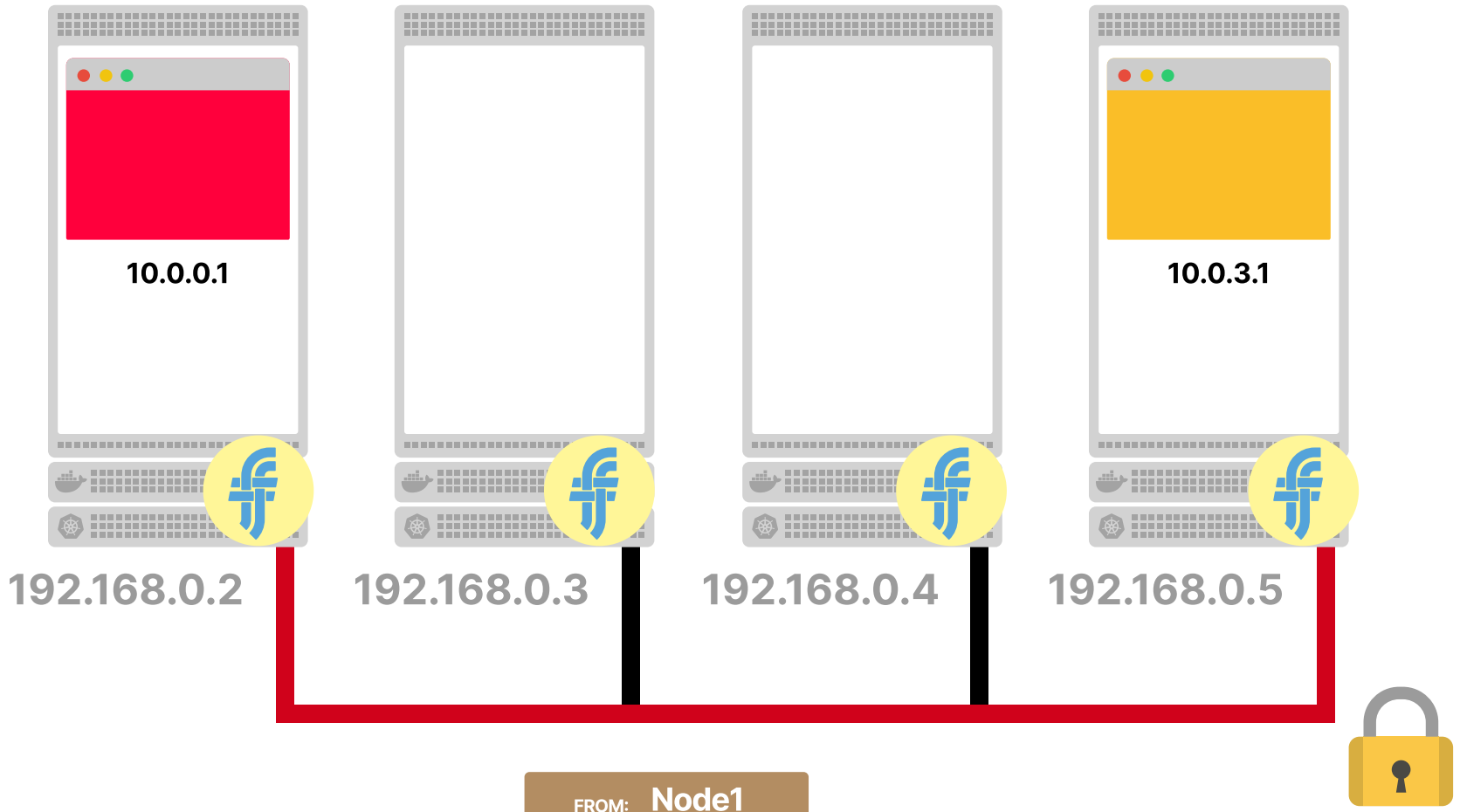
L7 policies

3. Network mapping

Network Policies

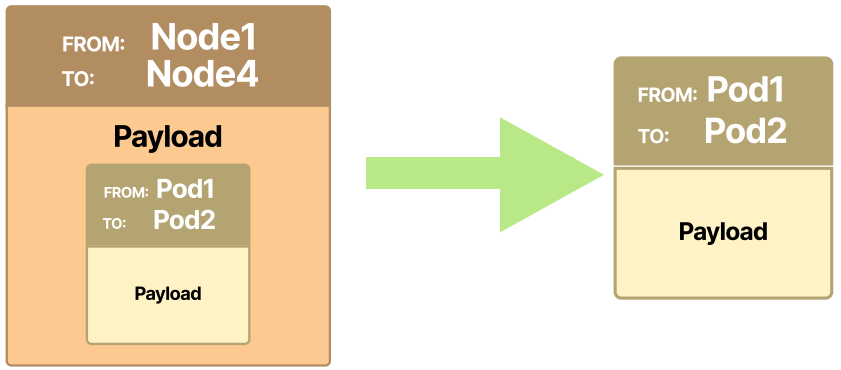
Encrypted traffic

L7 policies



FROM:
Pod ■ (10.0.0.1)

TO:
Pod ■ (10.0.3.1)

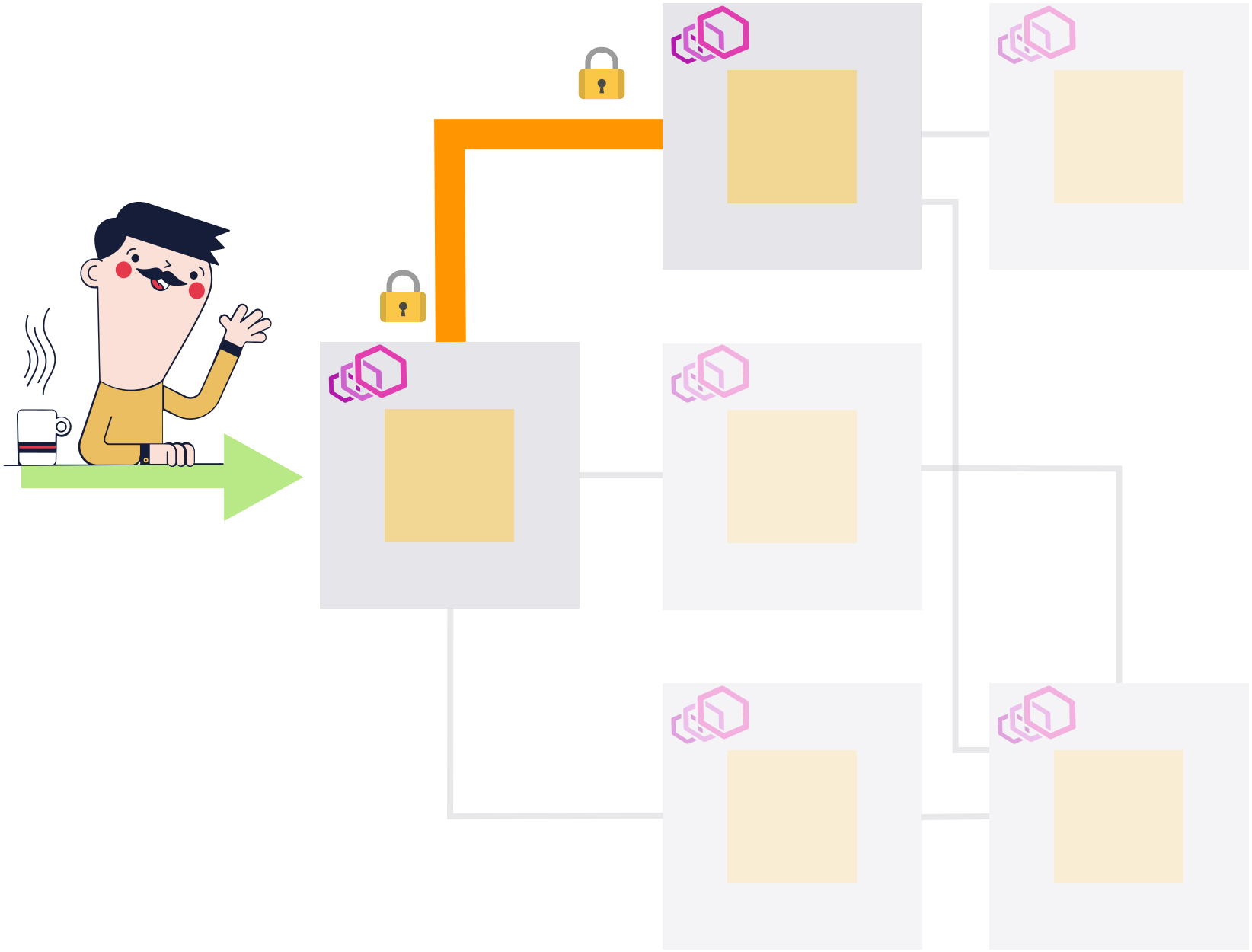


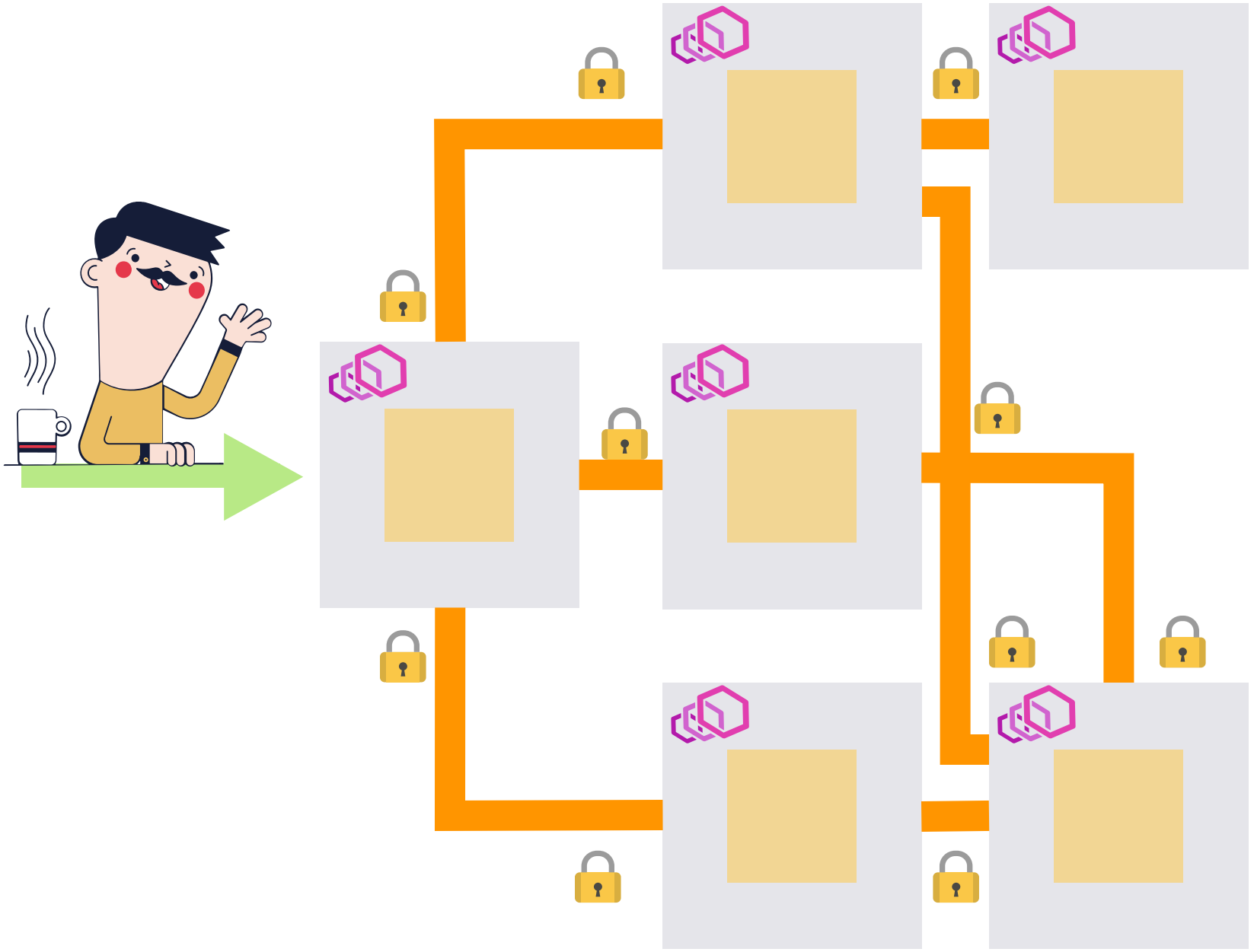
3. Network mapping

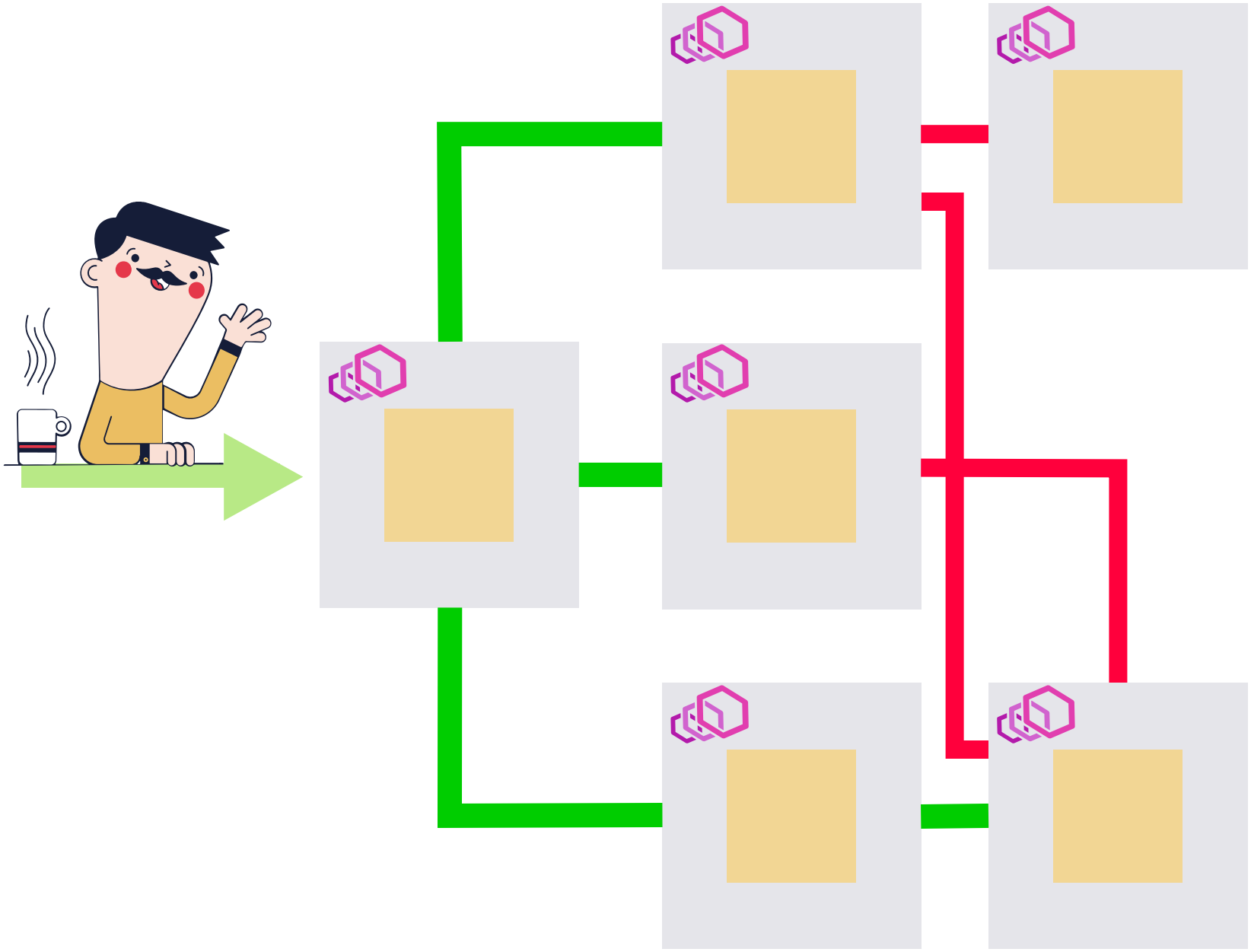
Network Policies

Encrypted traffic

L7 policies

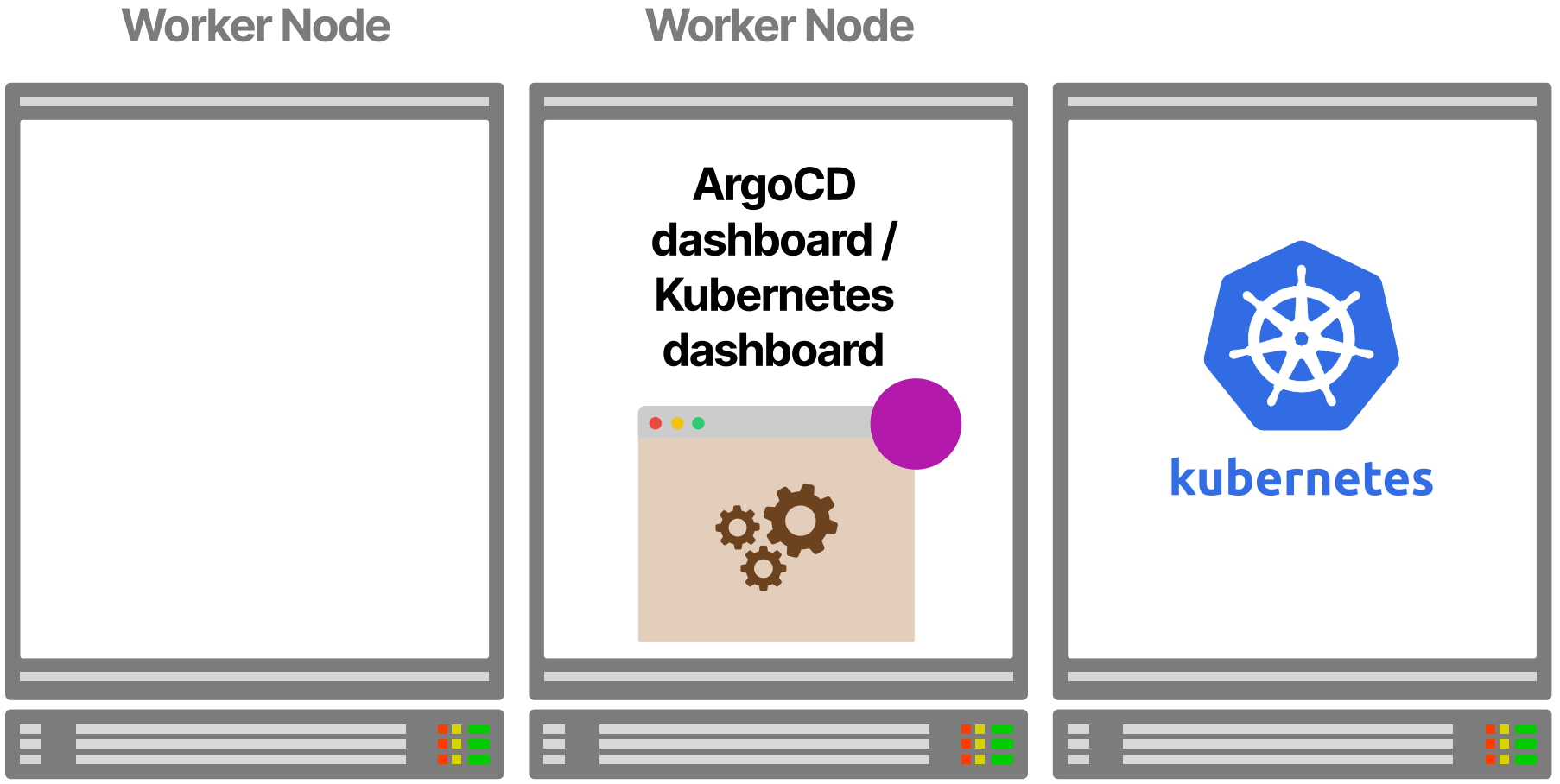






Discovery

4. Exposed sensitive interfaces

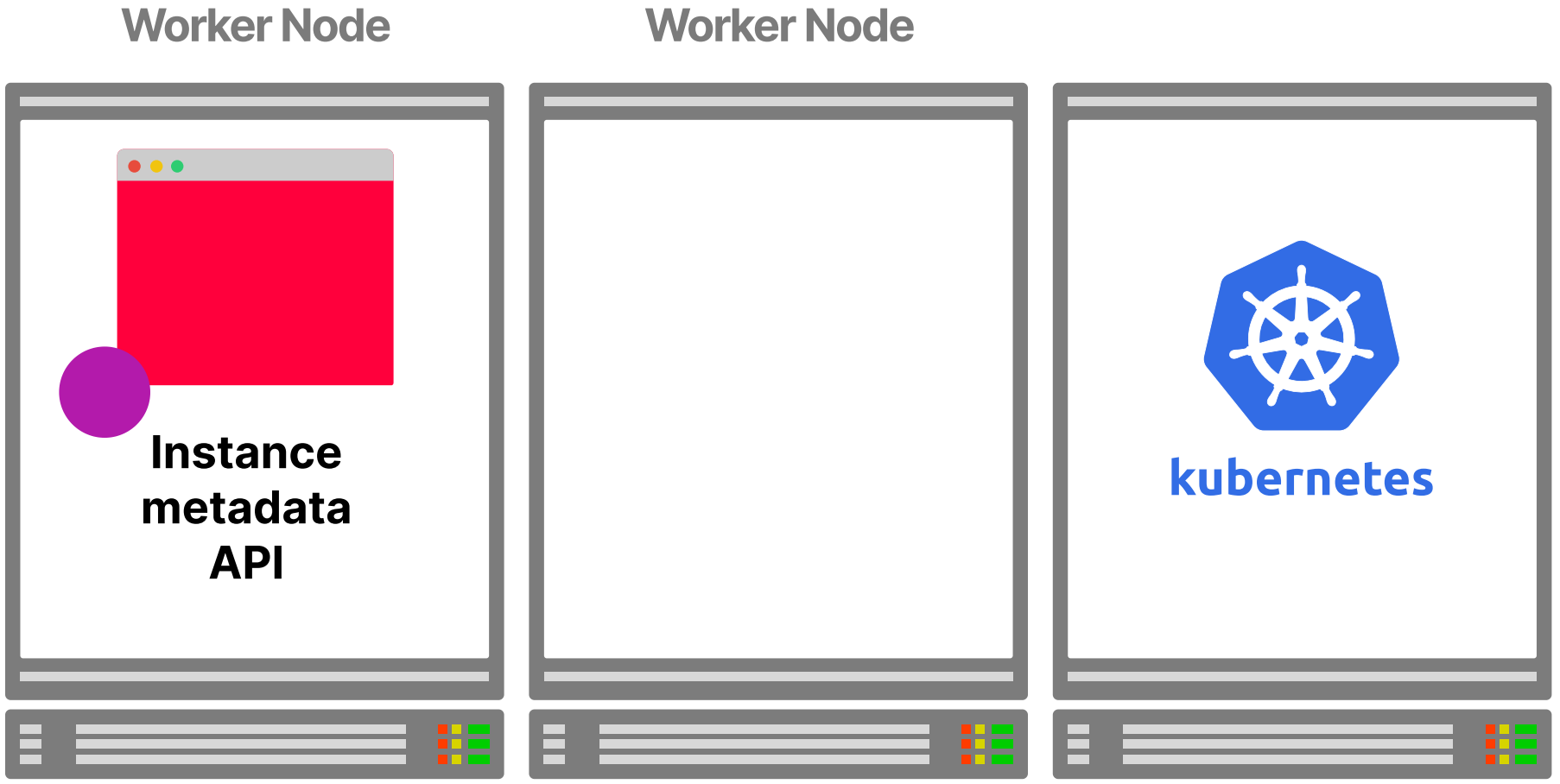

Worker Node
Worker Node
ArgoCD dashboard / Kubernetes dashboard
kubernetes

4. Exposed sensitive interfaces

Network Policies
L7 policies
Encrypted traffic

Discovery

5. Instance metadata API

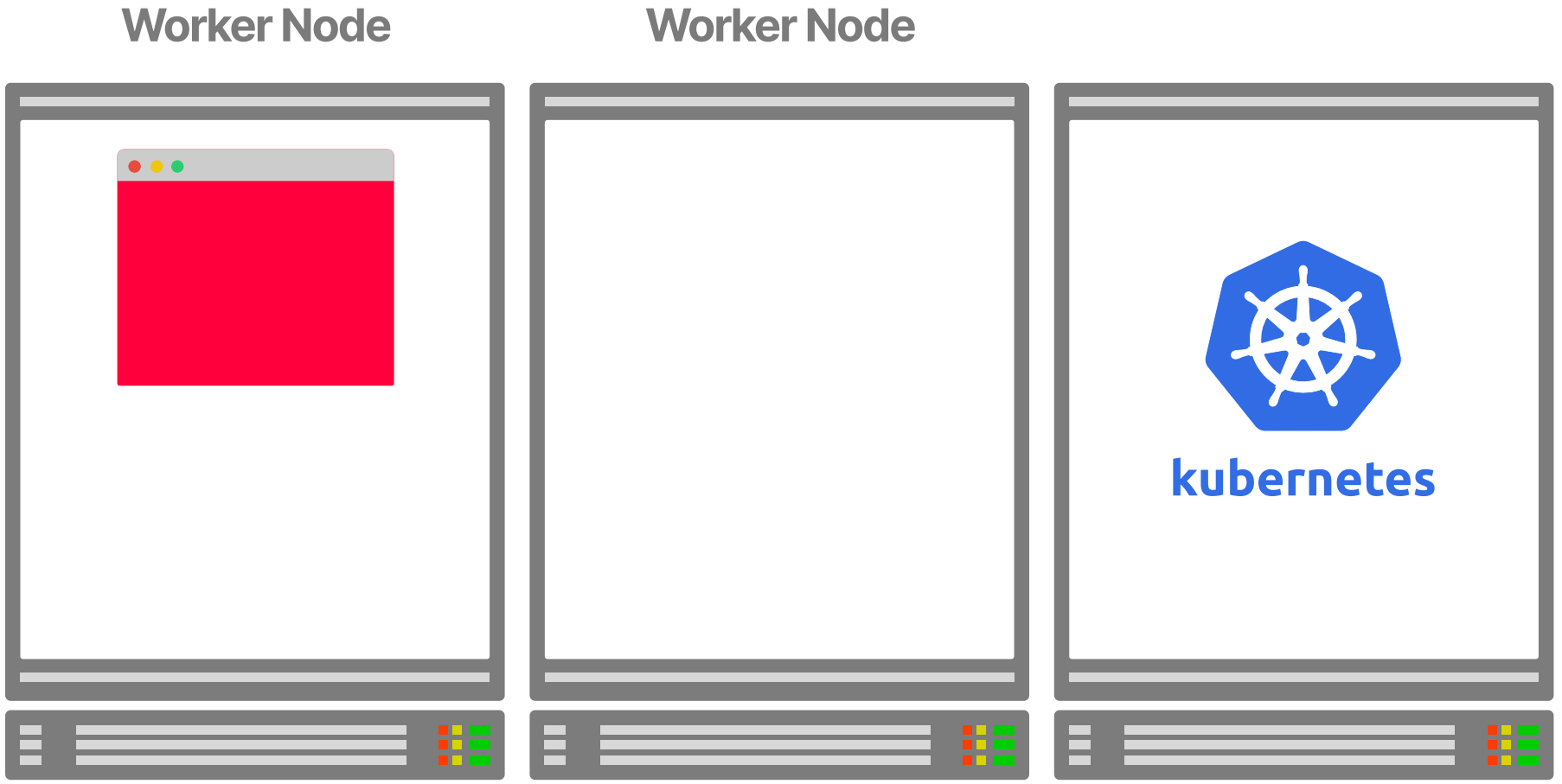

Worker Node
Worker Node
Instance metadata API
kubernetes

Disable cloud metadata

Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container					Access the Kubernetes API server	
Compromised images in registry	bash/cmd inside container					Access Kubelet API	
Kubeconfig file	New container					Network mapping	
Application vulnerability						Access Kubernetes dashboard	
Exposed sensitive interfaces						Instance metadata API	
Control plane + kubelet misconfiguration							

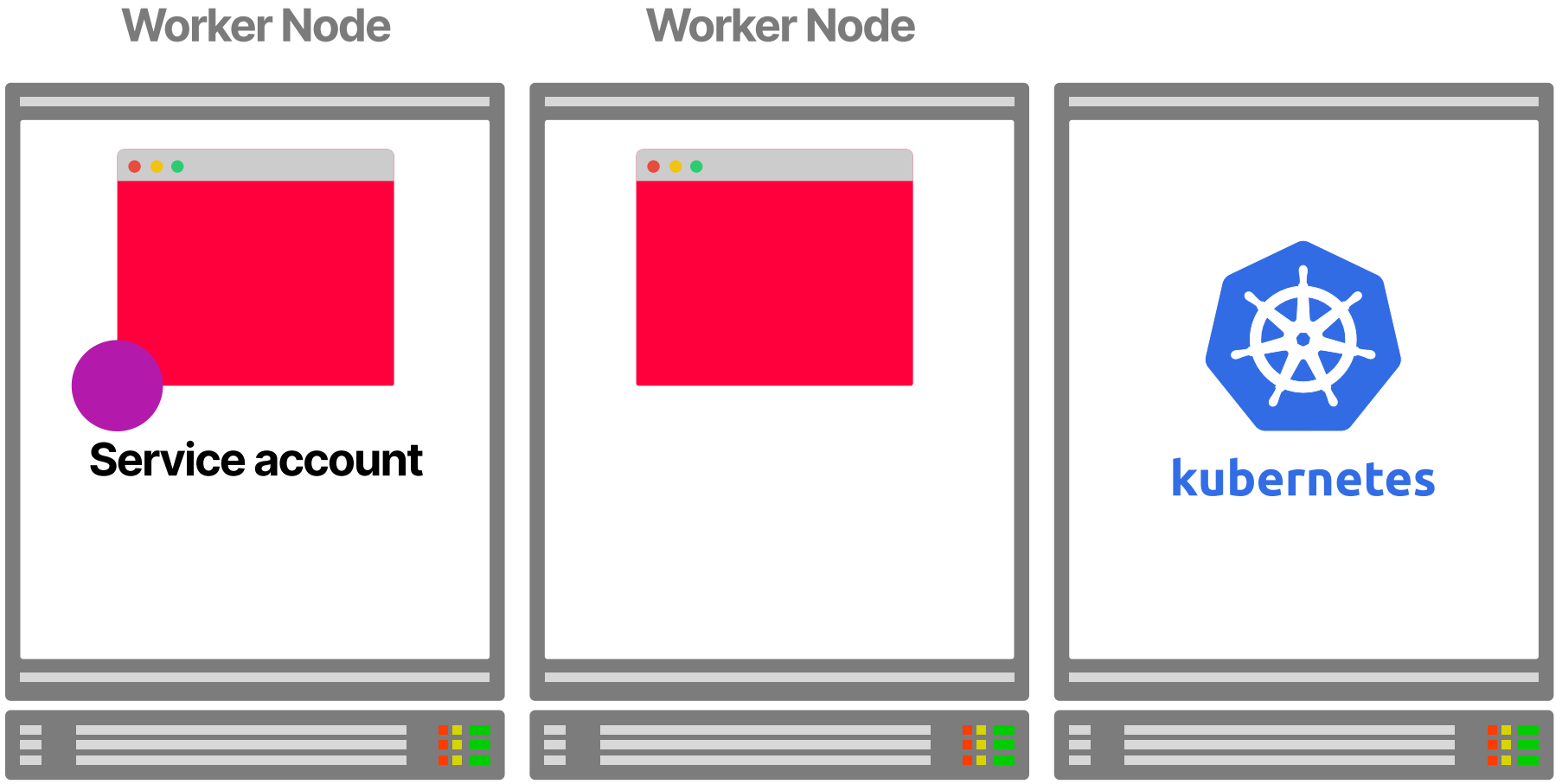
Lateral movement

04



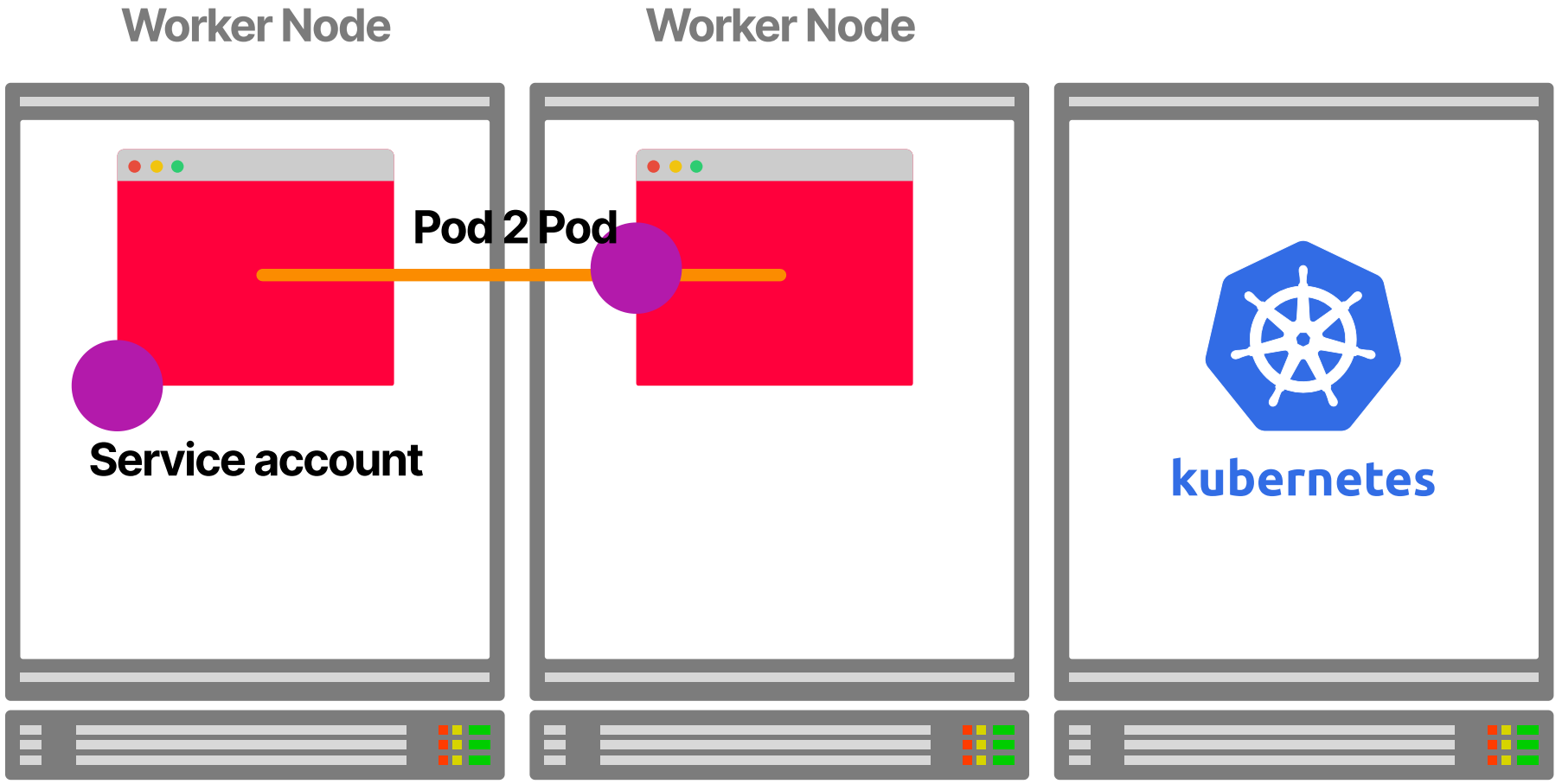
Microsoft Azure Google Cloud amazon web services

Access cloud resources



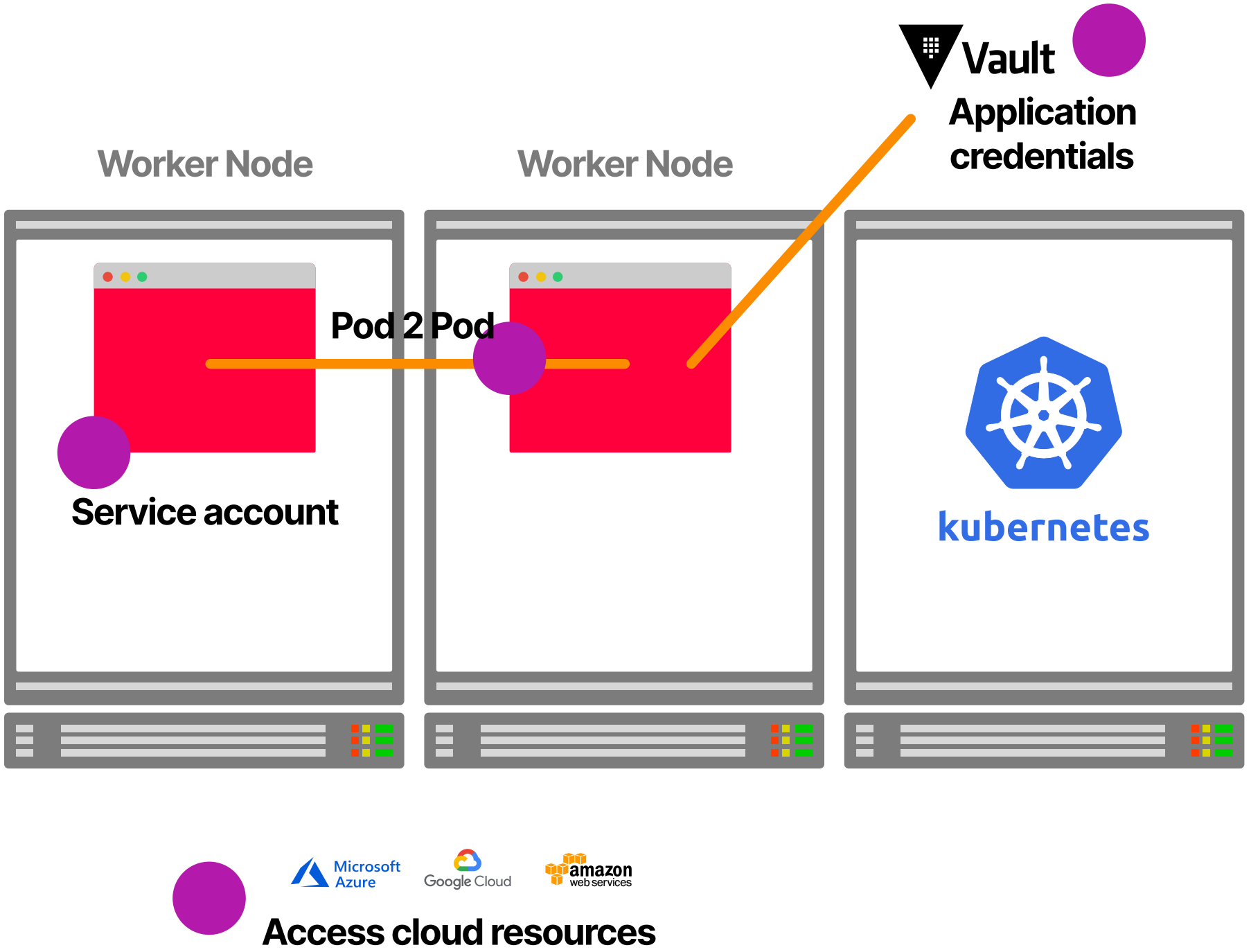
Microsoft Azure Google Cloud amazon web services

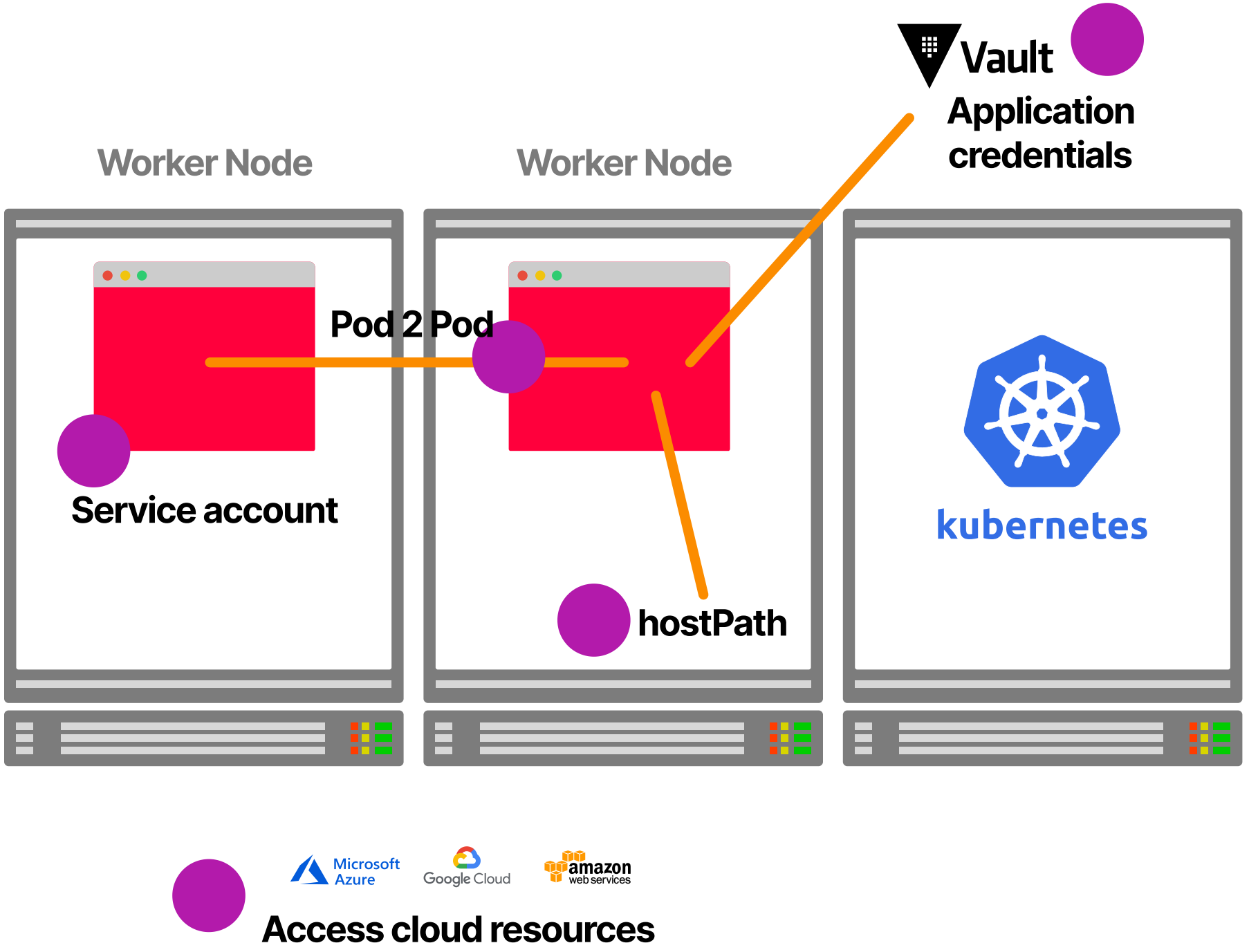
Access cloud resources

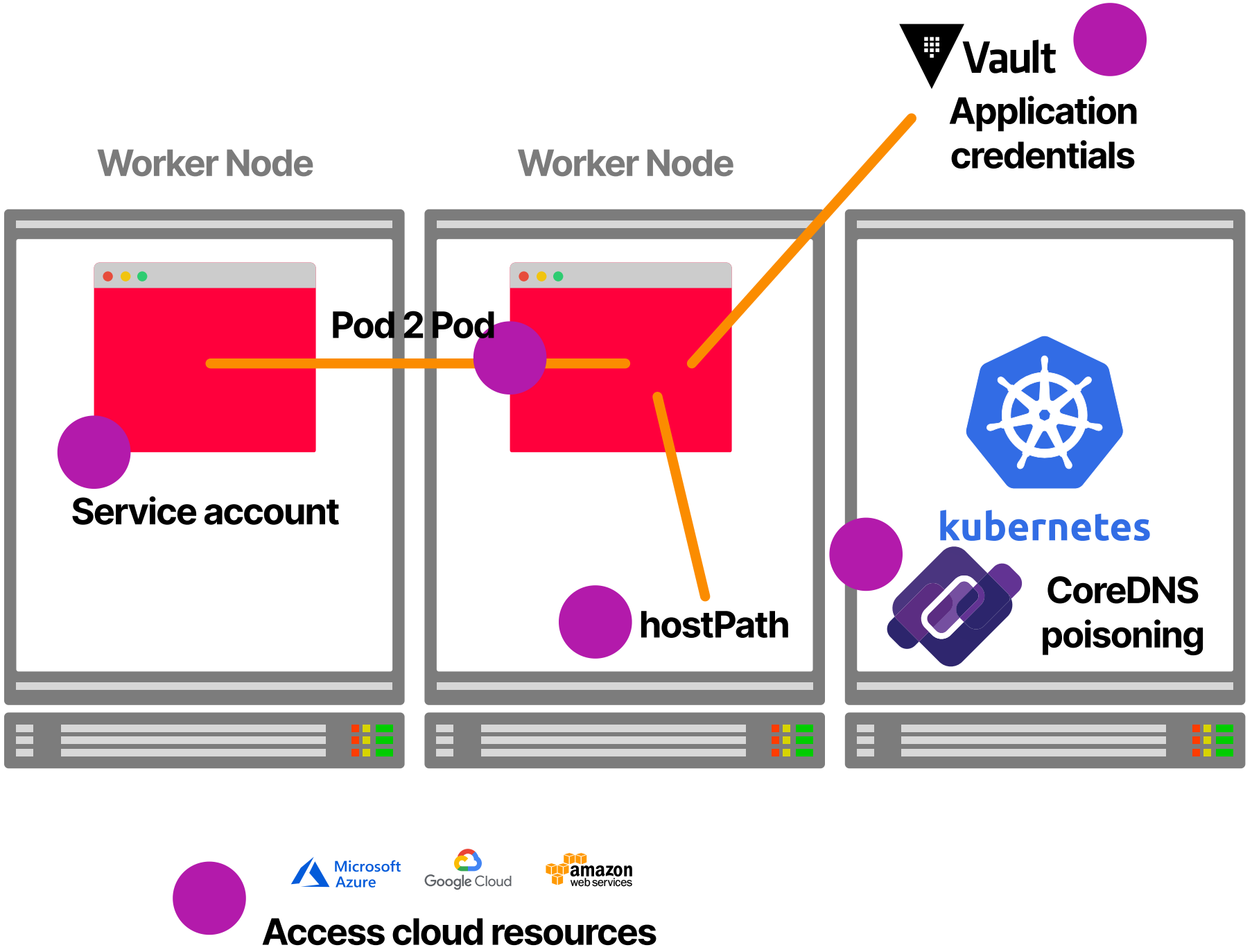


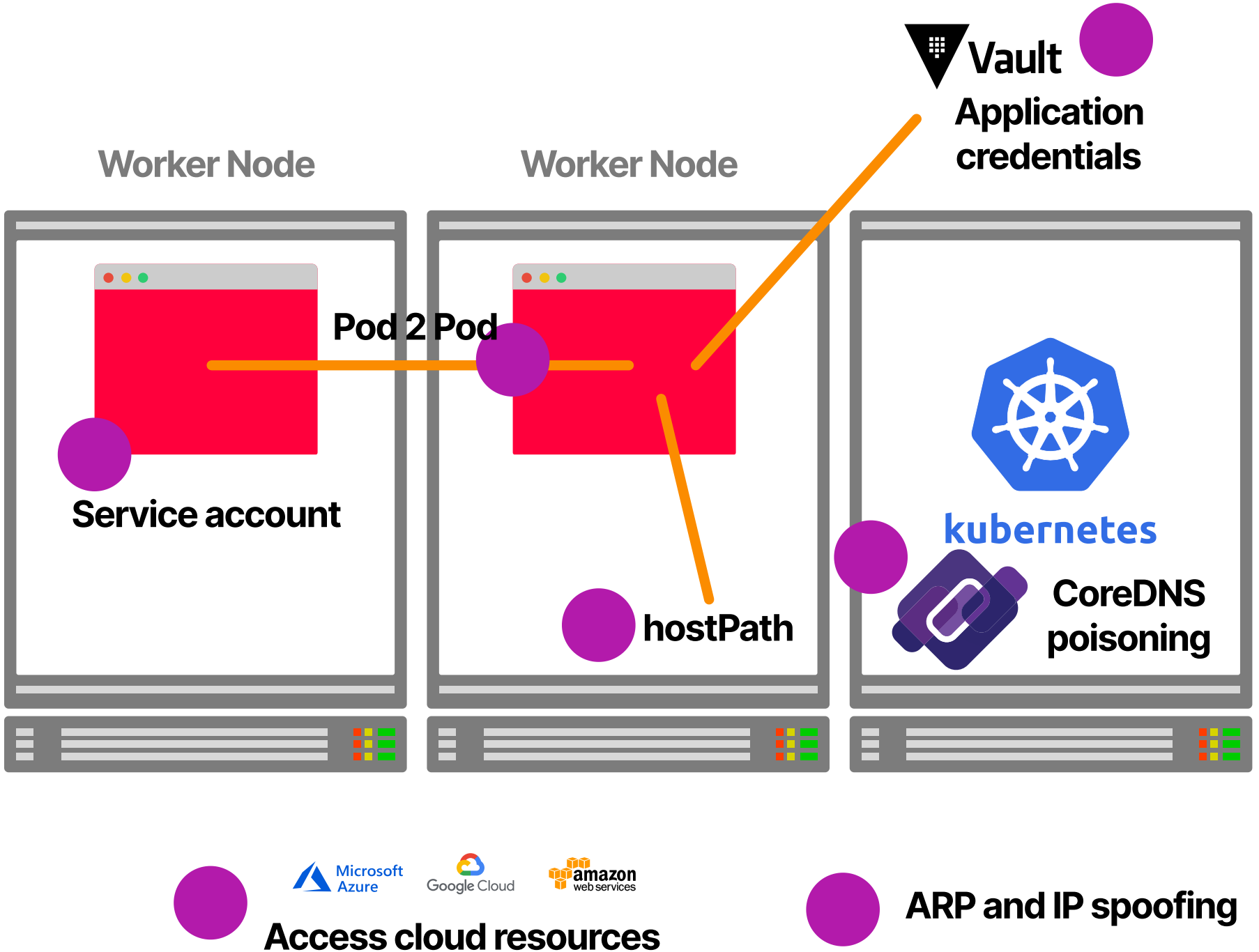
Microsoft Azure Google Cloud amazon web services

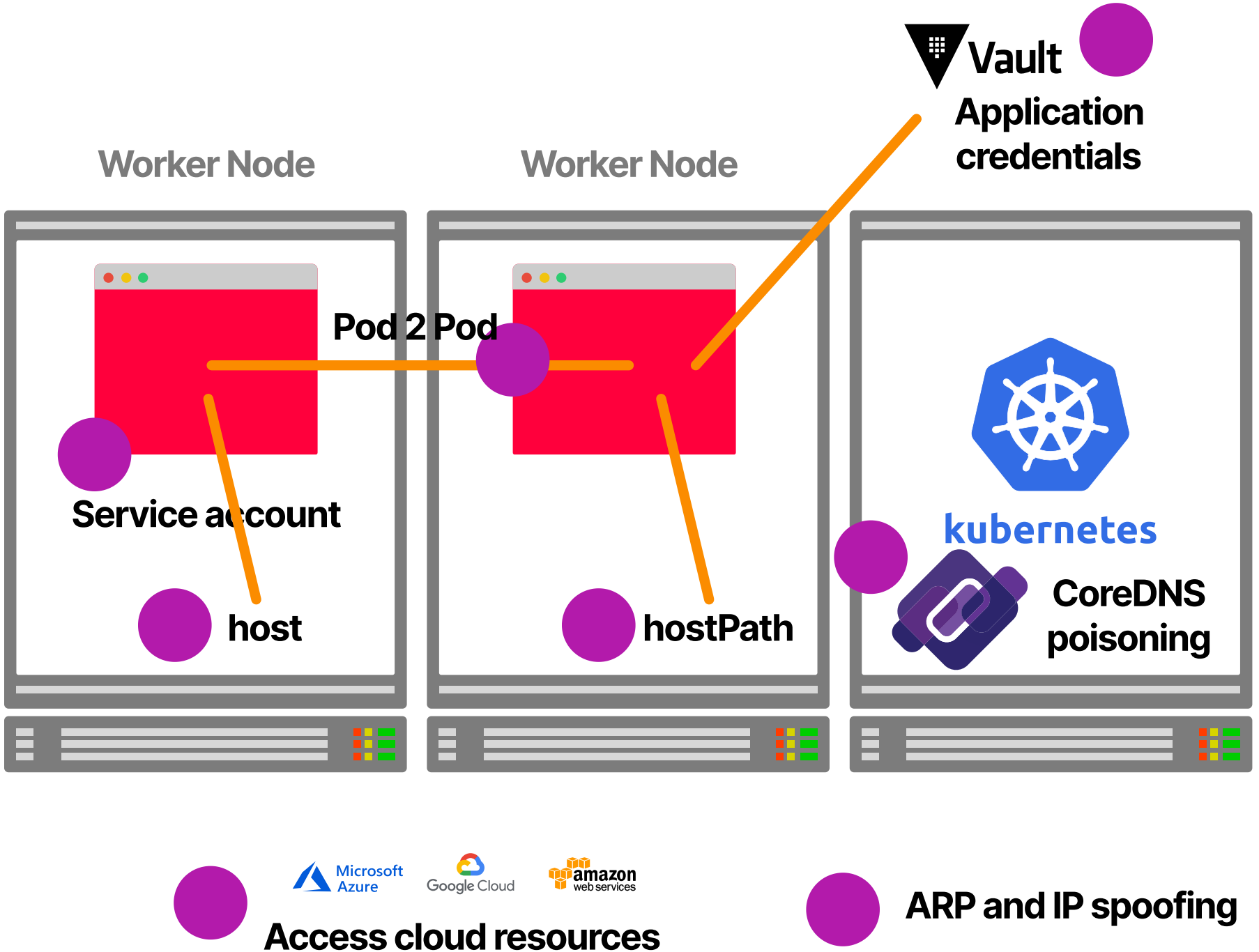
Access cloud resources


Vault
Application credentials
Worker Node
Worker Node
Pod 2 Pod
Service account
kubernetes
Microsoft Azure
Google Cloud
amazon web services
Access cloud resources


Vault
Application credentials
Worker Node
Worker Node
Pod 2 Pod
Service account
hostPath
kubernetes
Microsoft Azure
Google Cloud
amazon web services
Access cloud resources

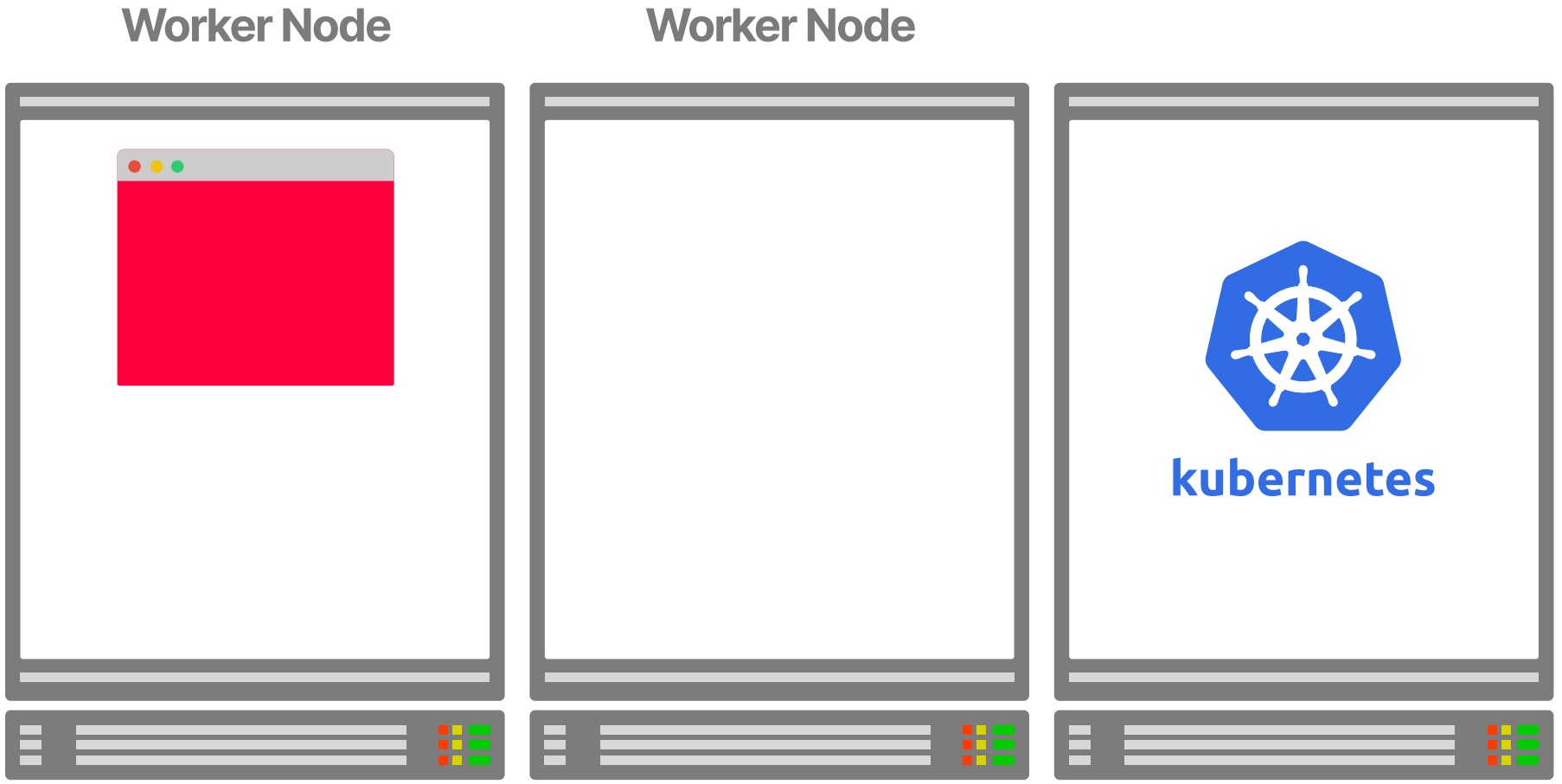

Vault
Application credentials
Worker Node
Worker Node
Pod 2 Pod
Service account
hostPath
kubernetes
CoreDNS poisoning
Microsoft Azure
Google Cloud
amazon web services
Access cloud resources


Vault
Application credentials
Worker Node
Worker Node
Pod 2 Pod
Service account
hostPath
kubernetes
CoreDNS poisoning
Microsoft Azure
Google Cloud
amazon web services
Access cloud resources
ARP and IP spoofing


Vault
Application credentials
Worker Node
Worker Node
Pod 2 Pod
Service account
host
hostPath
kubernetes
CoreDNS poisoning
Microsoft Azure
Google Cloud
amazon web services
Access cloud resources
ARP and IP spoofing

Lateral movement

1. Access cloud resources



Microsoft Azure Google Cloud amazon web services

Access cloud resources

1. Access cloud resources

IAMs

Granular permissions

Credentials rotation

1. Access cloud resources

IAMs

Granular permissions

Credentials rotation

1. Access cloud resources

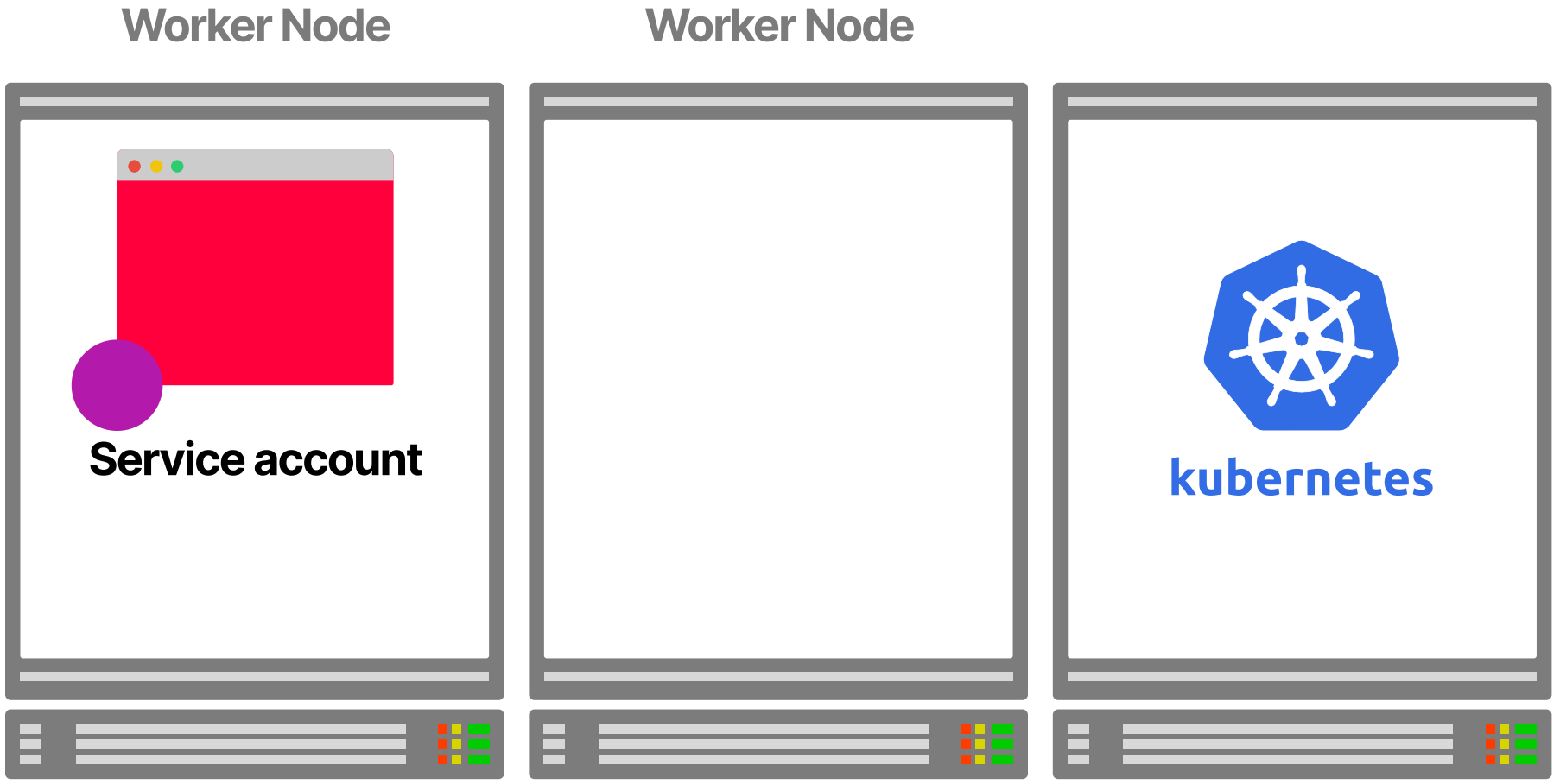
IAMs

Granular permissions

Credentials rotation

Lateral movement

2. Pod service account

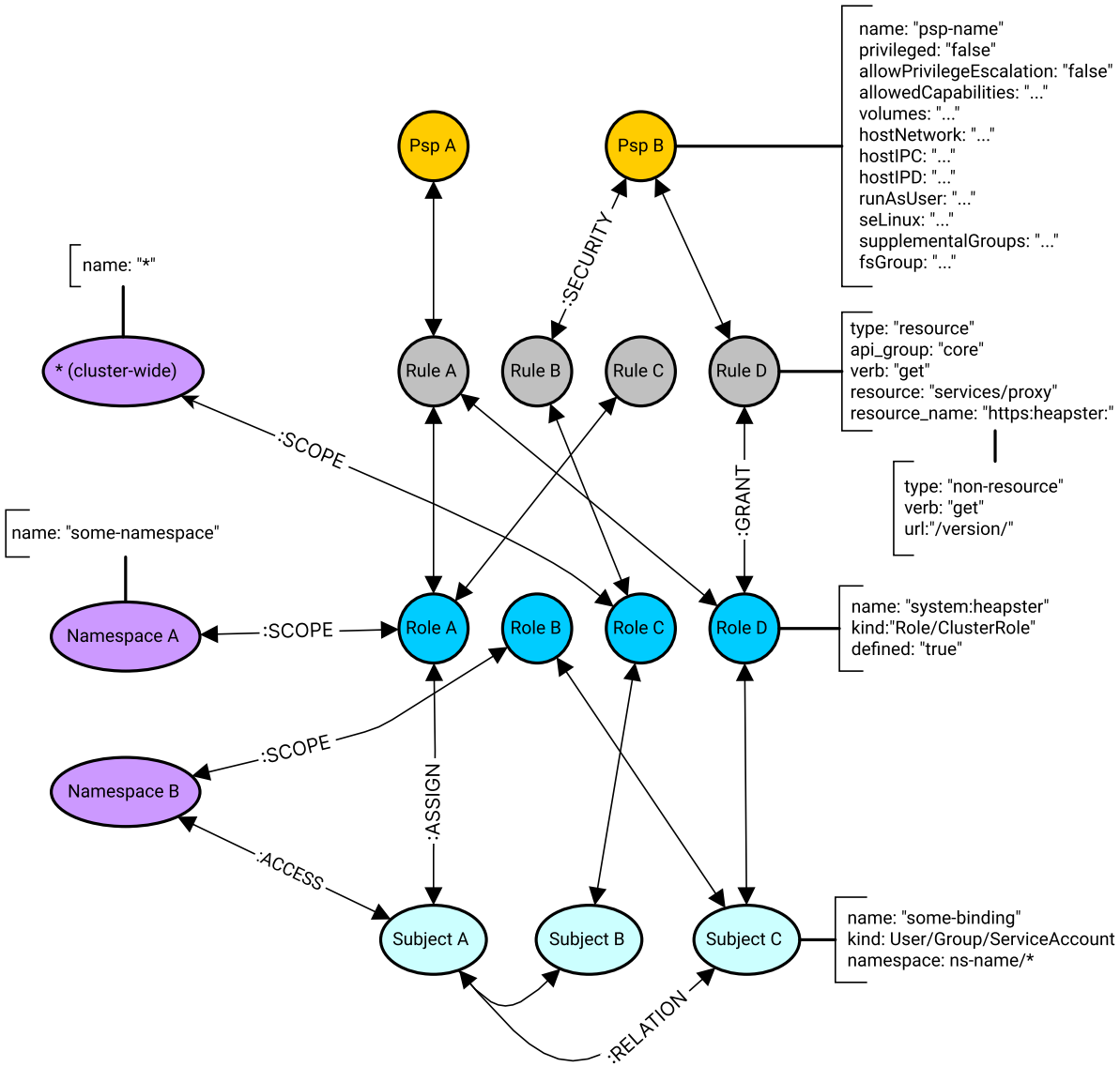

Worker Node
Worker Node
Service account
kubernetes

2. Pod service account

appvia/krane

alcideio/rbac-tool

cyberark/kubernetes-rbac-audit


Psp A
Psp B
name: "psp-name"
privileged: "false"
allowPrivilegeEscalation: "false"
allowedCapabilities: "..."
volumes: "..."
hostNetwork: "..."
hostIPC: "..."
hostIPD: "..."
runAsUser: "..."
seLinux: "..."
supplementalGroups: "..."
fsGroup: "..."
:SECURITY
name: "*"
* (cluster-wide)
Rule A
Rule B
Rule C
Rule D
type: "resource"
api_group: "core"
verb: "get"
resource: "services/proxy"
resource_name: "https:heapster:"
type: "non-resource"
verb: "get"
url:"/version/"
:SCOPE
:GRANT
name: "some-namespace"
Namespace A
:SCOPE
Role A
Role B
Role C
Role D
name: "system:heapster"
kind:"Role/ClusterRole"
defined: "true"
:SCOPE
Namespace B
:ASSIGN
:ACCESS
Subject A
Subject B
Subject C
name: "some-binding"
kind: User/Group/ServiceAccount
namespace: ns-name/*
:RELATION

2. Pod service account

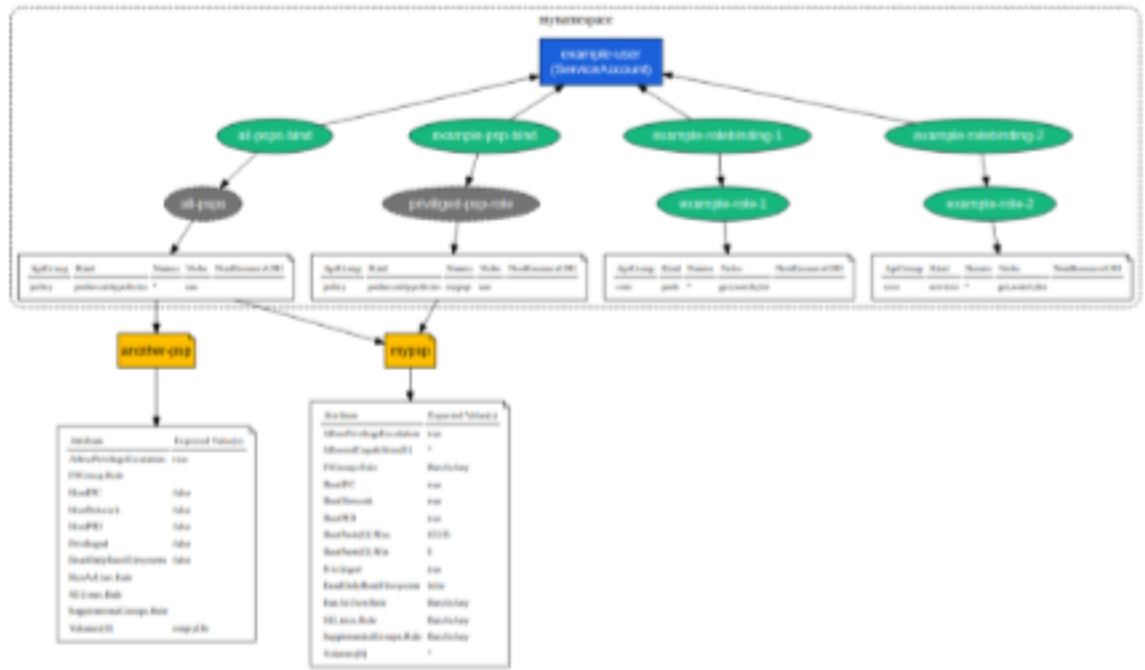
appvia/krane

alcideio/rbac-tool

cyberark/kubernetes-rbac-audit



Legend


mynamespace
example-user
(ServiceAccount)
all-psps-bind
example-psp-bind
example-rolebinding-1
example-rolebinding-2
all-psps
privilged-psp-role
example-role-1
example-role-2
another-psp
mypsp

2. Pod service account

appvia/krane

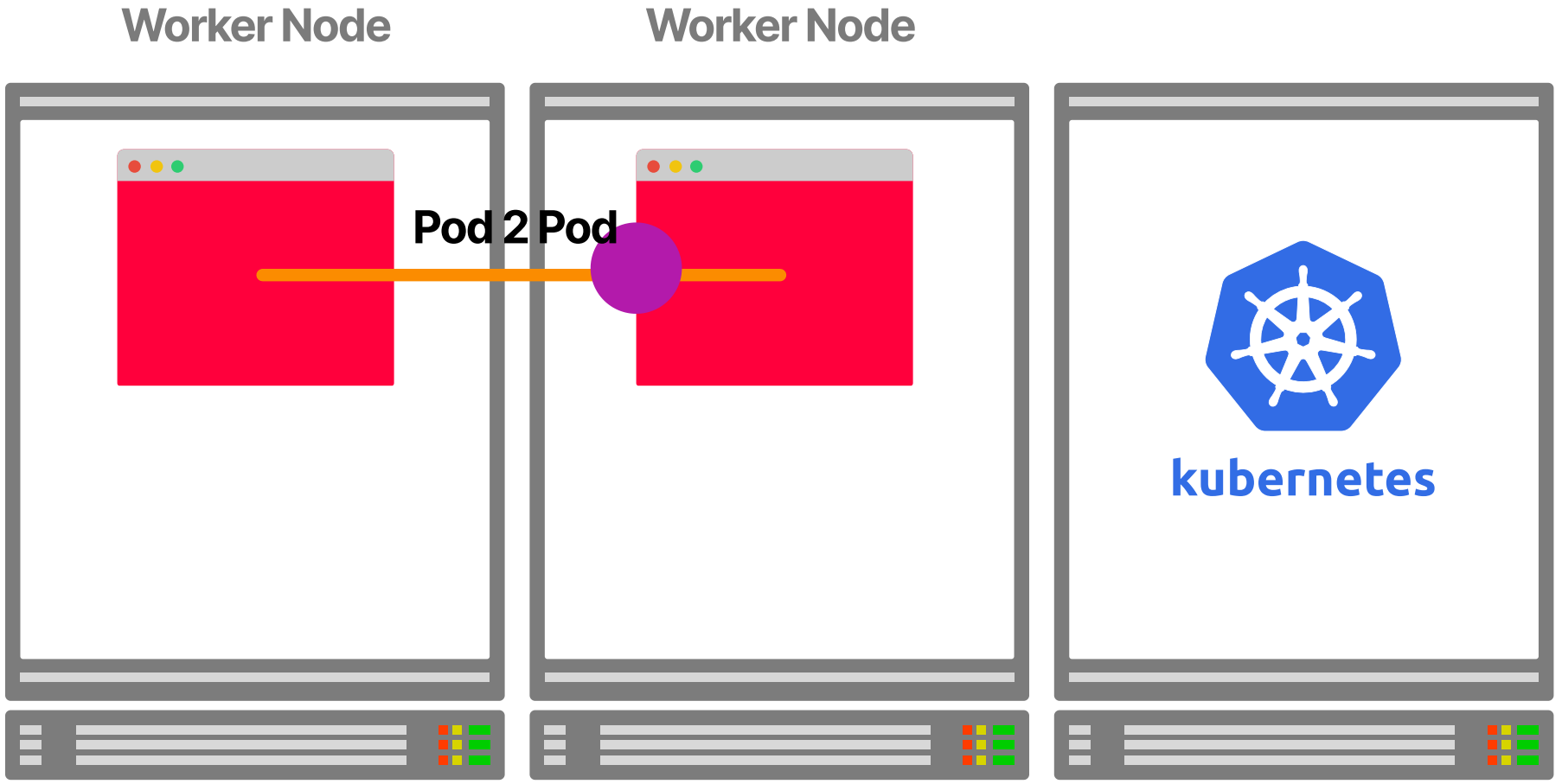
alcideio/rbac-tool

cyberark/kubernetes-rbac-audit

```
[*] Started enumerating risky ClusterRoles:
[!][ClusterRole]→ Cluster-pod-creator Has permission to create pods!
[!][ClusterRole]→ Cluster-Secret-reder Has permission to list secrets!
[!][ClusterRole]→ resource-reader Has permission to use get on any resource!
[!][ClusterRole]→ nginx-lb-nginx-ingress Has permission to list secrets!
[!][ClusterRole]→ prometheus-adapter-server-resources Has Admin-Cluster permission!
[!][ClusterRole]→ prometheus-kube-state-metrics Has permission to list secrets!
[!][ClusterRole]→ prometheus-prometheus-oper-operator Has permission to access statefulsets with any verb!
[!][ClusterRole]→ prometheus-prometheus-oper-operator Has permission to list secrets!
[!][ClusterRole]→ prometheus-prometheus-oper-operator Has permission to access secrets with any verb!
[*] Started enumerating risky Roles:
[!][Role]→ nginx-lb-nginx-ingress Has permission to list secrets!
[!][Role]→ kubesystem-pod-creator Has permission to create pods!
[!][Role]→ default-admin Has Admin-Cluster permission!
[!][Role]→ res-reader Has permission to use get on any resource!
[!][Role]→ Random-user Has permission to use get on any resource!
[!][Role]→ local-secret-reader Has permission to list secrets!
[*] Started enumerating risky ClusterRoleBinding:
[!][ClusterRoleBinding]→ nginx-lb-nginx-ingress is binded to nginx-lb-nginx-ingress ServiceAccount.
[!][ClusterRoleBinding]→ sa1-resources is binded to sa1 ServiceAccount.
[!][ClusterRoleBinding]→ secret-reader is binded to sa-secret-reader ServiceAccount.
[!][ClusterRoleBinding]→ sa-pod-creator is binded to sa-pod-creator ServiceAccount.
[!][ClusterRoleBinding]→ prometheus-adapter-hpa-controller is binded to prometheus-adapter ServiceAccount.
[!][ClusterRoleBinding]→ prometheus-kube-state-metrics is binded to prometheus-kube-state-metrics ServiceAccount.
[!][ClusterRoleBinding]→ prometheus-prometheus-oper-operator is binded to prometheus-prometheus-oper-operator ServiceAccount.
[*] Started enumerating risky RoleRoleBindings:
[!][RoleBinding]→ nginx-lb-nginx-ingress is binded to nginx-lb-nginx-ingress ServiceAccount.
[!][RoleBinding]→ local-secret is binded to kubesystem-secret-reader ServiceAccount.
```

Lateral movement

3. Cluster internal networking


Worker Node
Worker Node
Pod 2 Pod
kubernetes

Network policies editor

mattfenwick/cyclonus

inovex/illuminatio

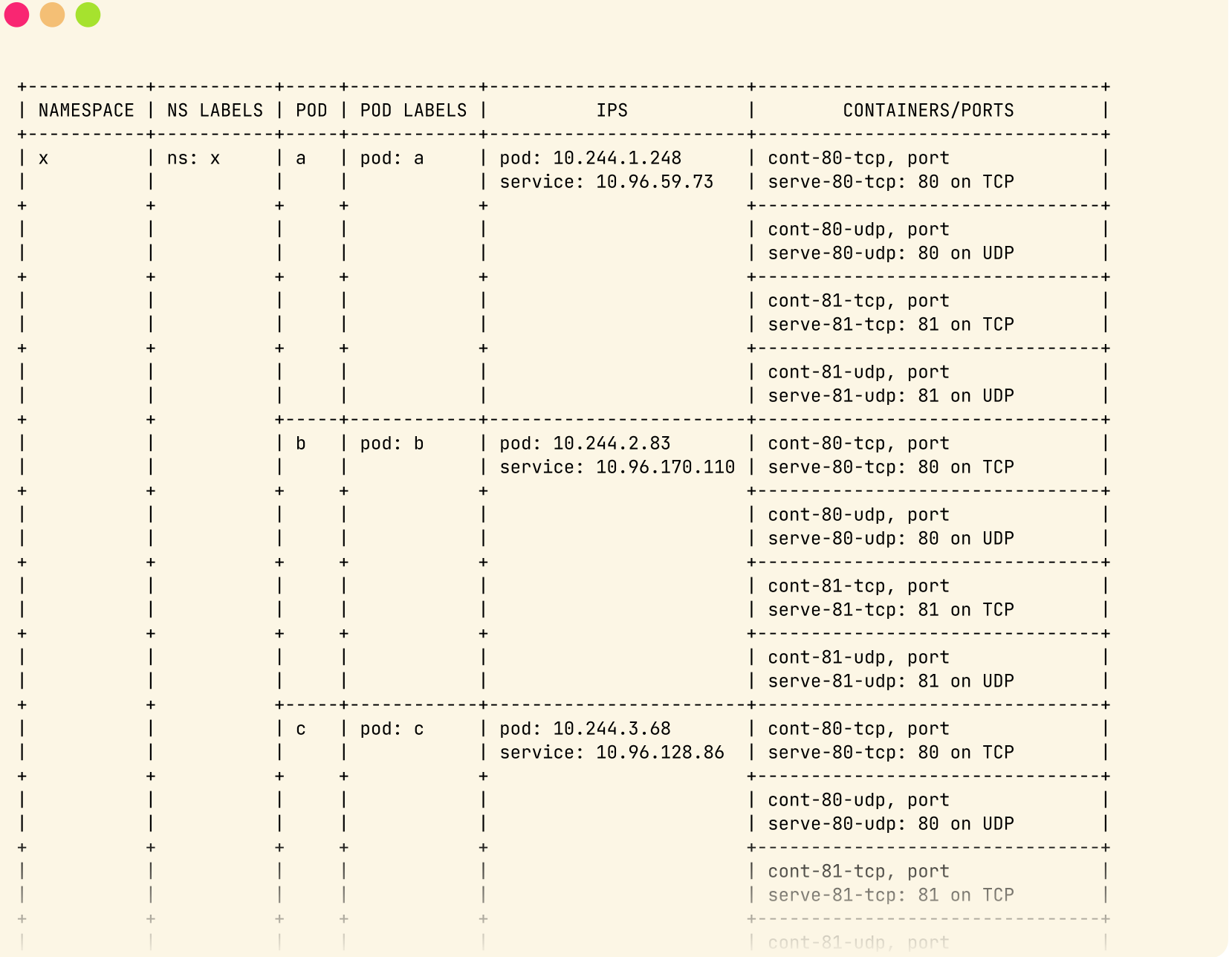

Feedback/Questions?
Ask on Slack
Outside Cluster
In Namespace
In Cluster
Kubernetes Network Policy
Cilium Network Policy
Policy Rating
Download
Share
1 apiVersion: networking.k8s.io/v1
2 kind: NetworkPolicy
3 metadata:
4 name: untitled-policy
5 spec:
6 podSelector: {}
7
Main tutorial
Flows upload
Welcome to the Network Policy Editor! Beta
This tutorial will teach you how to create a network policy using the Editor. It explains basic network policy concepts and guides you through the steps needed to achieve the desired least- privilege security and zero-trust concepts.
Step 1. What pods do you want to secure?
Cluster
namespaceA
namespaceB
Pod

3. Cluster Internal networking

Network policies editor

mattfenwick/cyclonus

inovex/illuminatio


NAMESPACE | NS LABELS | POD | POD LABELS | IPS | CONTAINERS/PORTS
x | ns: x | a | pod: a | pod: 10.244.1.248 | service: 10.96.59.73 | cont-80-tcp, port serve-80-tcp: 80 on TCP
cont-80-udp, port serve-80-udp: 80 on UDP
cont-81-tcp, port serve-81-tcp: 81 on TCP
cont-81-udp, port serve-81-udp: 81 on UDP
b | pod: b | pod: 10.244.2.83 | service: 10.96.170.110 | cont-80-tcp, port serve-80-tcp: 80 on TCP
cont-80-udp, port serve-80-udp: 80 on UDP
cont-81-tcp, port serve-81-tcp: 81 on TCP
cont-81-udp, port serve-81-udp: 81 on UDP
c | pod: c | pod: 10.244.3.68 | service: 10.96.128.86 | cont-80-tcp, port serve-80-tcp: 80 on TCP
cont-80-udp, port serve-80-udp: 80 on UDP
cont-81-tcp, port serve-81-tcp: 81 on TCP
cont-81-udp, port

3. Cluster Internal networking

Network policies editor

mattfenwick/cyclonus

inovex/illuminatio

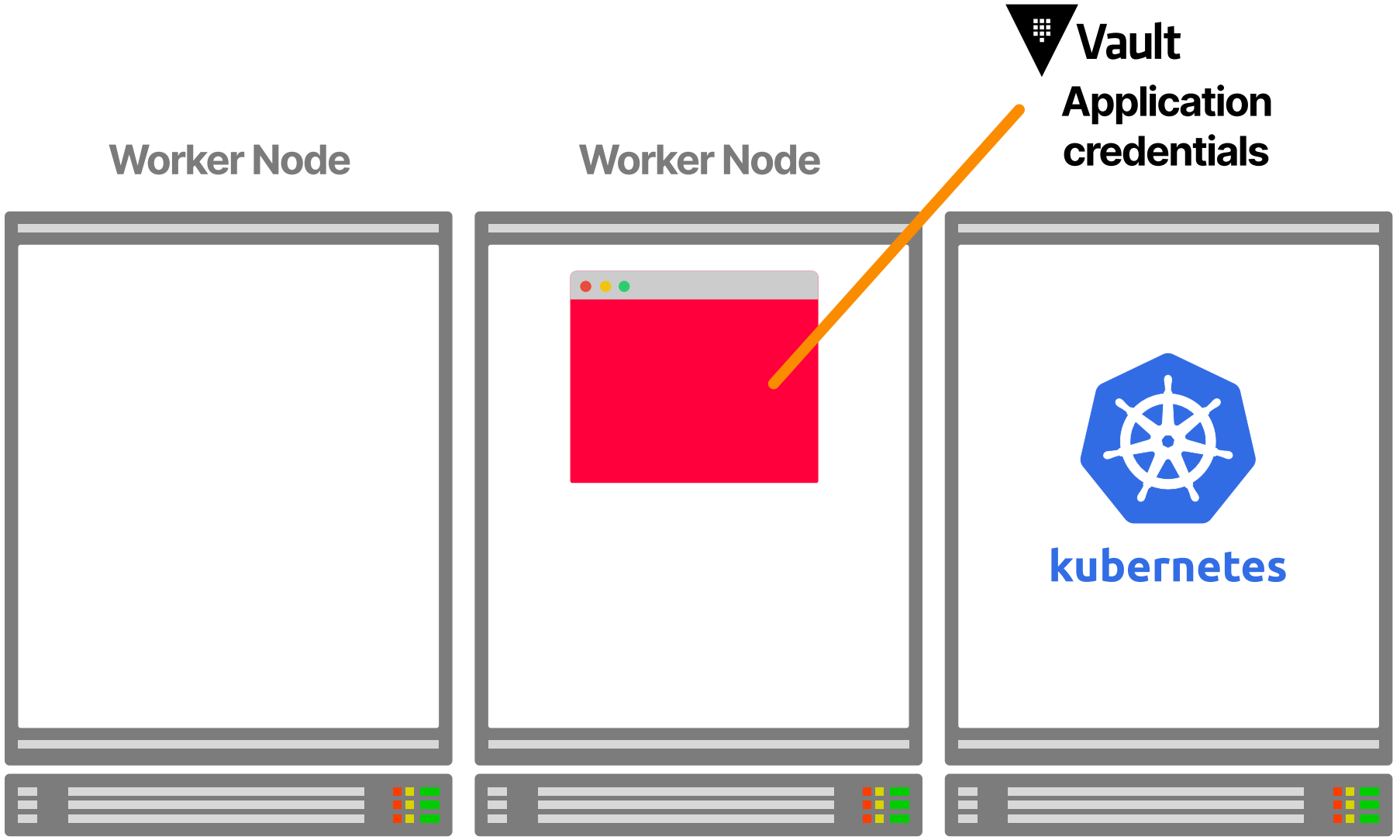
```
illuminatio clean run
Starting cleaning resources with policies ['on-request', 'always']
Deleting namespaces [] with cleanup policy on-request
Deleting namespaces [] with cleanup policy always
Deleting DSs in default with cleanup policy on-request
Deleting pods in default with cleanup policy on-request
Deleting svcs in default with cleanup policy on-request
Deleting CfgMaps in default with cleanup policy on-request
Deleting CRBs  with cleanup policy on-request globally
Deleting SAs in default with cleanup policy on-request
Deleting DSs in default with cleanup policy always
Deleting pods in default with cleanup policy always
Deleting svcs in default with cleanup policy always
Deleting CfgMaps in default with cleanup policy always
Deleting CRBs  with cleanup policy always globally
Deleting SAs in default with cleanup policy always
Finished cleanUp

Starting test generation and run.
Got cases: [NetworkTestCase(from=ClusterHost(namespace=default, podLabels={'app': 'web'}),
  to=ClusterHost(namespace=default, podLabels={'app': 'web'}), port=-*)]
Generated 1 cases in 0.0701 seconds
FROM             TO               PORT
default:app=web  default:app=web  -*

Using existing cluster role
Creating cluster role binding
TestResults: {'default:app=web': {'default:app=web': {'-*': {'success': True}}}}
Finished running 1 tests in 18.7413 seconds
FROM             TO               PORT  RESULT
default:app=web  default:app=web  -*    success
```

Lateral movement

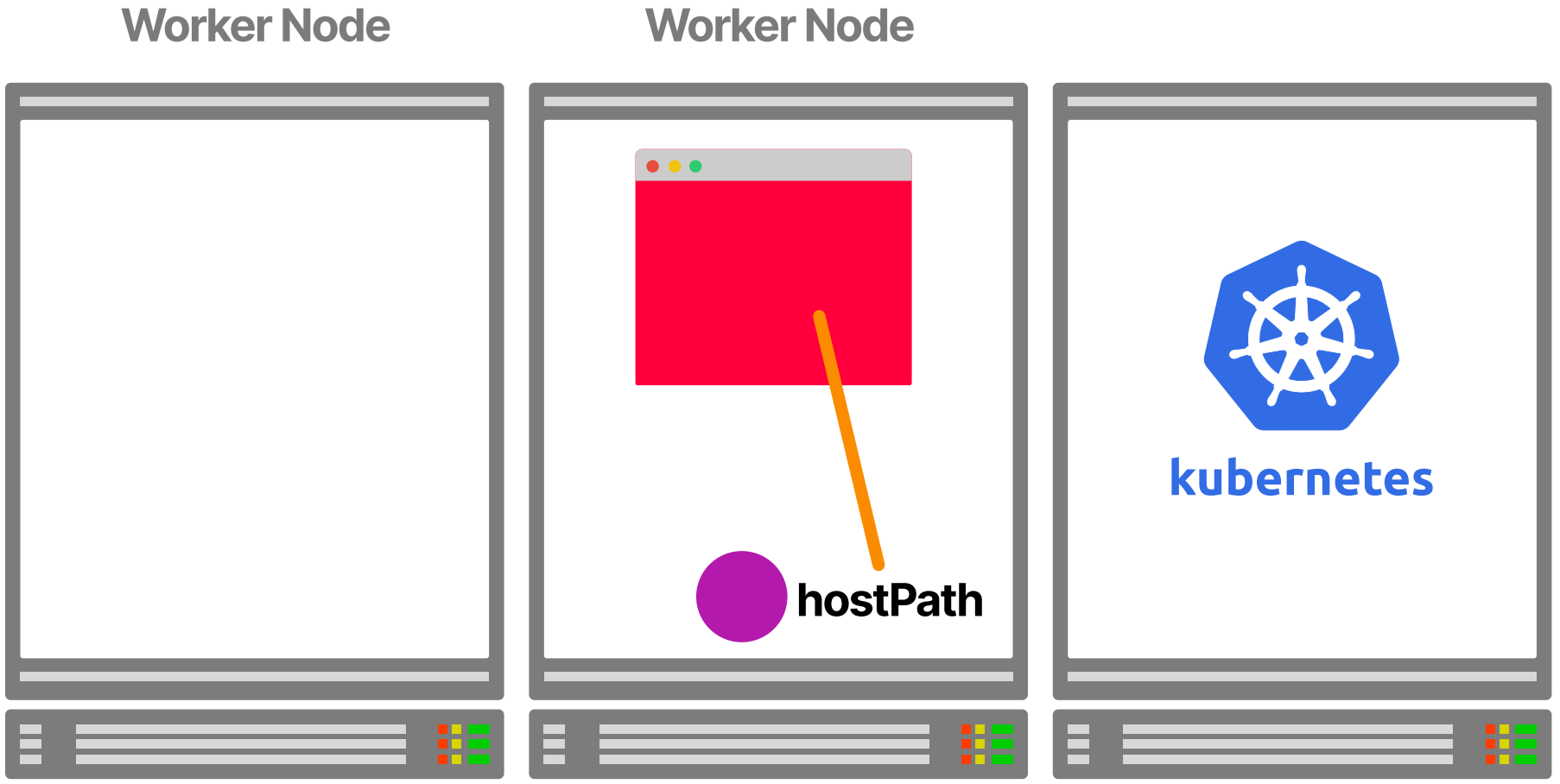
4. Application credentials


Vault
Application credentials
Worker Node
Worker Node
kubernetes

Granular permissions

Lateral movement

5. Writable volume mounts on host


Worker Node
Worker Node
hostPath
kubernetes

5. Writable volume mounts on host

OPA, Kyverno, etc.

Restrict priviliged pods

5. Writable volume mounts on host

OPA, Kyverno, etc.

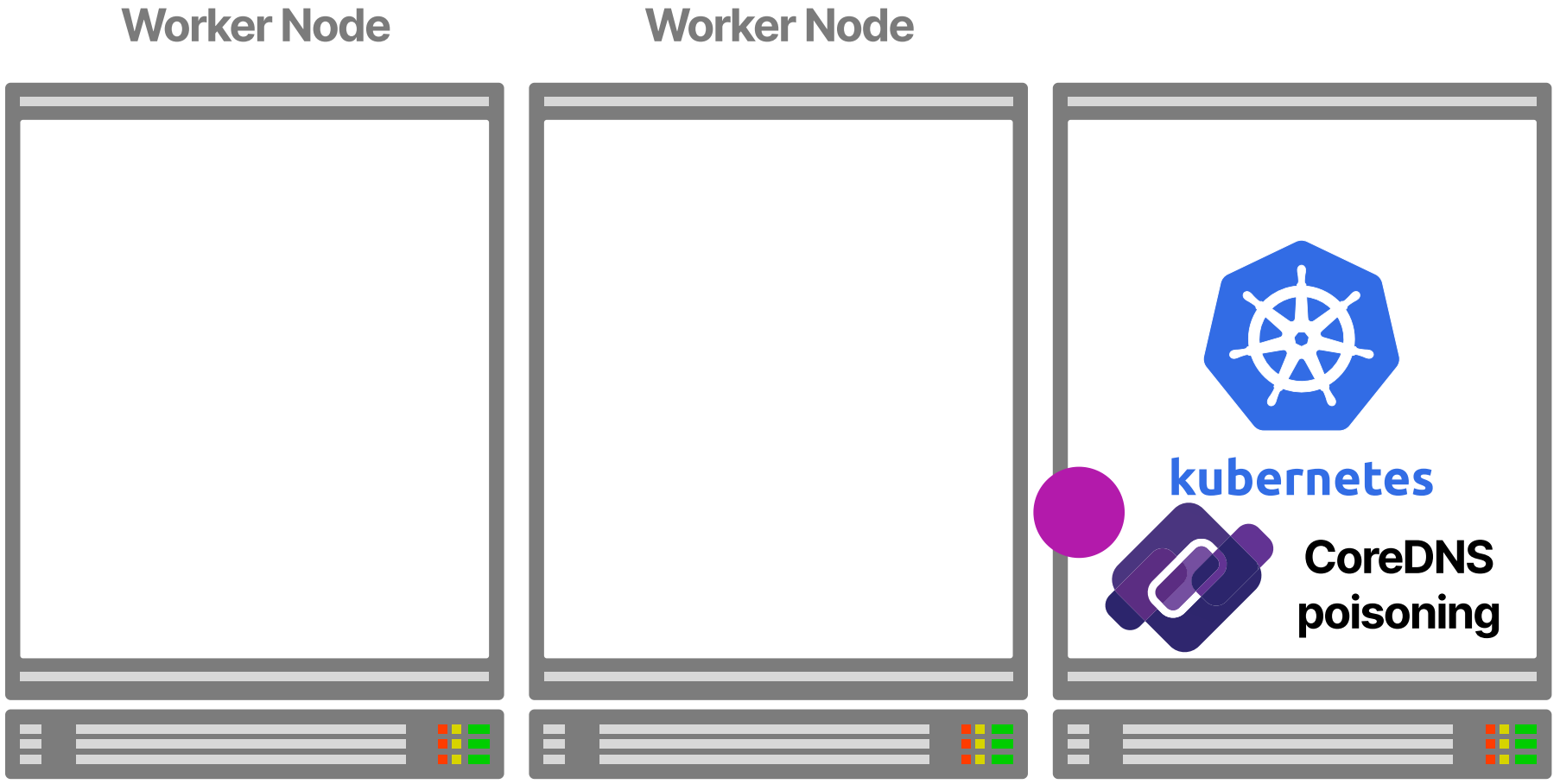
Restrict priviliged pods

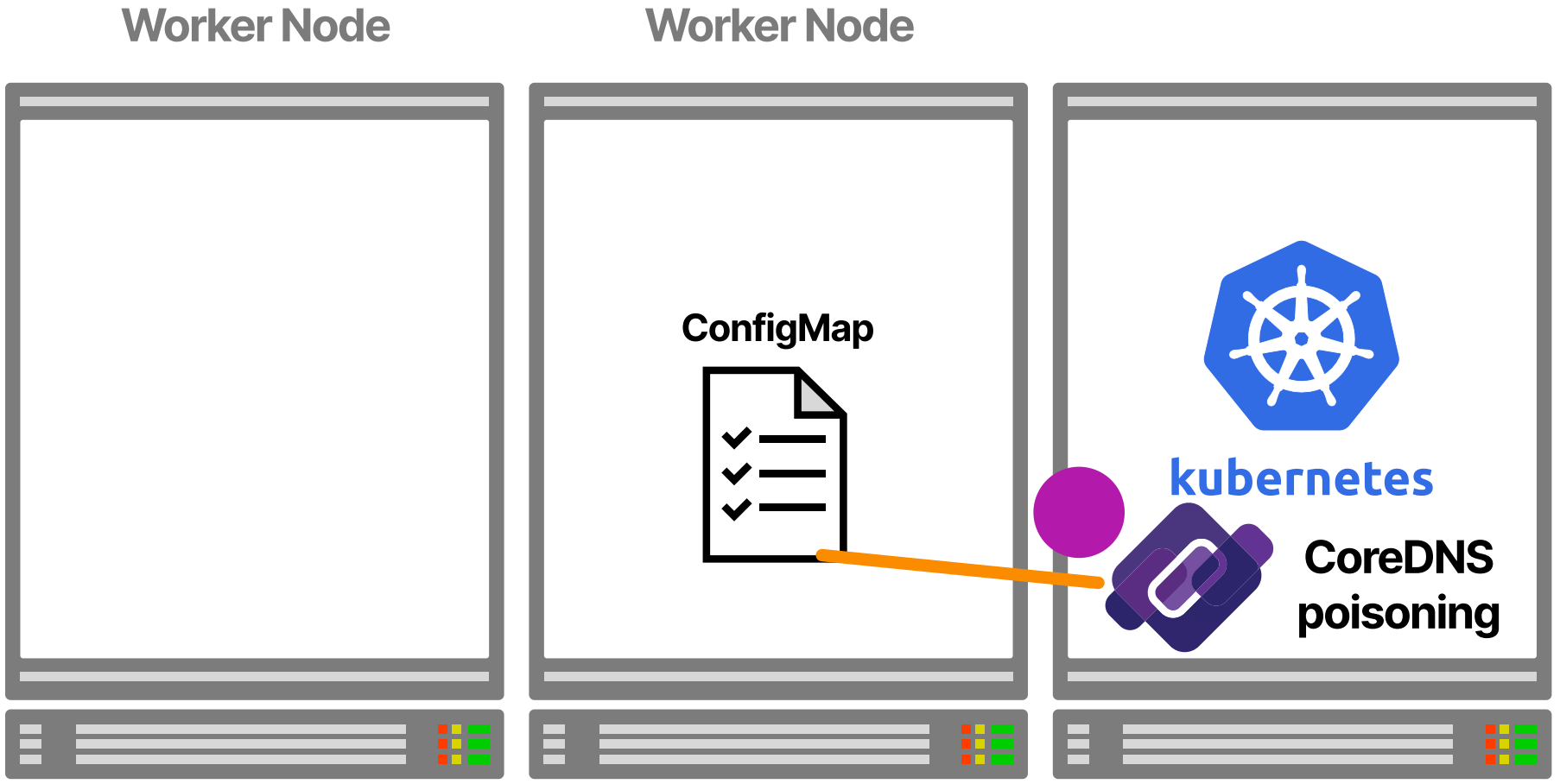
```
package kubernetes.admission

deny[message] {
    #applies for Pod resources
    input.request.kind.kind == "Pod"
    #loops through all containers in the request
    container := input.request.object.spec.containers[_]
    #for each container, check privileged field
    container.securityContext.privileged
    #if all above statements are true, return message
    message := sprintf("Privileged container %v ", [container.name])
}
```

Lateral movement

6. CoreDNS poisoning


Worker Node
Worker Node
kubernetes
CoreDNS
poisoning

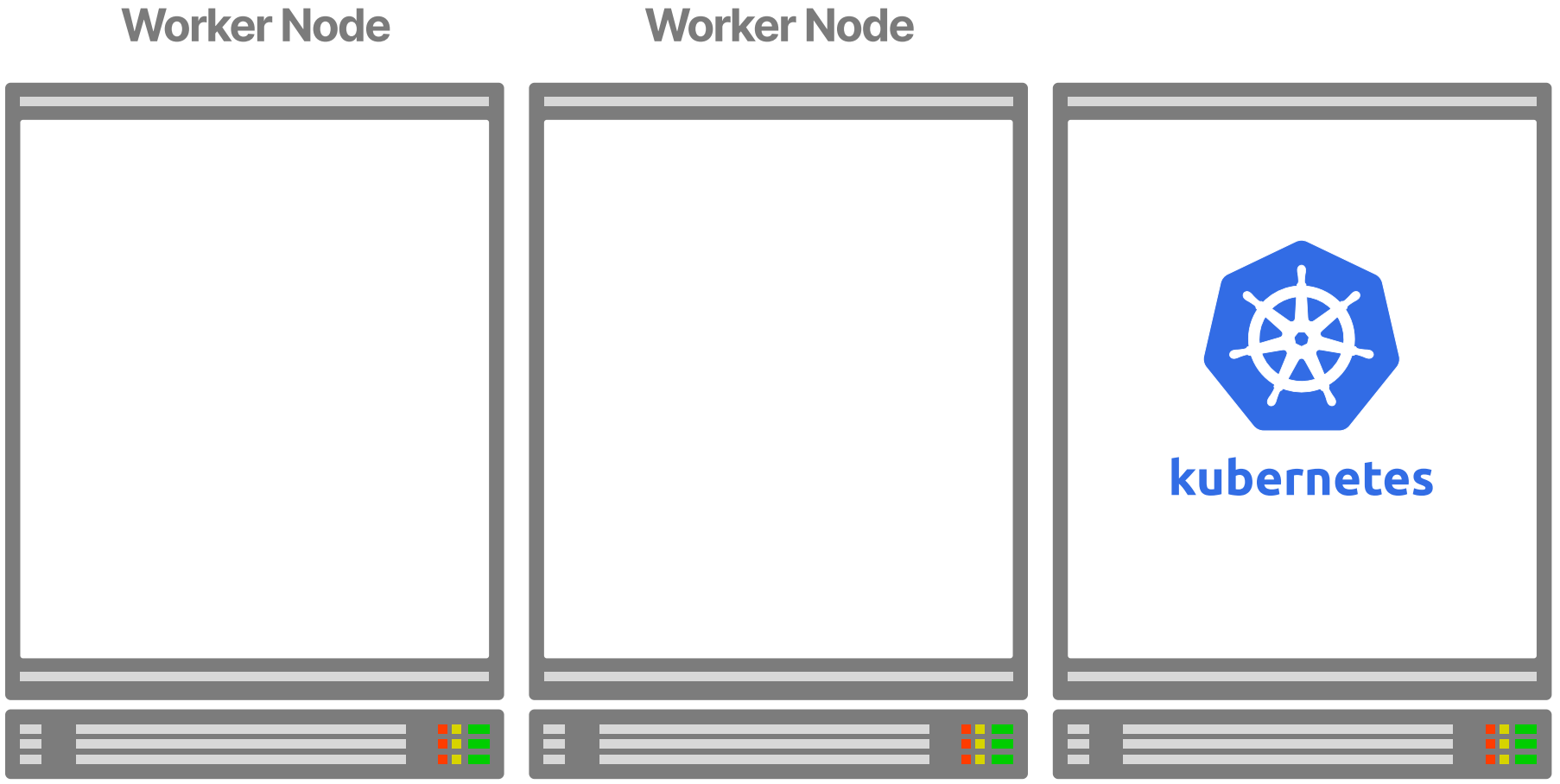

Worker Node
Worker Node
ConfigMap
kubernetes
CoreDNS
poisoning

6. CoreDNS poisoning

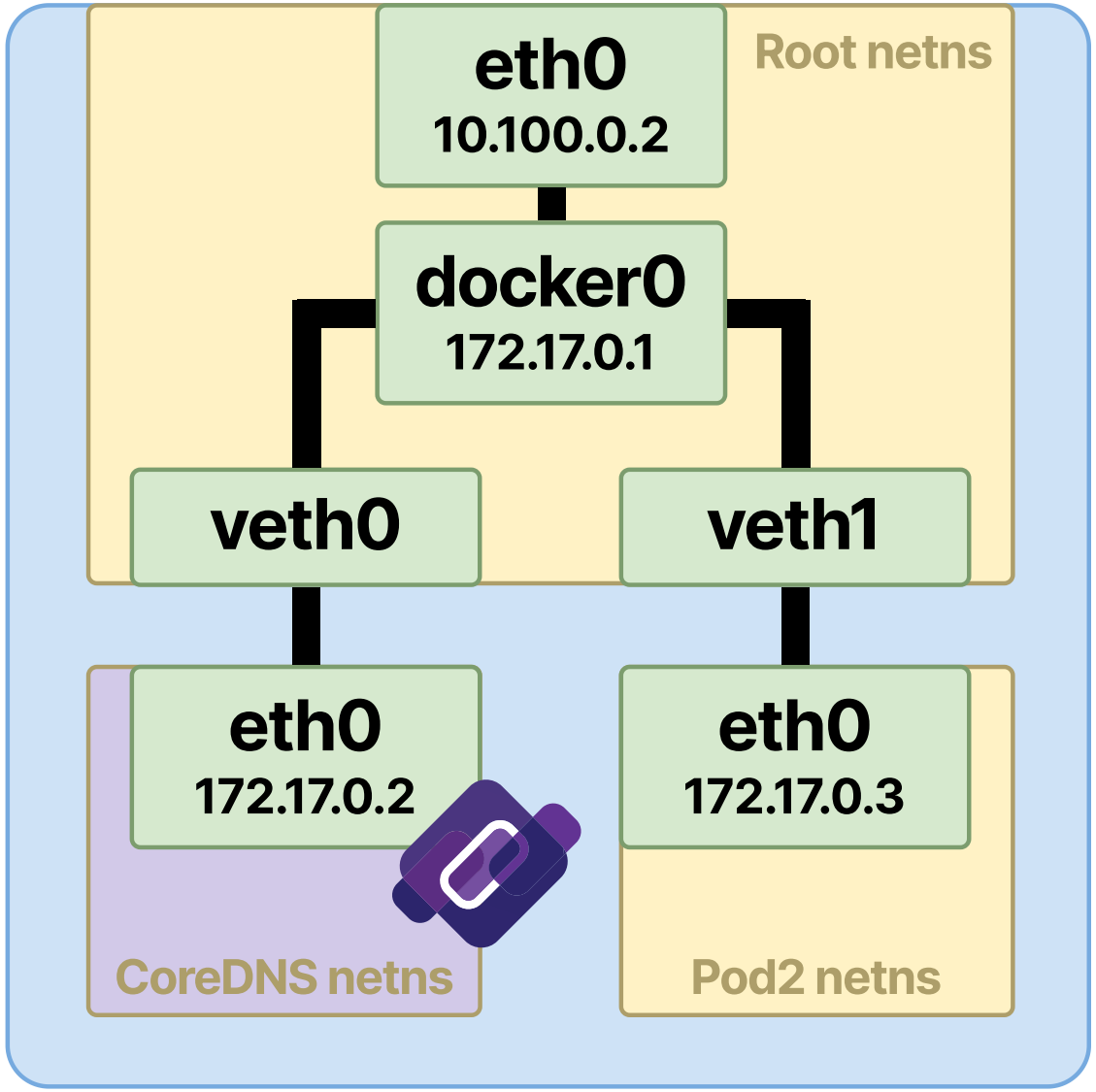
RBAC

Lateral movement

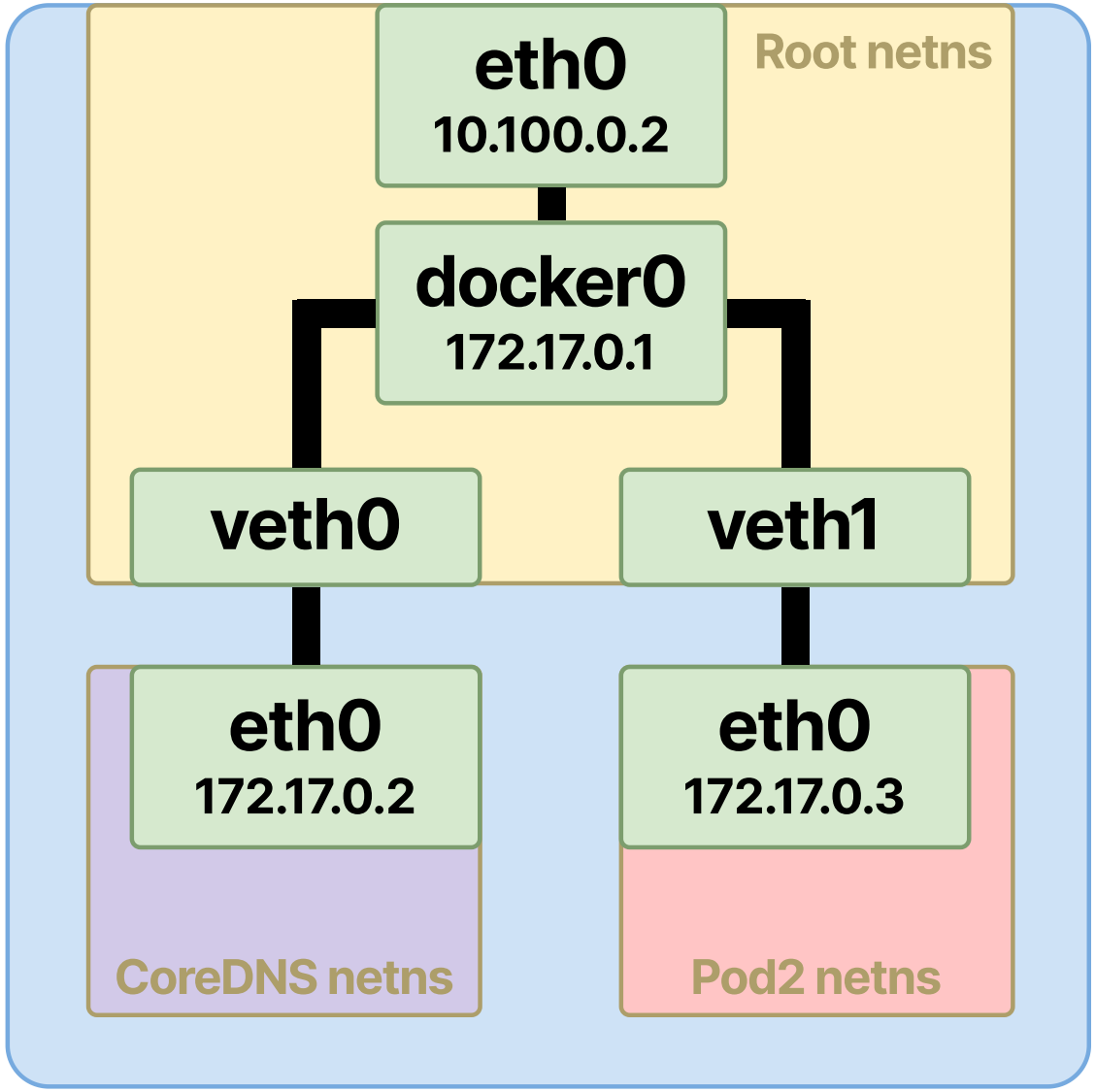
7. ARP poisoning and IP spoofing



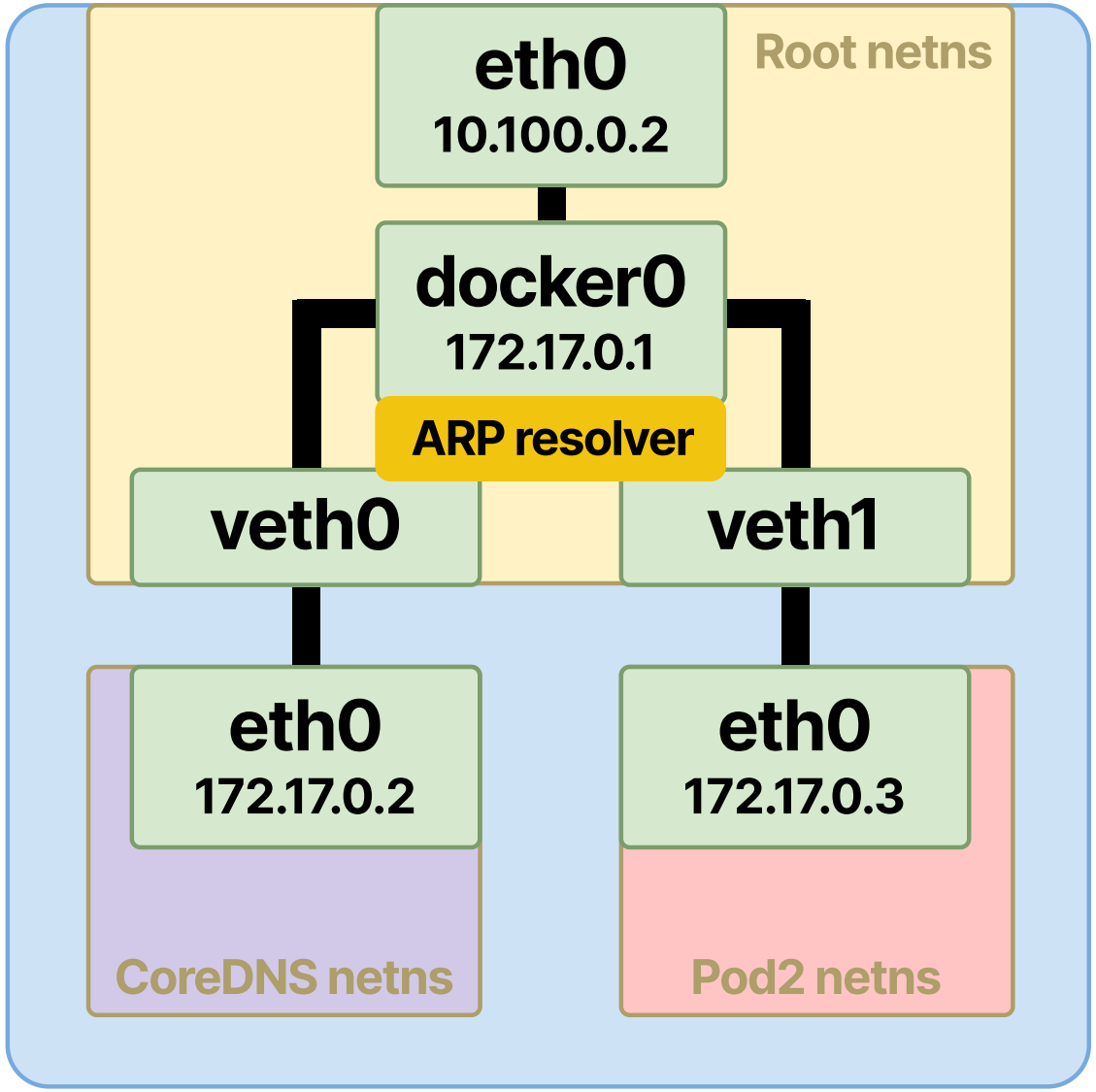
ARP and IP spoofing


eth0
10.100.0.2
Root netns
docker0
172.17.0.1
veth0
veth1
eth0
172.17.0.2
eth0
172.17.0.3
CoreDNS netns
Pod2 netns

Node


eth0
10.100.0.2
Root netns
docker0
172.17.0.1
veth0
veth1
eth0
172.17.0.2
eth0
172.17.0.3
CoreDNS netns
Pod2 netns

Node


eth0
10.100.0.2
Root netns
docker0
172.17.0.1
ARP resolver
veth0
veth1
eth0
172.17.0.2
eth0
172.17.0.3
CoreDNS netns
Pod2 netns

Node

7. ARP poisoning and IP spoofing

aquasecurity/kube-hunter

Different CNI

Drop NET_RAW

172.17.0.1

Node / Master

6 vulnerabilities

SEVERITY	CATEGORY	VULNERABILITY	DESCRIPTION	EVIDENCE
High	Remote Code Execution	Dashboard Exposed	All oprations on the cluster are exposed	nodes: minikube
High	Remote Code Execution	Anonymous Authentication	The kubelet is misconfigured, potentially allowing secure access to all requests on the kubelet, without the need to authenticate	
Medium	Information Disclosure	K8s Version Disclosure	The kubernetes version could be obtained from logs in the /metrics endpoint	v1.10.0
Medium	Information Disclosure	Cluster Health Disclosure	By accessing the open /healthz handler, an attacker could get the cluster health state without authenticating	status: ok
Medium	Information Disclosure	Exposed Pods	An attacker could view sensitive information about pods that are bound to a Node using the /pods endpoint	count: 10
Low	Access Risk	Privileged Container	A Privileged container exist on a node. could expose the node/cluster to unwanted root operations	pod: kube-proxy-w8z8b, container: kube-proxy

7. ARP poisoning and IP spoofing

aquasecurity/kube-hunter

Different CNI

Drop NET_RAW

OpenShift SDN CNI
OVN-Kubernetes CNI

No ARP spoofing

7. ARP poisoning and IP spoofing

aquasecurity/kube-hunter

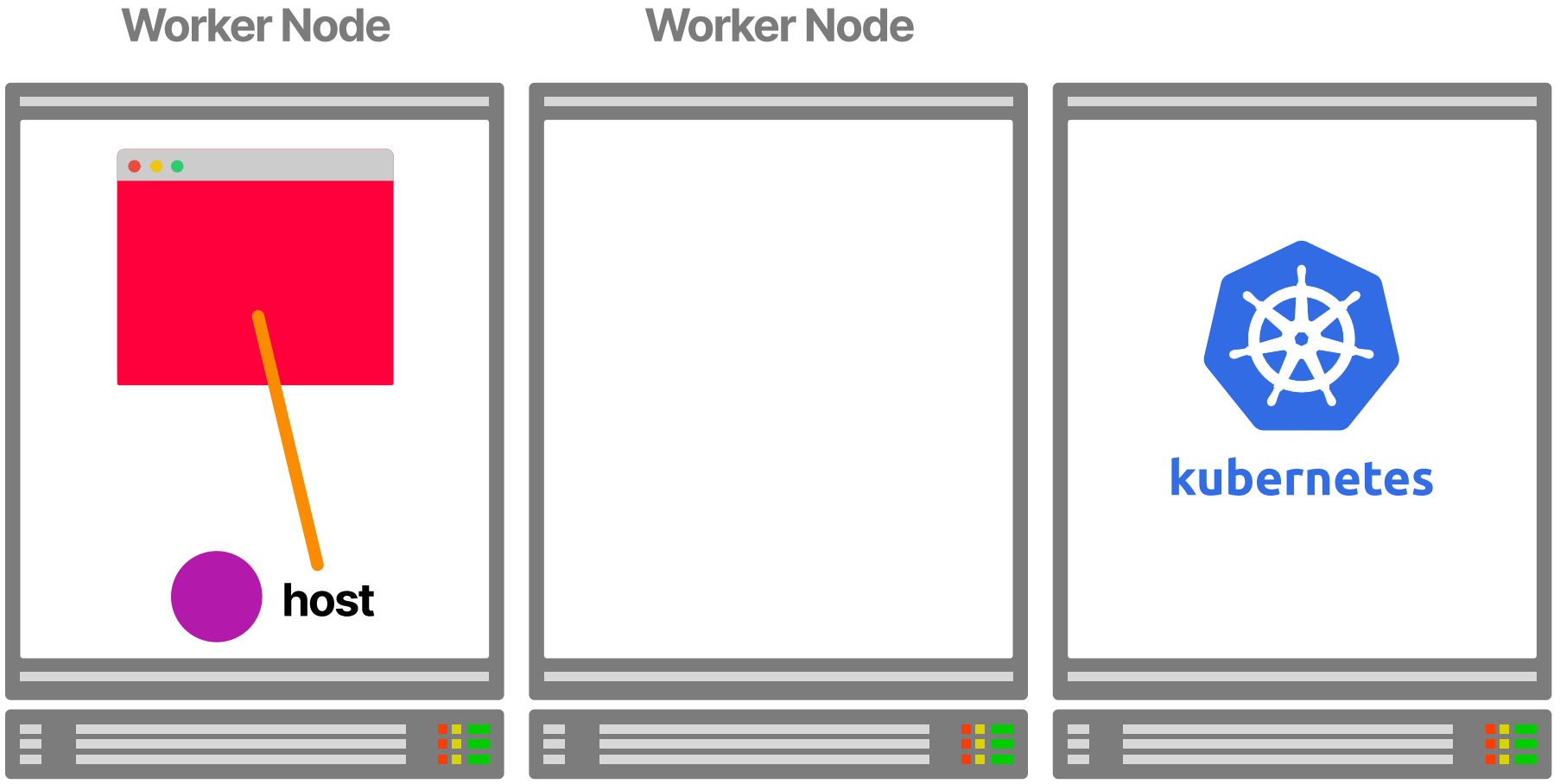
Different CNI

Drop NET_RAW

```
~$ cat pod.yaml
apiVersion: v1
kind: Pod
metadata:
  name: example-pod
  labels:
    app: web
spec:
  containers:
  - name: app
    image: nginx
    securityContext:
      capabilities:
        drop:
        - NET_RAW
```

Lateral movement

8. Container escape


Worker Node
Worker Node
host
kubernetes

8. Container escape

SecurityContext

gVisor

Katacontainers

```
~$ cat pod.yaml
apiVersion: v1
kind: Pod
metadata:
  name: security-context-pod
spec:
  securityContext:
    runAsUser: 2500
    fsGroup: 2000
  volumes:
  - name: security-context-vol
    emptyDir: {}
  containers:
  - name: security-context-cont
    image: supergiantkir/k8s-liveliness
    volumeMounts:
    - name: security-context-vol
      mountPath: /data/test
    securityContext:
      allowPrivilegeEscalation: false
```

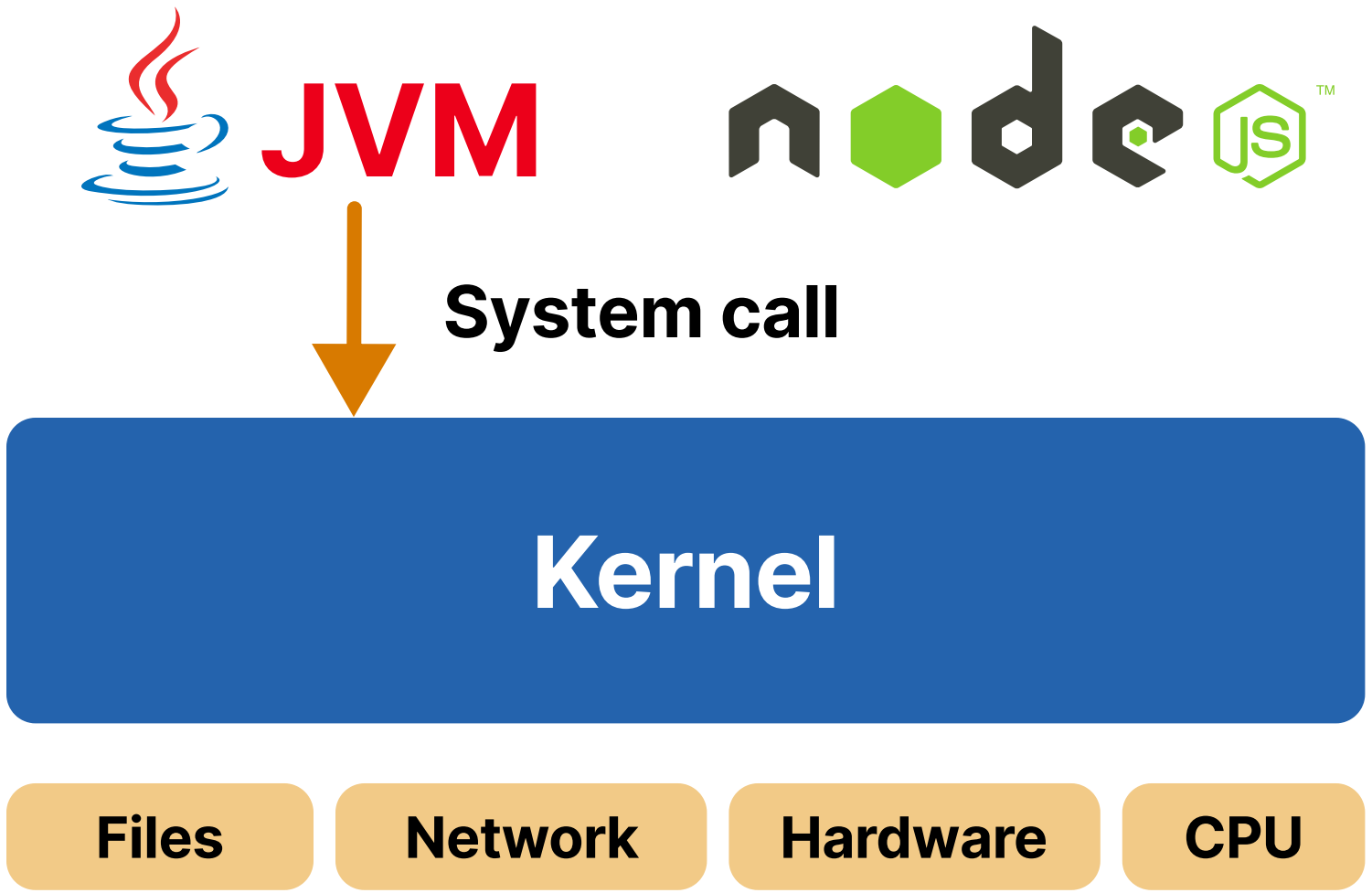
```
~$ cat pod.yaml
apiVersion: v1
kind: Pod
metadata:
  name: linux-cpb-demo
spec:
  securityContext:
    runAsUser: 3000
  containers:
  - name: linux-cpb-cont
    image: supergiantkir/k8s-liveliness
    securityContext:
      capabilities:
        add: ["NET_ADMIN"]
```

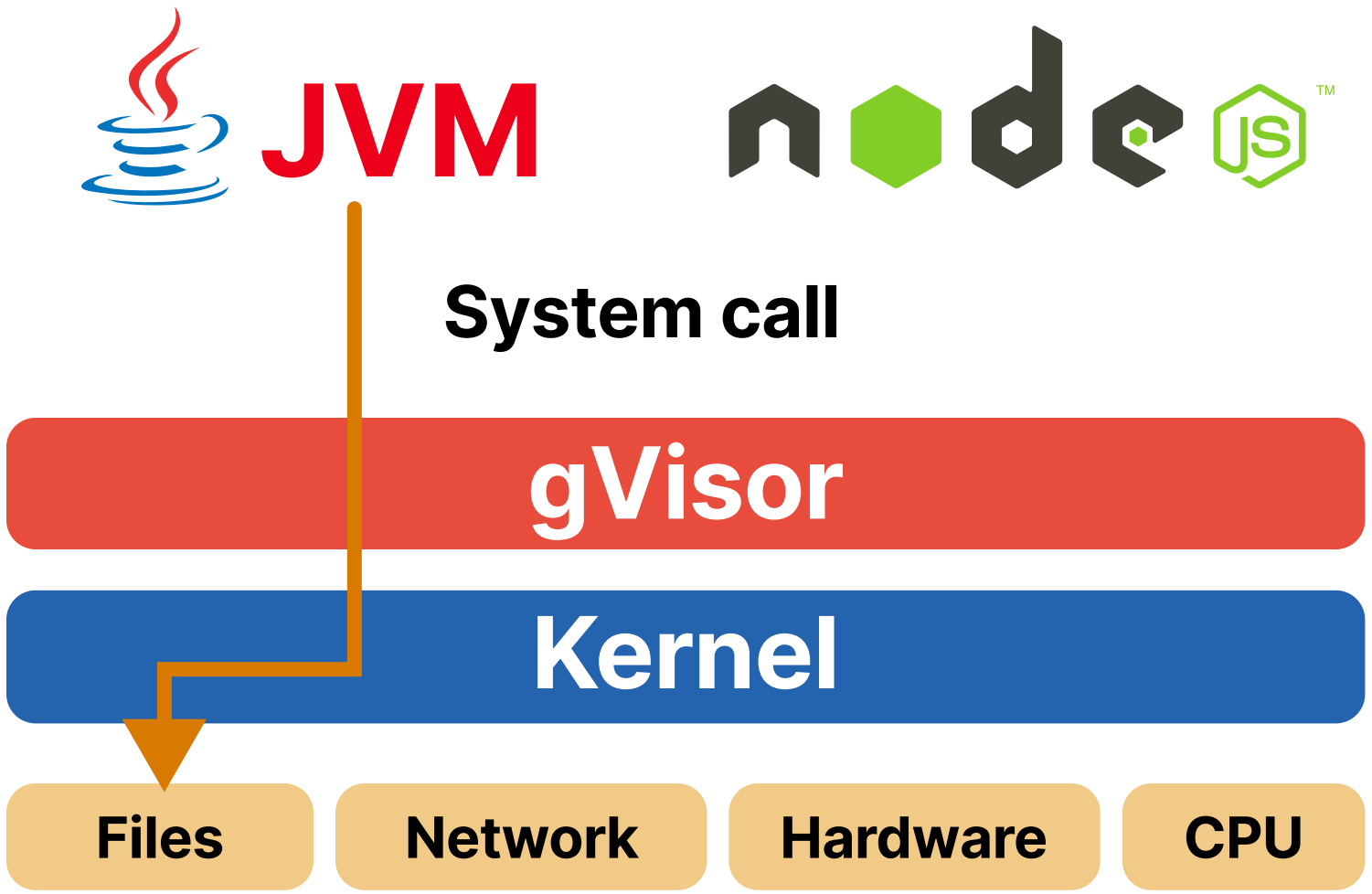
8. Container escape

SecurityContext

gVisor

Katacontainers


JVM
node
JS
System call
Kernel
Files
Network
Hardware
CPU

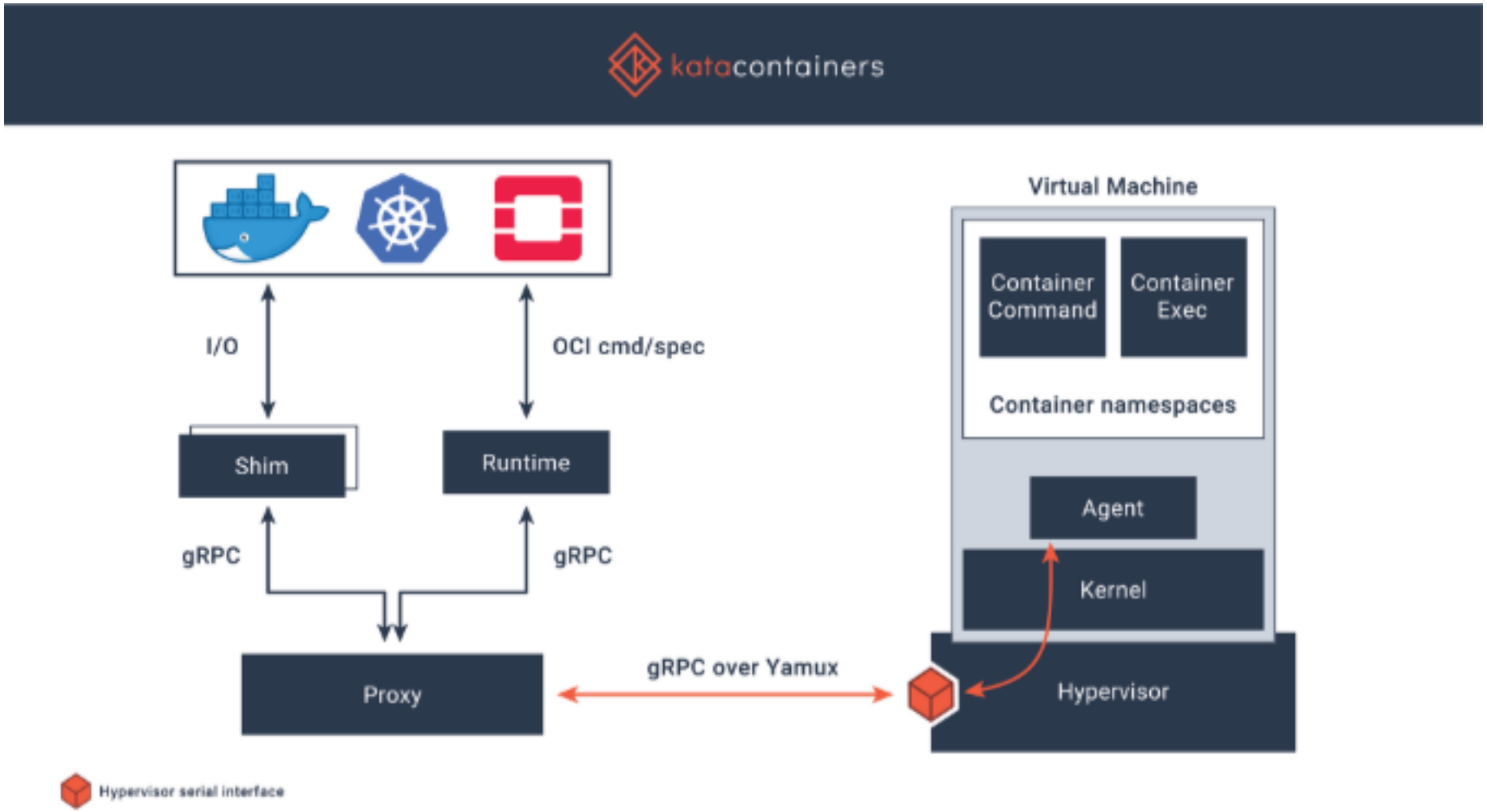

JVM
node
JS
System call
gVisor
Kernel
Files
Network
Hardware
CPU

8. Container escape

SecurityContext

gVisor

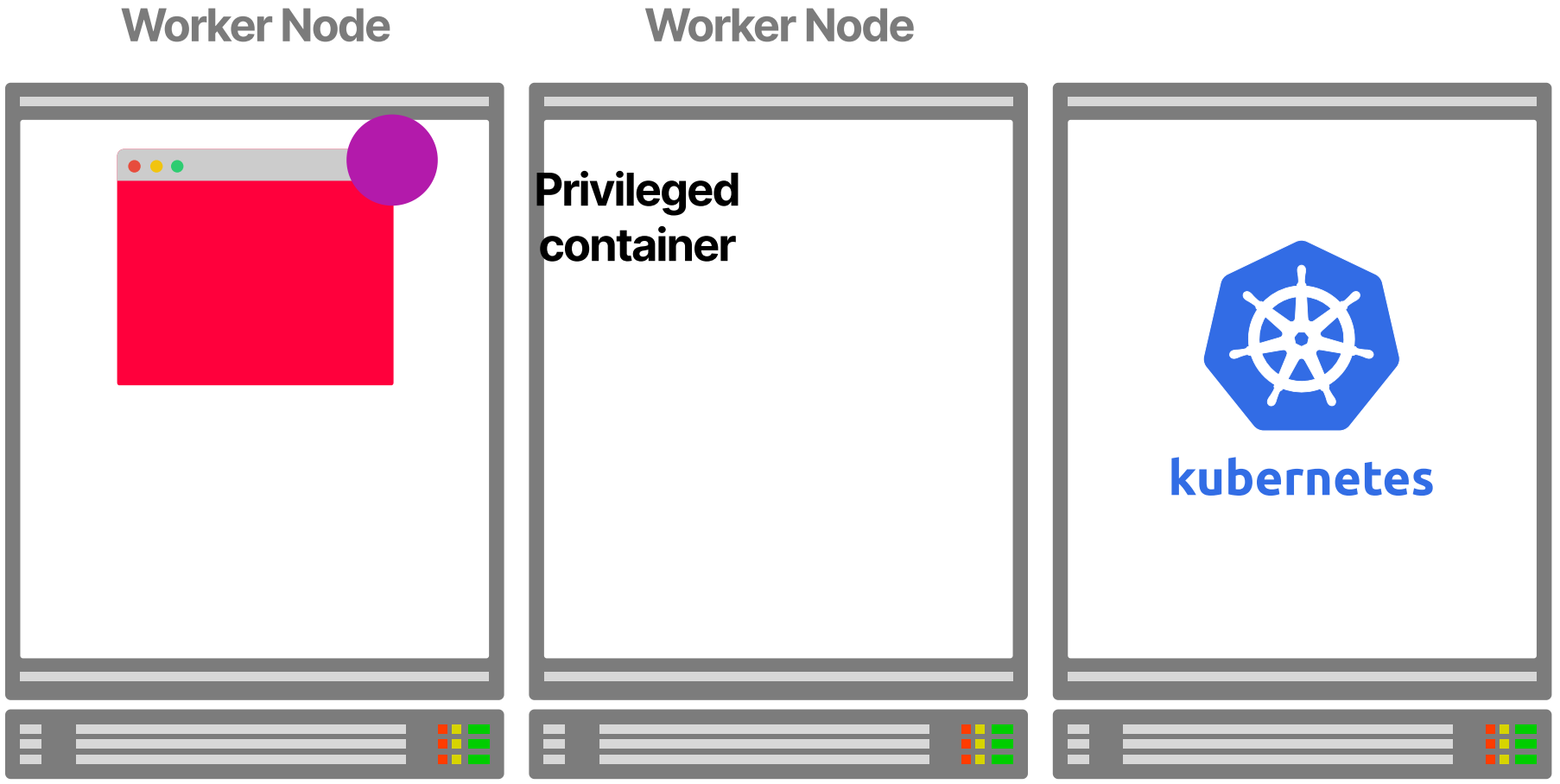
Katacontainers

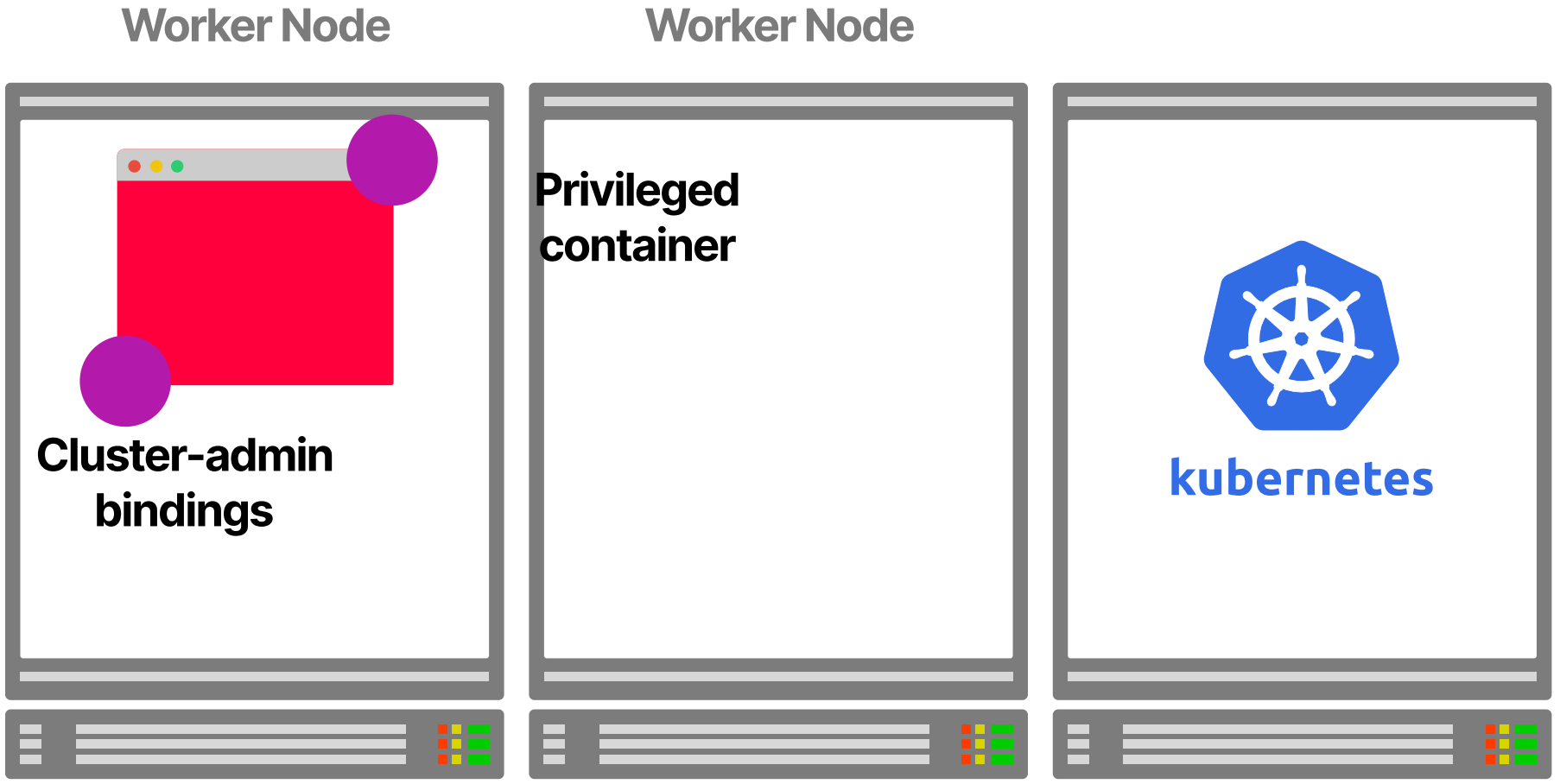

katacontainers
I/O
OCI cmd/spec
Shim
Runtime
gRPC
gRPC
Proxy
gRPC over Yamux
Virtual Machine
Container Command
Container Exec
Container namespaces
Agent
Kernel
Hypervisor
Hypervisor serial interface

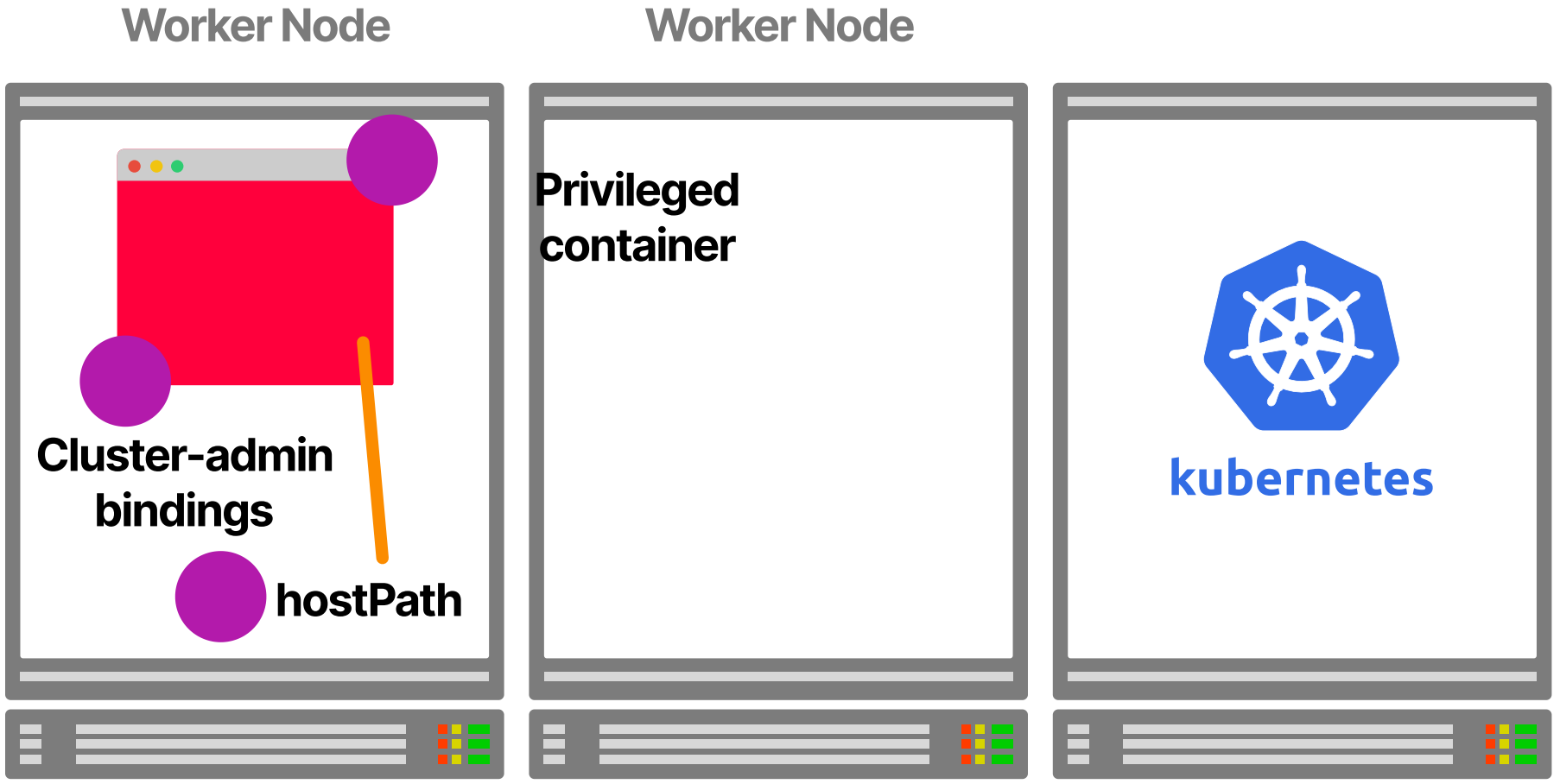
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container					Access the Kubernetes API server	Access cloud resources
Compromised images in registry	bash/cmd inside container					Access Kubelet API	Pod service account
Kubeconfig file	New container					Network mapping	Cluster internal networking
Application vulnerability						Access Kubernetes dashboard	Application credentials
Exposed sensitive interfaces						Instance metadata API	Writable volume mounts on the host
Control plane + kubelet misconfiguration							CoreDNS poisoning
							ARP poisoning and IP spoofing
							Container escape

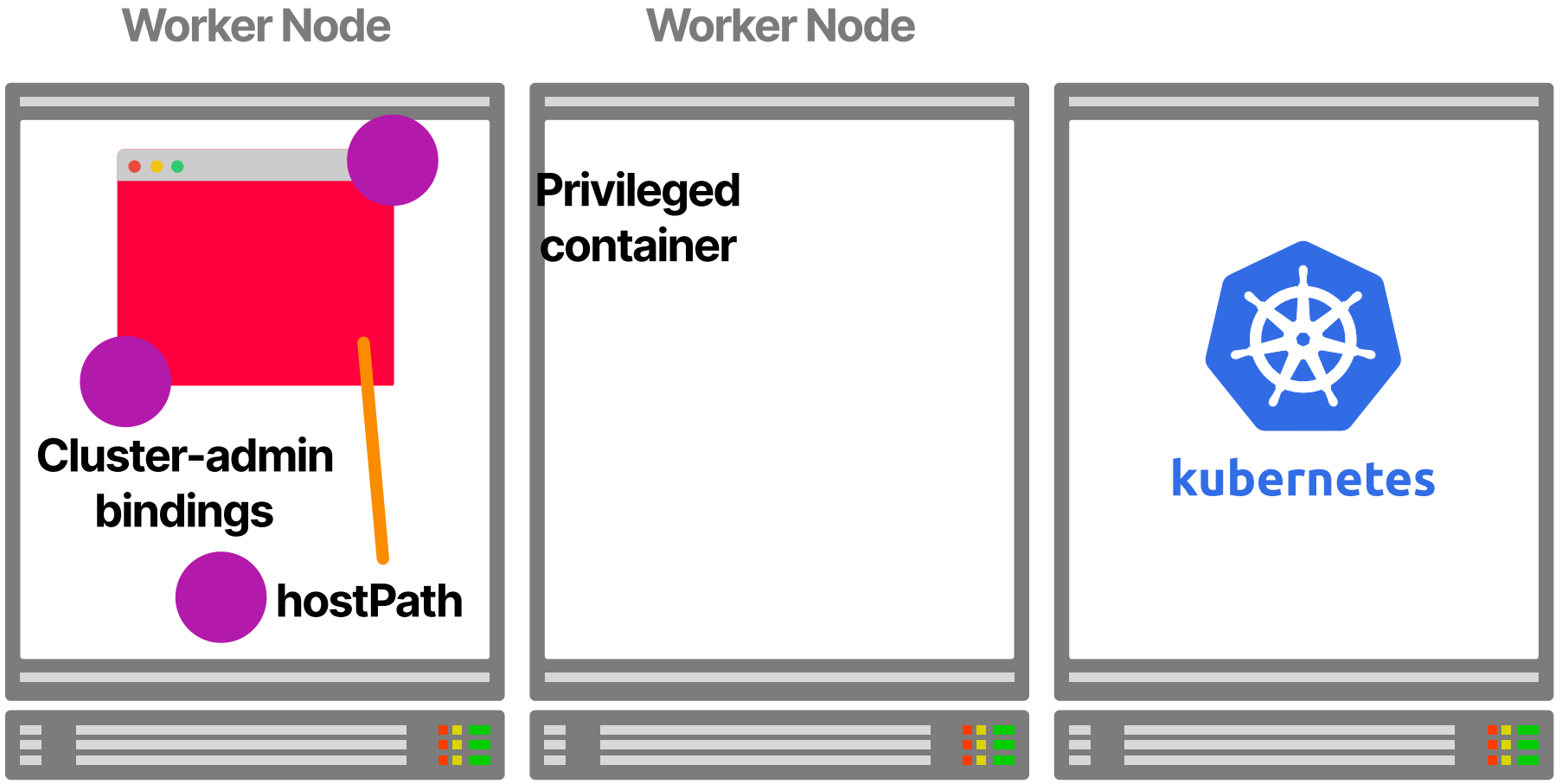
Privilege escalation

05


Worker Node
Worker Node
Privileged
container
kubernetes


Worker Node
Worker Node
Cluster-admin bindings
Privileged container
kubernetes


Worker Node
Worker Node
Cluster-admin
bindings
hostPath
Privileged
container
kubernetes

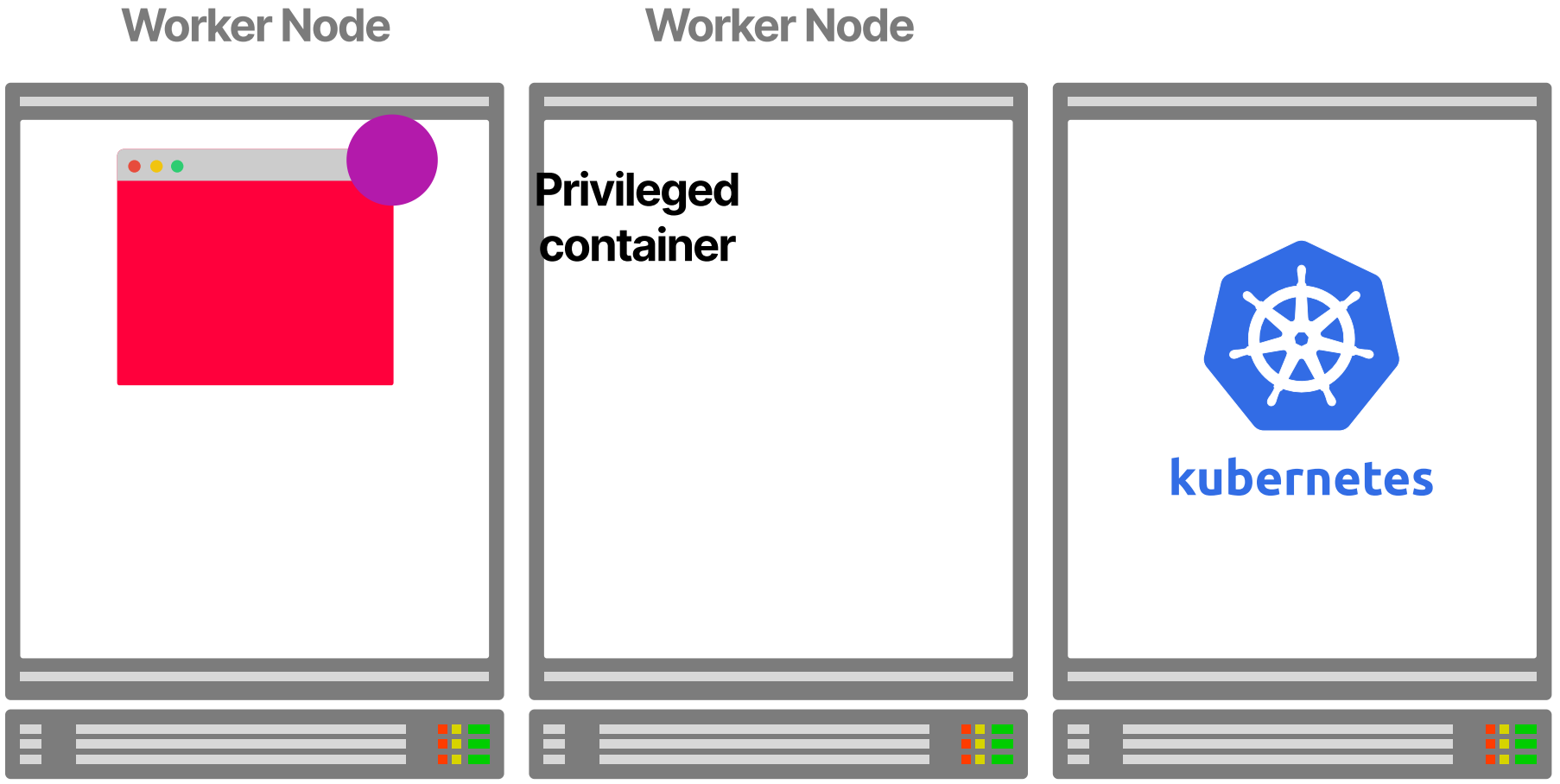


Microsoft Azure Google Cloud amazon web services

Access cloud resources

Privilege escalation

1. Privileged container


Worker Node
Worker Node
Privileged
container
kubernetes

1. Privileged container

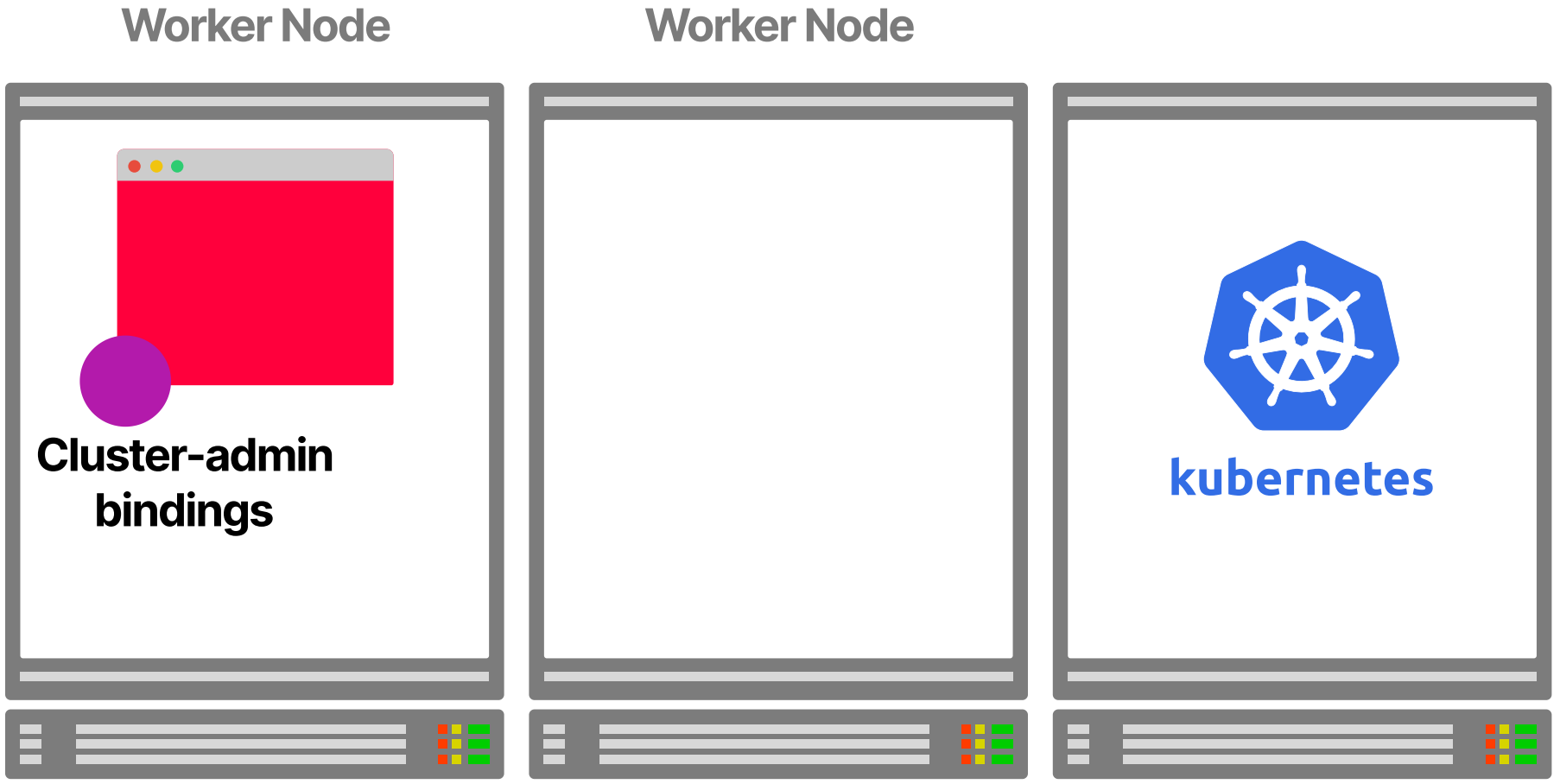




polaris

Privilege escalation

2. Cluster-admin bindings

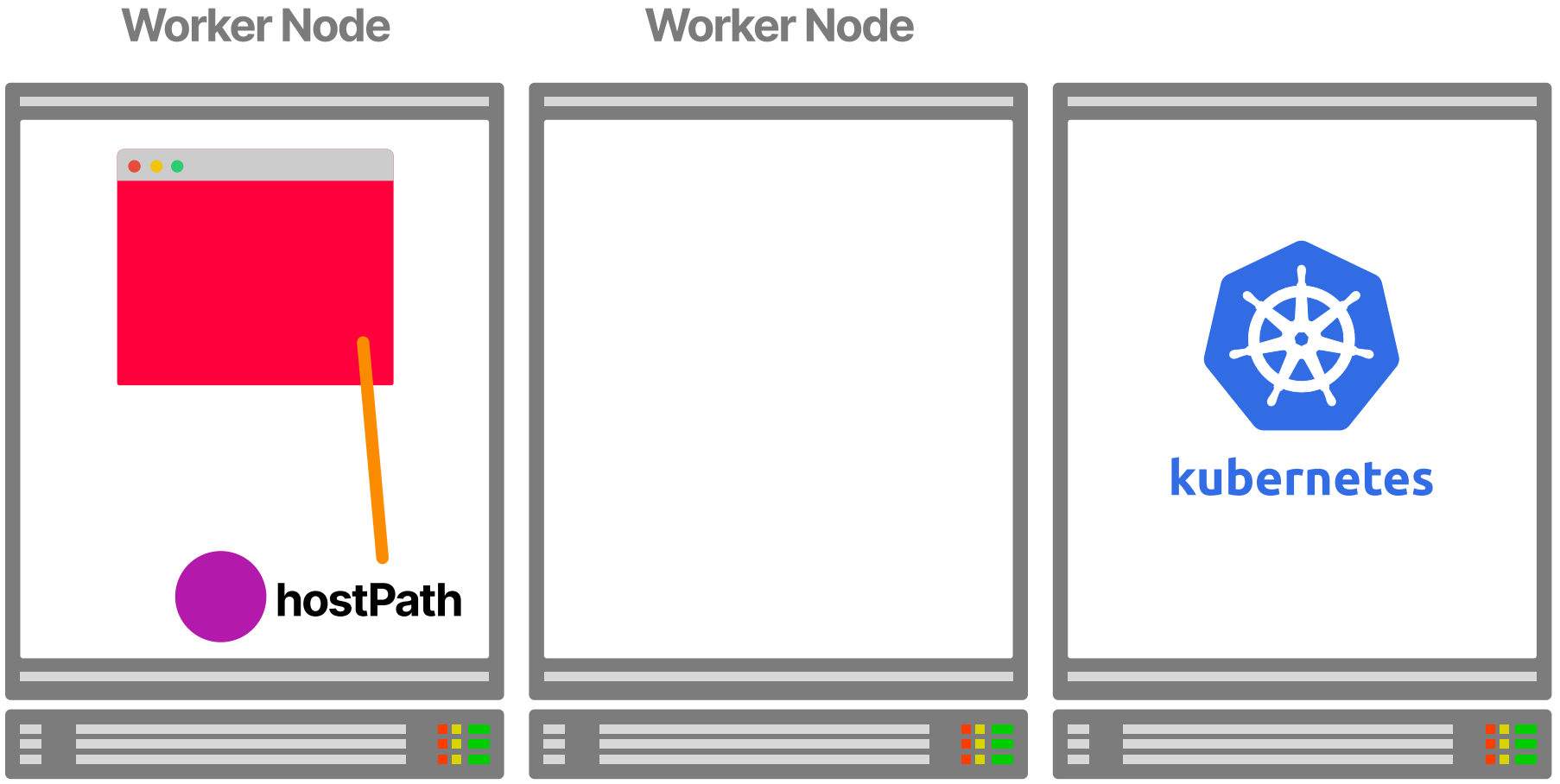

Worker Node
Worker Node
Cluster-admin
bindings
kubernetes

2. Cluster-admin bindings

appvia/krane
alcideio/rbac-tool
cyberark/kubernetes-rbac-audit

Privilege escalation

3. hostPath mount

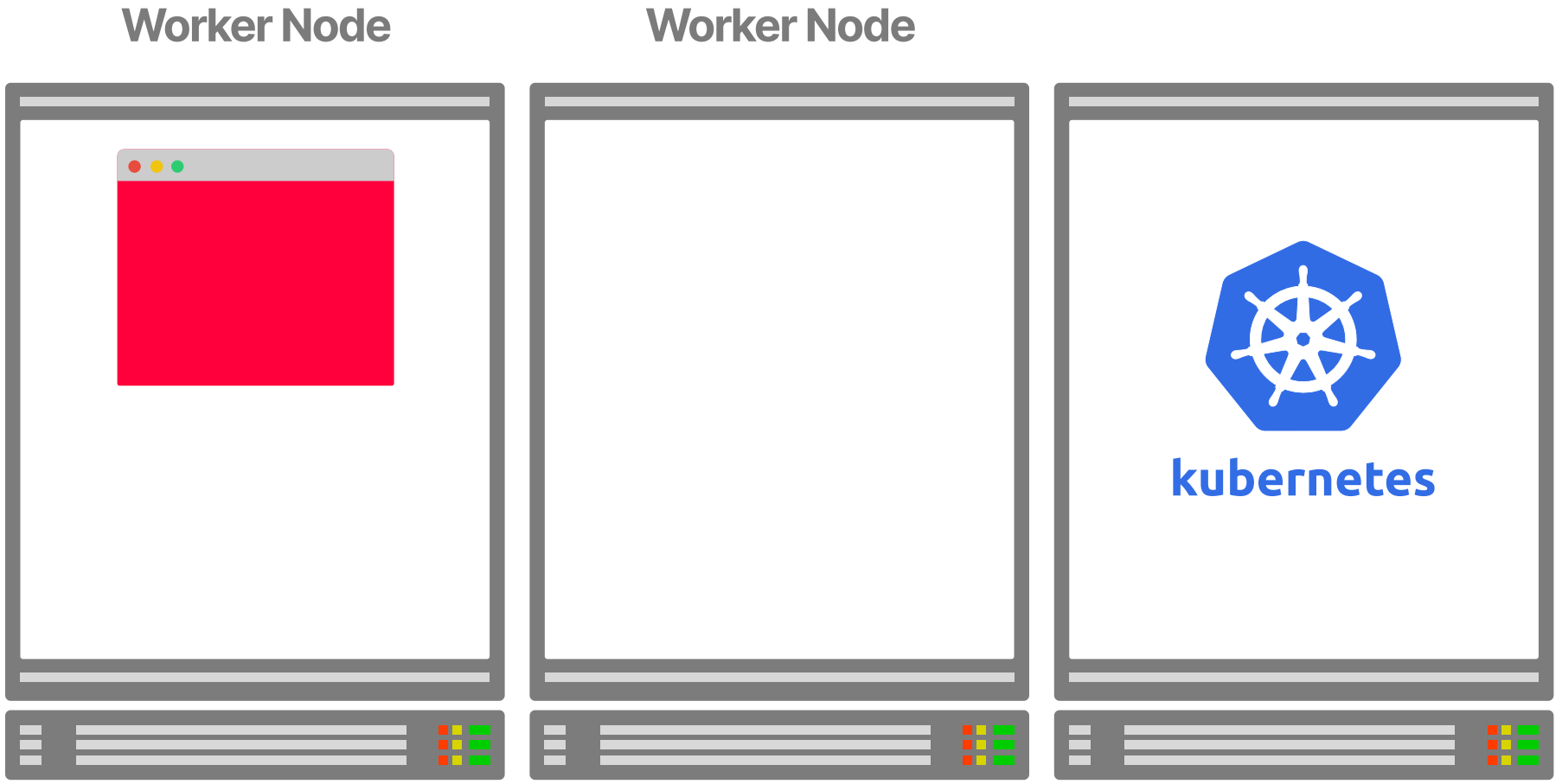

Worker Node
Worker Node
hostPath
kubernetes

3. hostPath mount

OPA, Kyverno, etc.
Restrict priviliged pods SecurityContext

Privilege escalation

4. Access to cloud services





Microsoft Azure Google Cloud amazon web services

Access cloud resources

4. Access cloud resources

IAMs
Granular permissions
Credentials rotation

Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container		Priviliged container			Access the Kubernetes API server	Access cloud resources
Compromised images in registry	bash/cmd inside container		Cluster-admin binding			Access Kubelet API	Pod service account
Kubeconfig file	New container		hostPath mount			Network mapping	Cluster internal networking
Application vulnerability			Access to cloud resources			Access Kubernetes dashboard	Application credentials
Exposed sensitive interfaces						Instance metadata API	Writable volume mounts on the host
Control plane + kubelet misconfiguration							CoreDNS poisoning
							ARP poisoning and IP spoofing
							Container escape

Credentials access

06

Credentials access

1. Kubernetes secrets
2. Kubernetes IAMs
3. Pod service account
4. Application credentials

Credentials access

1. Kubernetes secrets

2. Kubernetes IAMs

3. Pod service account

4. Application credentials

Credentials access

1. Kubernetes secrets

2. Kubernetes IAMs

3. Pod service account

4. Application credentials

Credentials access

1. Kubernetes secrets

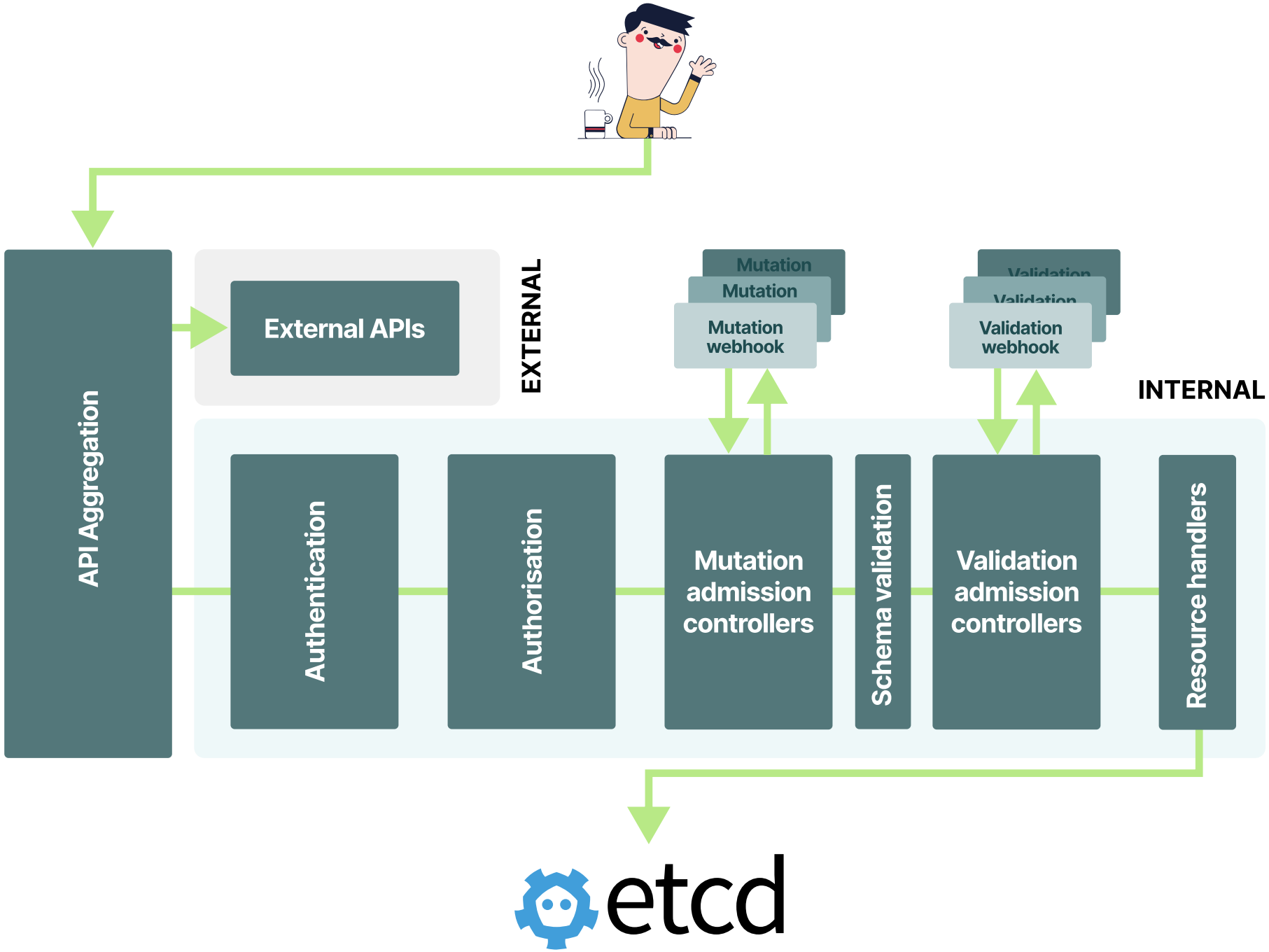
2. Kubernetes IAMs

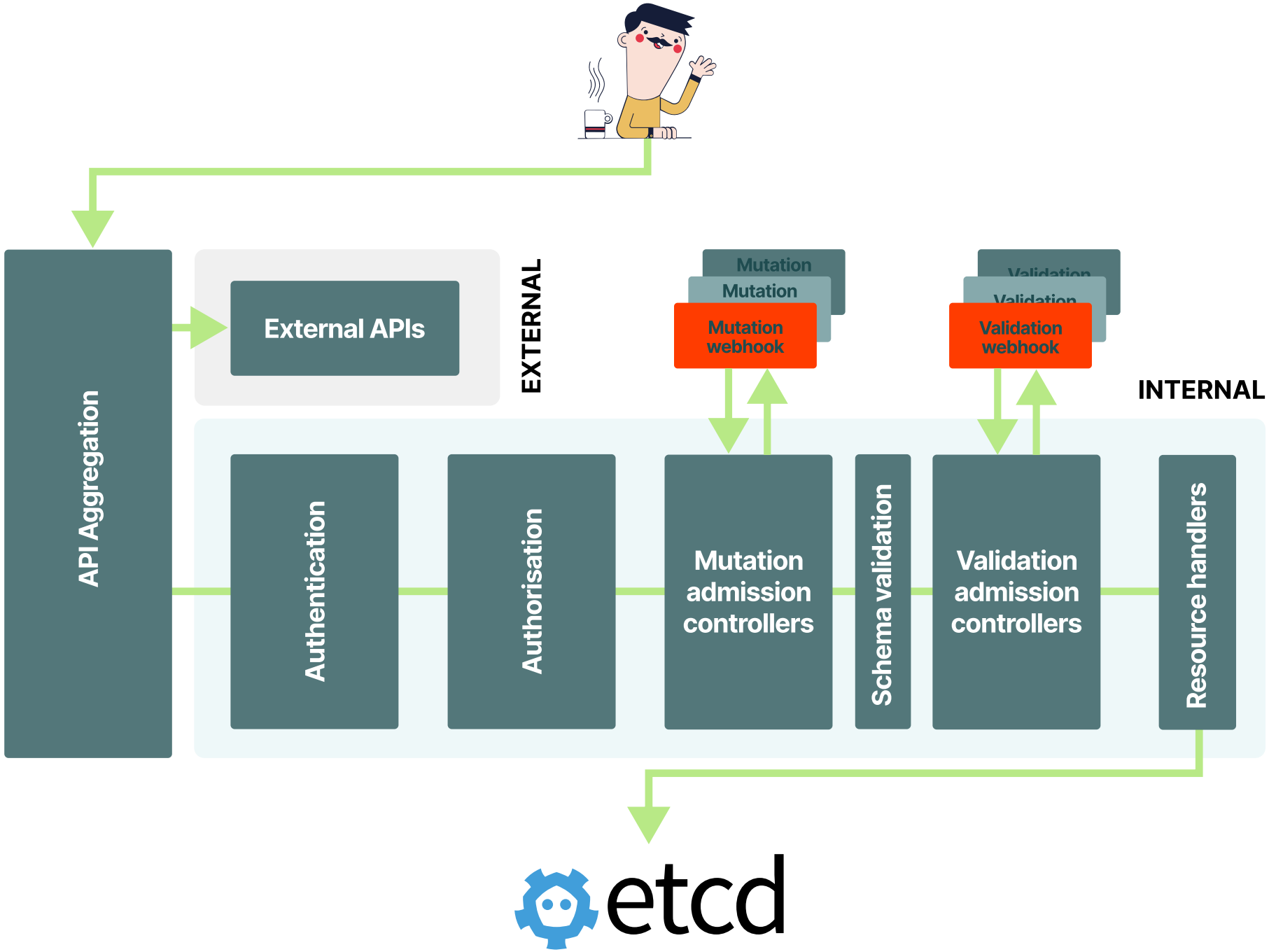
3. Pod service account

4. Application credentials

Credentials access

5. Admission controllers


API Aggregation
External APIs
EXTERNAL
Mutation
Mutation
Mutation webhook
Validation
Validation
Validation webhook
INTERNAL
Authentication
Authorisation
Mutation admission controllers
Schema validation
Validation admission controllers
Resource handlers
etcd


API Aggregation
External APIs
EXTERNAL
Mutation
Mutation
Mutation webhook
Validation
Validation
Validation webhook
INTERNAL
Authentication
Authorisation
Mutation admission controllers
Schema validation
Validation admission controllers
Resource handlers
etcd

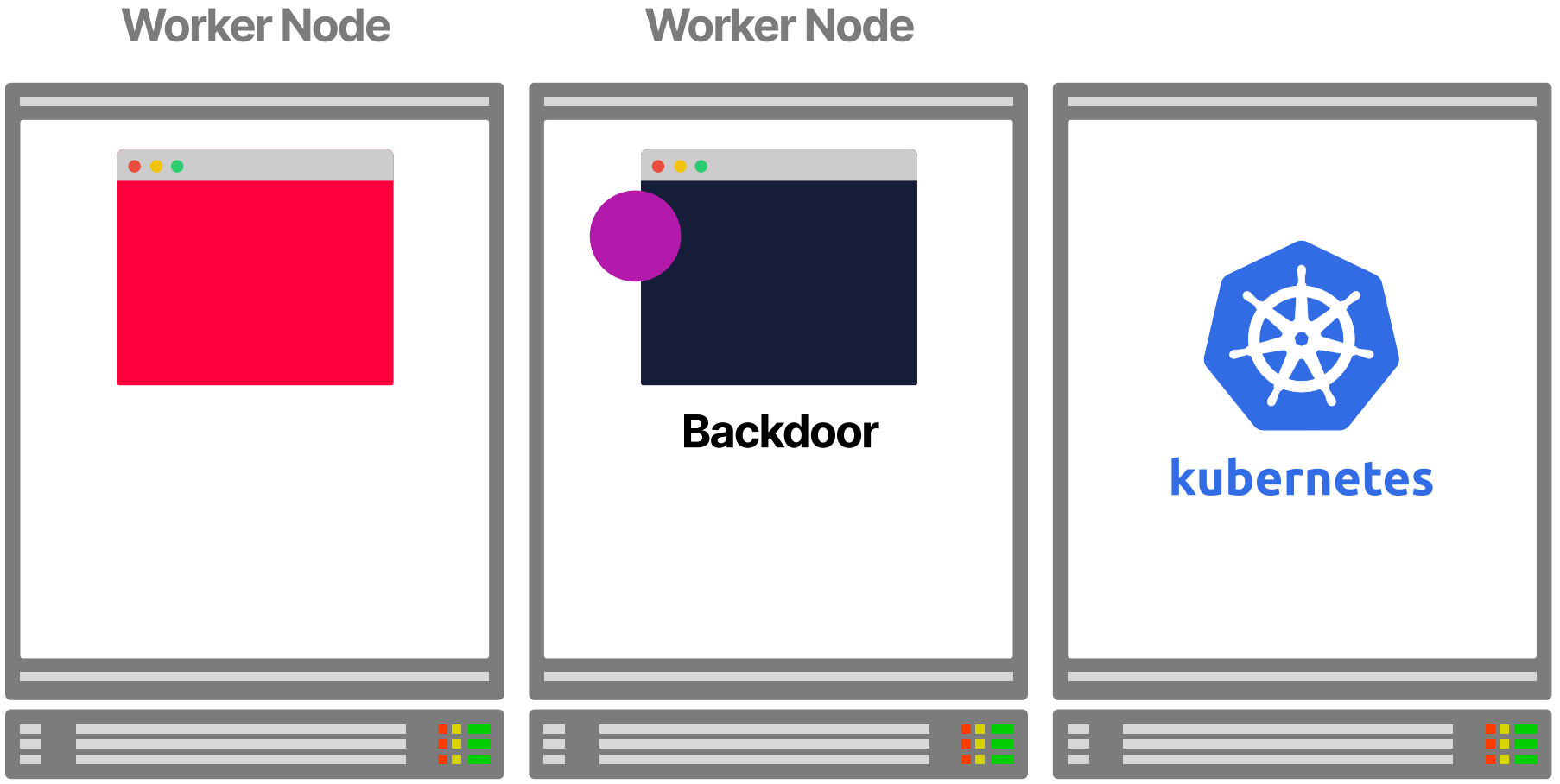
5. Admission controllers

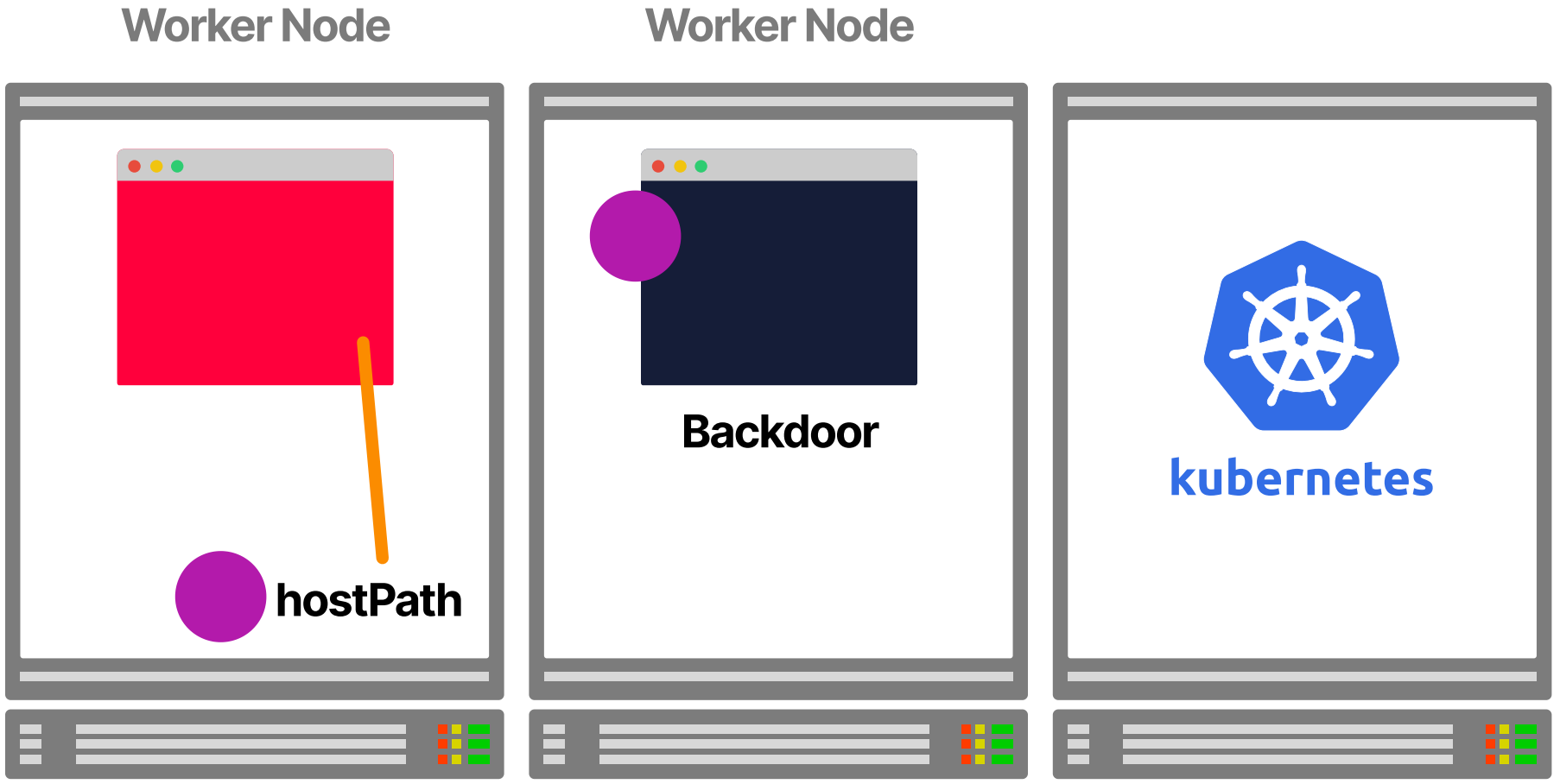
RBAC

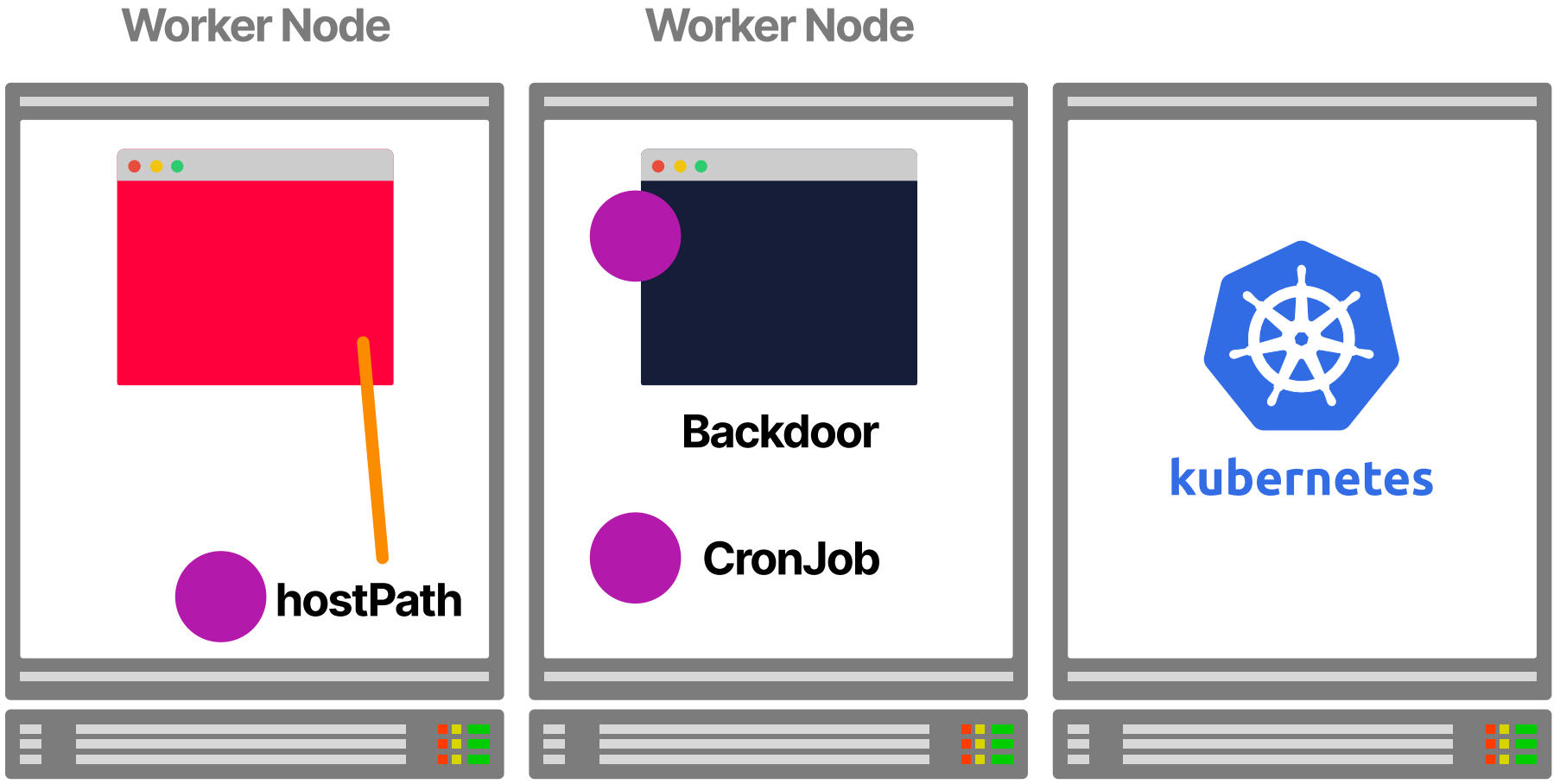
Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container		Priviliged container		Kubernetes secrets	Access the Kubernetes API server	Access cloud resources
Compromised images in registry	bash/cmd inside container		Cluster-admin binding		Kubernetes IAMs	Access Kubelet API	Pod service account
Kubeconfig file	New container		hostPath mount		Pod service account	Network mapping	Cluster internal networking
Application vulnerability			Access to cloud resources		Applications credentials	Access Kubernetes dashboard	Application credentials
Exposed sensitive interfaces					Access managed identities credentials	Instance metadata API	Writable volume mounts on the host
Control plane + kubelet misconfiguration					Malicious admission controller		CoreDNS poisoning
							ARP poisoning and IP spoofing
							Container escape

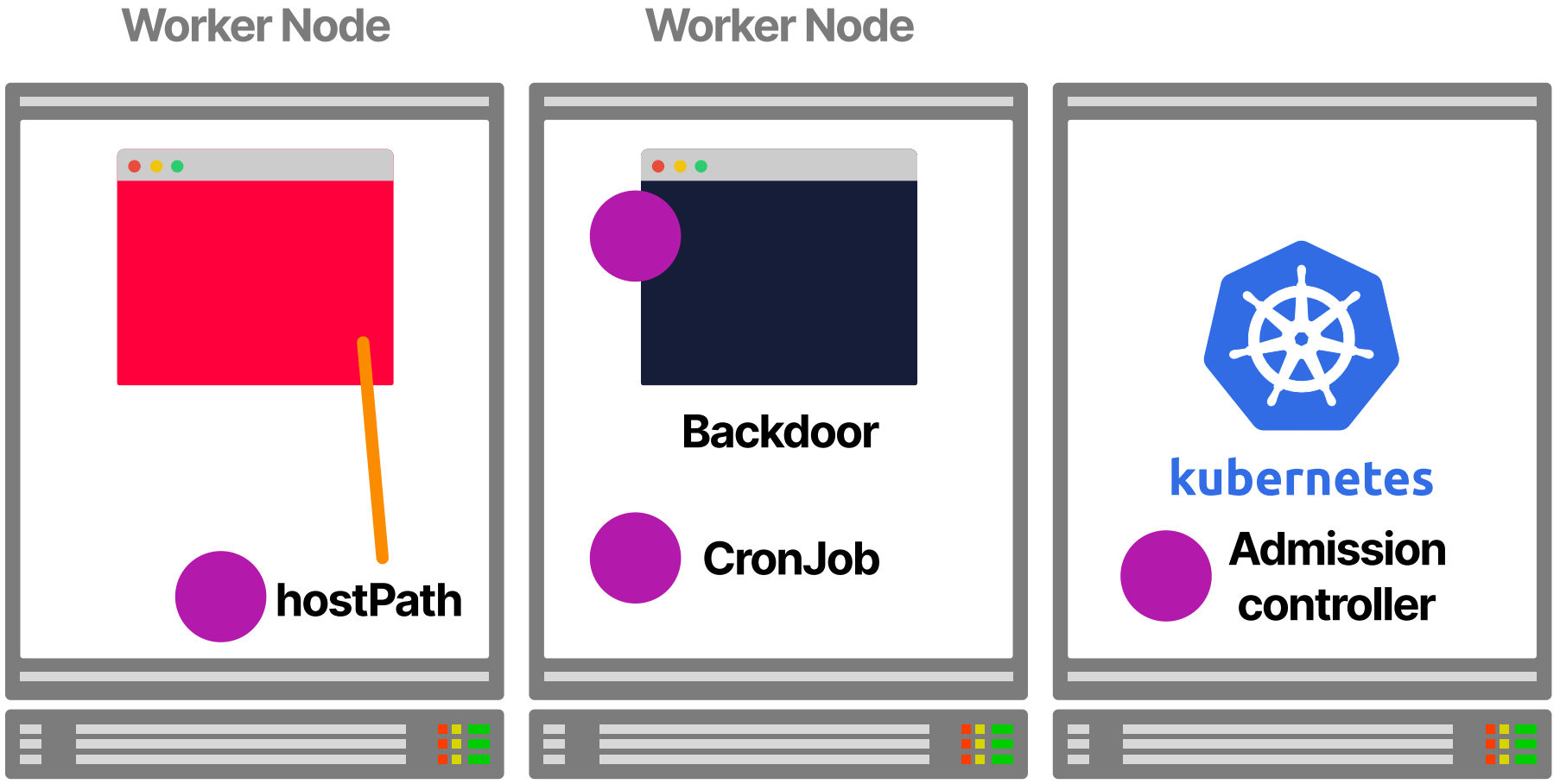
Persistence

07


Worker Node
Worker Node
Backdoor
kubernetes

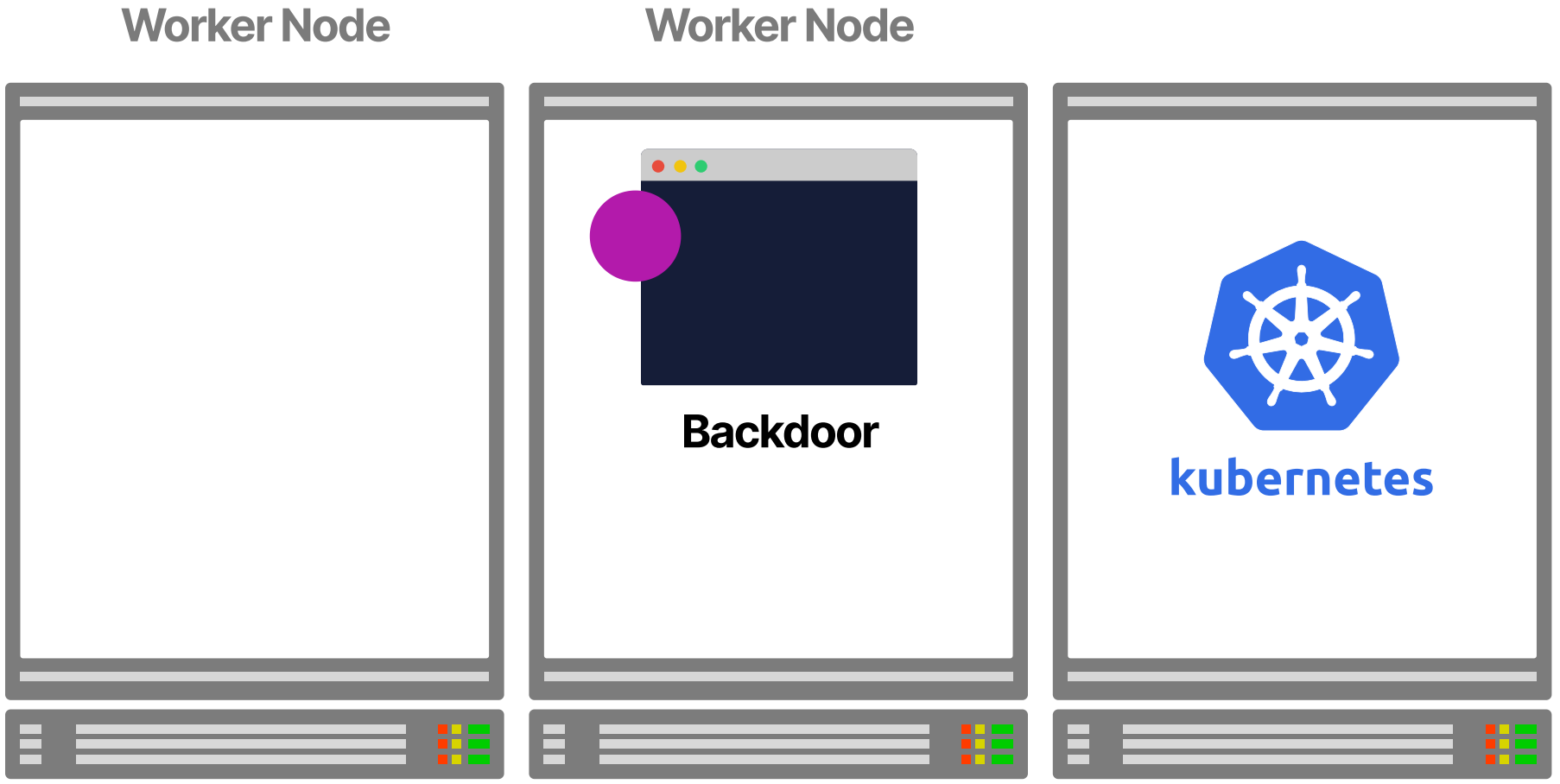

Worker Node
Worker Node
hostPath
Backdoor
kubernetes


Worker Node
Worker Node
hostPath
Backdoor
CronJob
kubernetes


Worker Node
Worker Node
hostPath
Backdoor
CronJob
kubernetes
Admission
controller

Persistence

1. Backdoor container


Worker Node
Worker Node
Backdoor
kubernetes

1. Backdoor container

RBAC

NetworkPolicies

jetstack/version-checker

1. Backdoor container

RBAC

NetworkPolicies

jetstack/version-checker

1. Backdoor container

RBAC

NetworkPolicies

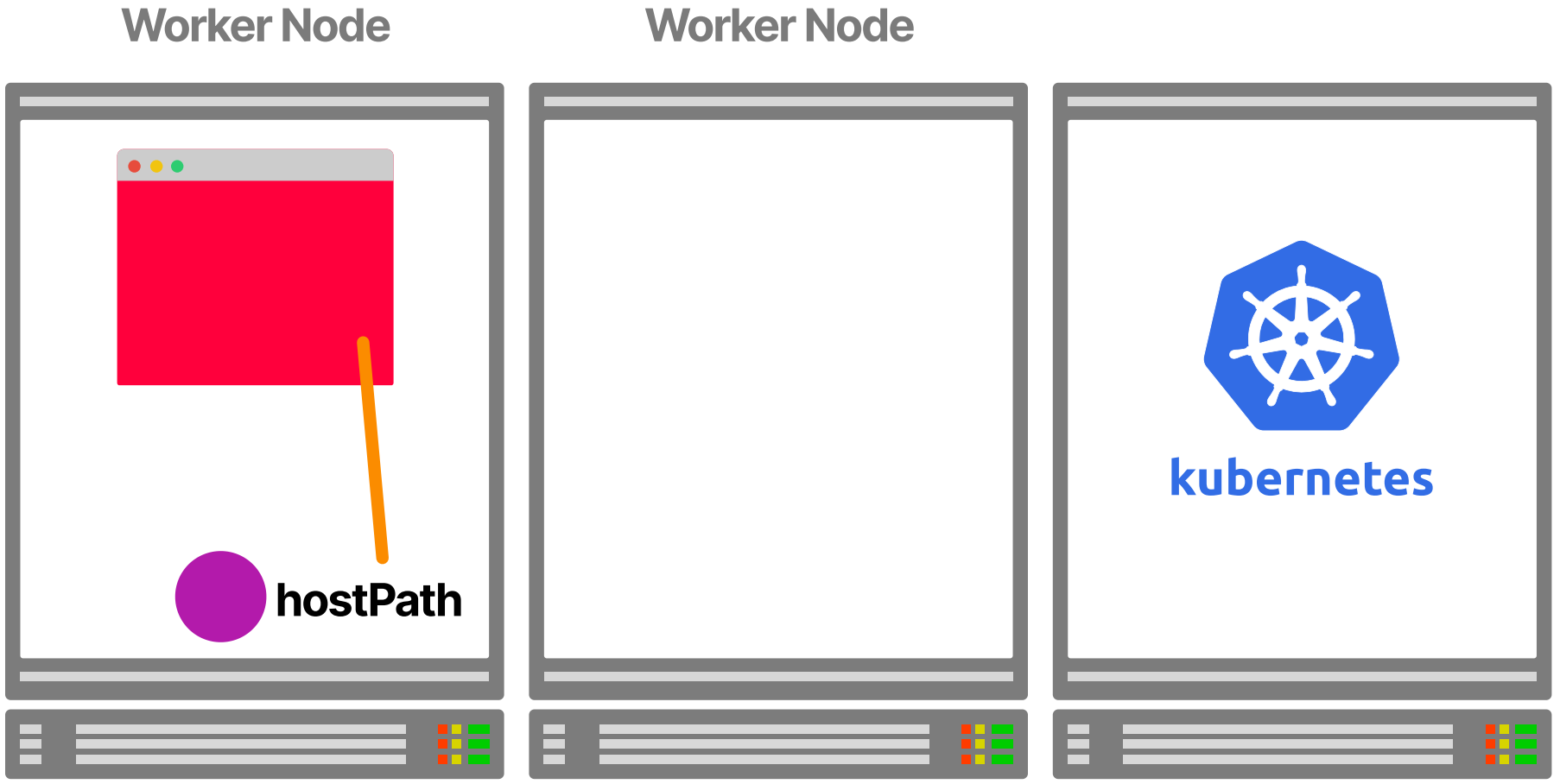
jetstack/version-checker

Cluster Image Version Checks

Image	Current Version	Latest Version	Is Latest
docker.io/cilium/operator	v1.7.4	v1.8.2	No
docker.io/jimmidyson/configmap-reload	v0.3.0	v0.4.0	No
gcr.io/jetstack-cre/version-checker	v0.0.1-alpha.0	v0.0.1-alpha.0	Yes
gcr.io/jetstack-josh/knot-stress	v0.1.0-alpha.1	v0.1.0-alpha.1	Yes
grafana/grafana	7.0.3	7.1.3	No
grafana/grafana	7.1.1	7.1.3	No
k8s.gcr.io/coredns	1.6.7	1.7.0	No
k8s.gcr.io/etcd	3.4.3-0	3.4.9	No
k8s.gcr.io/kube-apiserver	v1.18.2	v1.18.6	No
k8s.gcr.io/kube-controller-manager	v1.18.2	v1.18.6	No
k8s.gcr.io/kube-proxy	v1.18.2	v1.18.6	No
k8s.gcr.io/kube-scheduler	v1.18.2	v1.18.6	No
kindest/kindnetd	0.5.4	0.6.0	No
kiwigrid/k8s-sidecar	0.1.151	0.1.178	No
quay.io/coreos/kube-state-metrics	v1.9.7	v1.9.7	Yes
quay.io/coreos/prometheus-config-reloader	v0.38.1	v0.41.1	No
quay.io/coreos/prometheus-operator	v0.38.1	v0.41.1	No
quay.io/jetstack/kube-oidc-proxy	v0.3.0	v0.3.0	Yes
quay.io/prometheus/alertmanager	v0.21.0	v0.21.0	Yes
quay.io/prometheus/node-exporter	v1.0.0	v1.0.1	No
quay.io/prometheus/prometheus	v2.18.2	v2.20.1	No
quay.io/prometheus/prometheus	v2.20.1	v2.20.1	Yes
rancher/local-path-provisioner	v0.0.12	v0.0.17	No
squareup/ghostunnel	v1.5.2	v1.5.2	Yes

Persistence

2. Writable hostPath mount

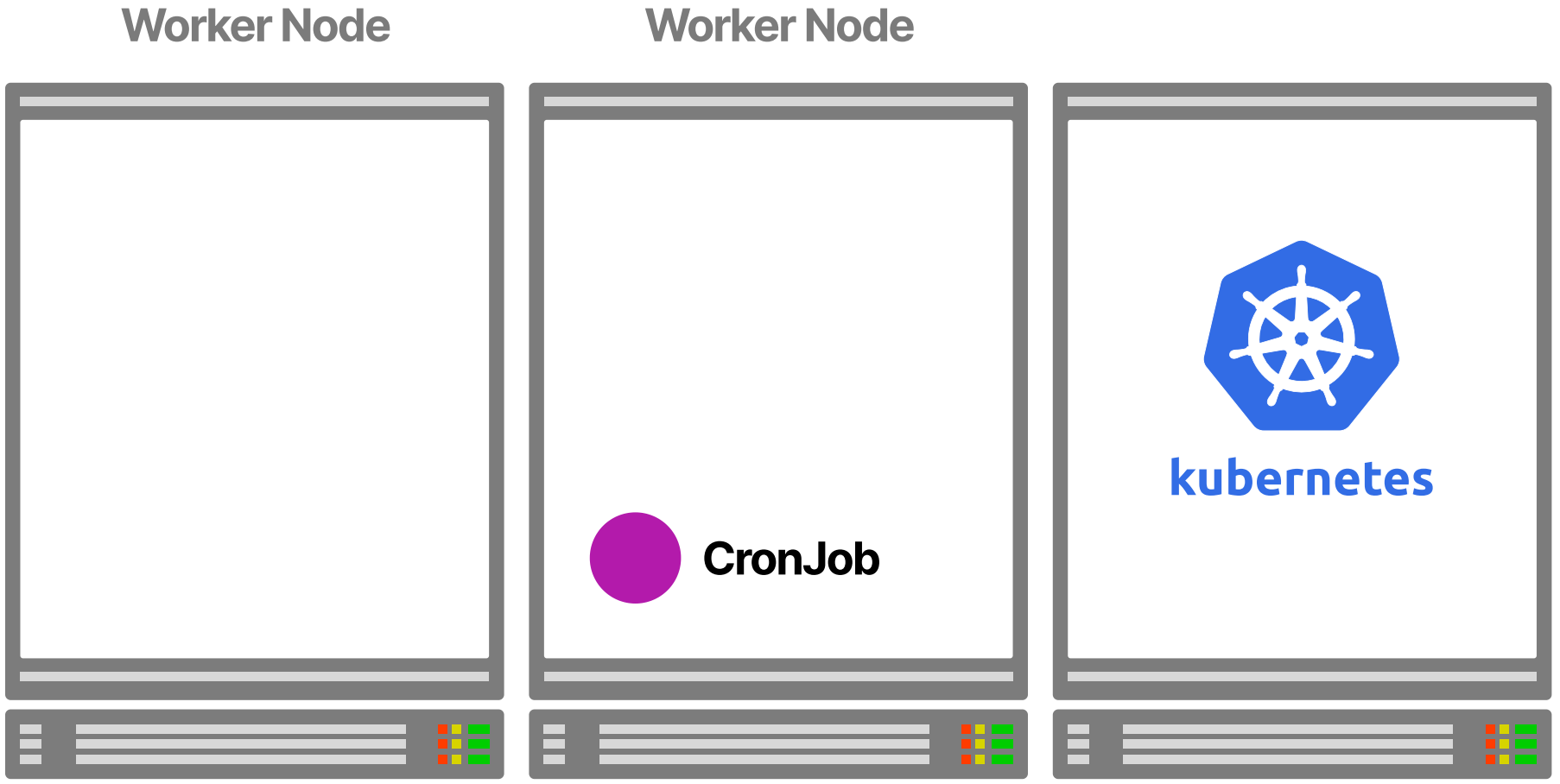

Worker Node
Worker Node
hostPath
kubernetes

2. Writable hostPath mount

OPA, Kyverno, etc.
SecurityContext

Persistence

3. Kubernetes CronJob


Worker Node
Worker Node
CronJob
kubernetes

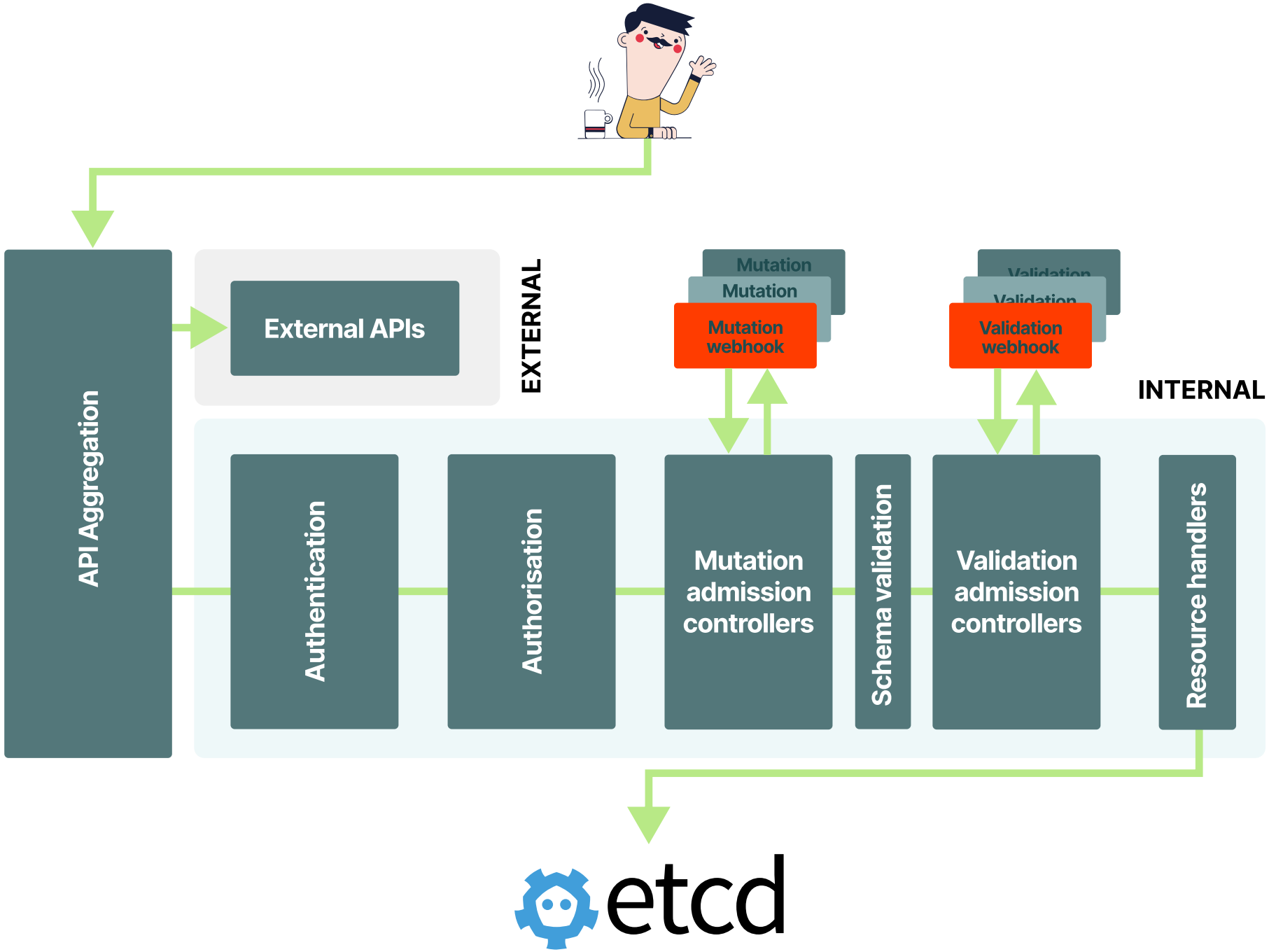
```yaml
apiVersion: batch/v1
kind: CronJob
metadata:
  name: hello
spec:
  schedule: "*/1 * * * *"
  jobTemplate:
    spec:
      template:
        spec:
          containers:
          - name: hello
            image: busybox
            imagePullPolicy: IfNotPresent
            command:
            - /bin/sh
            - -c
            - date; echo Hello from the Kubernetes cluster
          restartPolicy: OnFailure
```

3. Kubernetes CronJob

RBAC
jetstack/version-checker

Persistence

4. Malicious admission controller


API Aggregation
External APIs
EXTERNAL
Mutation
Mutation
Mutation webhook
Validation
Validation
Validation webhook
INTERNAL
Authentication
Authorisation
Mutation admission controllers
Schema validation
Validation admission controllers
Resource handlers
etcd

```
~$ cat pod.yaml
apiVersion: v1
kind: Pod
metadata:
  name: example-pod
  labels:
    app: web
spec:
  containers:
  - name: app
    image: my-private-reg/nginx:v1
  - name: sidecar
    image: istio/sidecar-backdoor
```

4. Admission controller

RBAC

jetstack/version-checker

Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container	Backdoor container	Priviliged container		Kubernetes secrets	Access the Kubernetes API server	Access cloud resources
Compromised images in registry	bash/cmd inside container	Writable hostPath mount	Cluster-admin binding		Kubernetes IAMs	Access Kubelet API	Pod service account
Kubeconfig file	New container	Kubernetes CronJob	hostPath mount		Pod service account	Network mapping	Cluster internal networking
Application vulnerability		Malicious admission controller	Access to cloud resources		Applications credentials	Access Kubernetes dashboard	Application credentials
Exposed sensitive interfaces					Access managed identities credentials	Instance metadata API	Writable volume mounts on the host
Control plane + kubelet misconfiguration					Malicious admission controller		CoreDNS poisoning
							ARP poisoning and IP spoofing
							Container escape

Defence evasion

08

Defence evasion

1. Clear container logs
2. Delete Kubernetes events
3. Pod / container name squatting
4. Connect from a proxy server

Defence evasion

1. Clear container logs

2. Delete Kubernetes events

3. Pod / container name squatting

4. Connect from a proxy server

Defence evasion

1. Clear container logs
2. Delete Kubernetes events
3. **Pod / container name squatting**
4. Connect from a proxy server

Defence evasion

1. Clear container logs
2. Delete Kubernetes events
3. Pod / container name squatting
4. **Connect from a proxy server**

Defence evasion

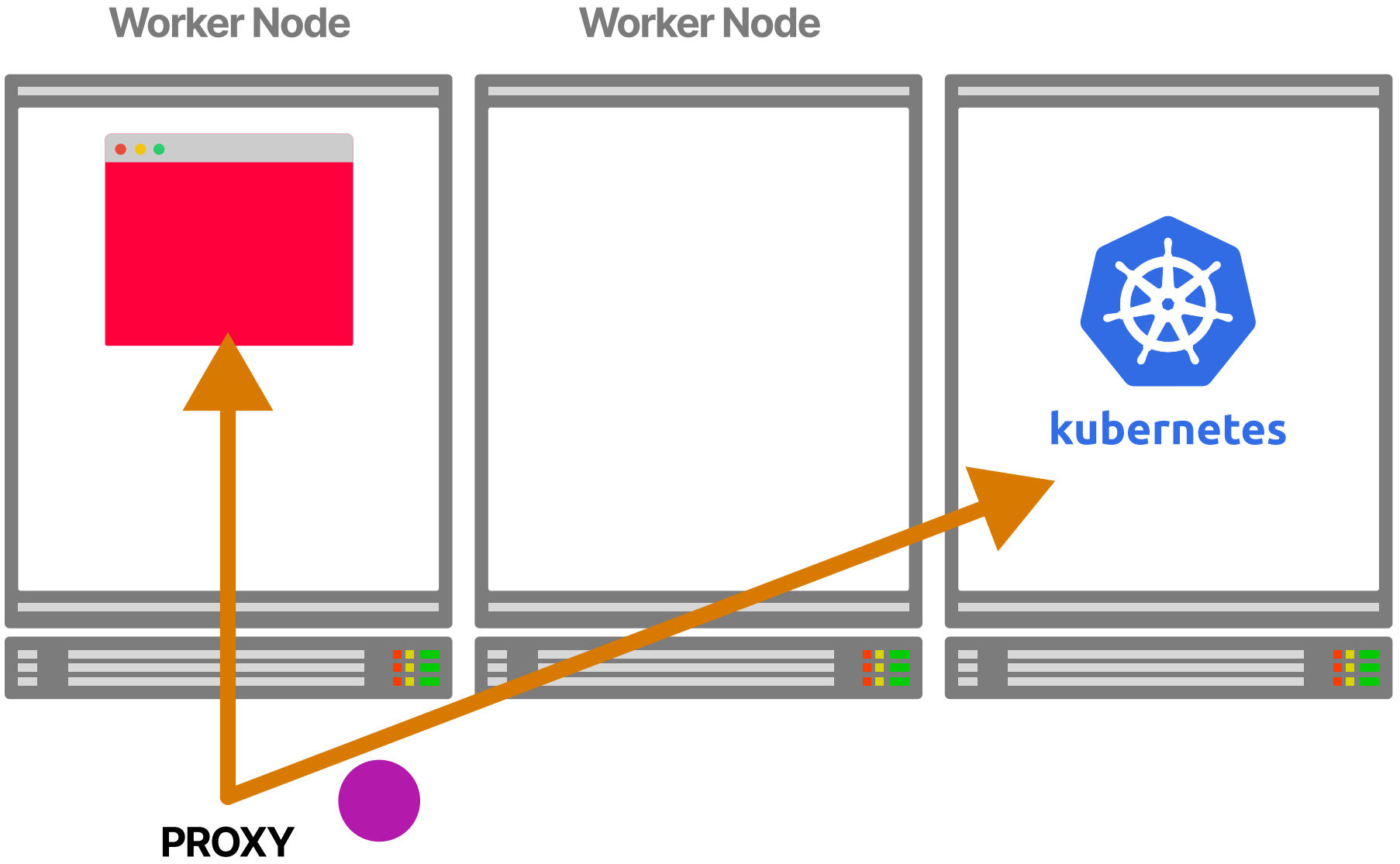
Clear container logs & delete Kubernetes events

```
apiVersion: audit.k8s.io/v1
kind: Policy
rules:
  # Log pod changes at RequestResponse level
  - level: RequestResponse
    resources:
    - group: ""
      # Resource "pods" doesn't match requests to any subresource
      # of pods, which is consistent with the RBAC policy.
      resources: ["pods"]
  # Log "pods/log", "pods/status" at Metadata level
  - level: Metadata
    resources:
    - group: ""
      resources: ["pods/log", "pods/status"]

  # Don't log requests to a configmap called "controller-leader"
  - level: None
    resources:
    - group: ""
      resources: ["configmaps"]
      resourceNames: ["controller-leader"]
```

Defence evasion

Connect from proxy server


Worker Node
Worker Node
kubernetes
PROXY

Connect from proxy server

NetworkPolicies

Encrypter cluster network

mTLS between Pods

Connect from proxy server

NetworkPolicies

Encrypter cluster network

mTLS between Pods

Connect from proxy server

NetworkPolicies

Encrypter cluster network

mTLS between Pods

Initial access	Execution	Persistence	Privilege escalation	Defense evasion	Credential Access	Discovery	Lateral movement
Using cloud credentials	Exec into container	Backdoor container	Priviliged container	Clear container logs	Kubernetes secrets	Access the Kubernetes API server	Access cloud resources
Compromised images in registry	bash/cmd inside container	Writable hostPath mount	Cluster-admin binding	Delete Kubernetes events	Kubernetes IAMs	Access Kubelet API	Pod service account
Kubeconfig file	New container	Kubernetes CronJob	hostPath mount	Pod / container name squatting	Pod service account	Network mapping	Cluster internal networking
Application vulnerability		Malicious admission controller	Access to cloud resources	Connect from proxy server	Applications credentials	Access Kubernetes dashboard	Application credentials
Exposed sensitive interfaces					Access managed identities credentials	Instance metadata API	Writable volume mounts on the host
Control plane + kubelet misconfiguration					Malicious admission controller		CoreDNS poisoning
							ARP poisoning and IP spoofing
							Container escape

Thanks.